UNIDAD 3:
Seguridad informática

SEGURIDAD EN REDES

- UNIDAD 3
- Seguridad en Redes de Información

CONTENIDOS

- Seguridad de la red.
- Seguridad en capa de transporte.
- Seguridad perimetral.
- Detección y prevención de intrusos.
- Seguridad en redes inalámbricas.
- Redes privadas virtuales.
- OSINT
- Criptografía.
- Funciones de hash.
- Infraestructura de clave pública.
- Firma digital.
- Estenografía.

UNIDAD 3:
Seguridad informática
SEGURIDAD PERIMETRAL

UNPAZ
Universidad Nacional de José C. Paz

Seguridad informática

Lic. en Gestión de Tecnologías de la Información

Mecanismos de protección y monitoreo

Se pueden utilizar distintas herramientas como mecanismo de protección y/o de monitoreo y control:

Algunos ejemplos:

– Herramientas para controlar accesos de red (FW)
– Herramientas para la detección de intrusiones (IDS)
– Herramientas para la prevención de intrusiones (IPS)
– Honeypots
– Otras herramientas: IDS de filesystems



Soluciones

- **Para delimitar el perímetro de seguridad de una red contamos con los dispositivos llamados “Firewalls”.**

- **Un firewall puede permitir o prohibir las comunicaciones que se hacen o se reciben.**

- **El control está basado en políticas definidas por la organización o el criterio del usuario que lo implementa.**



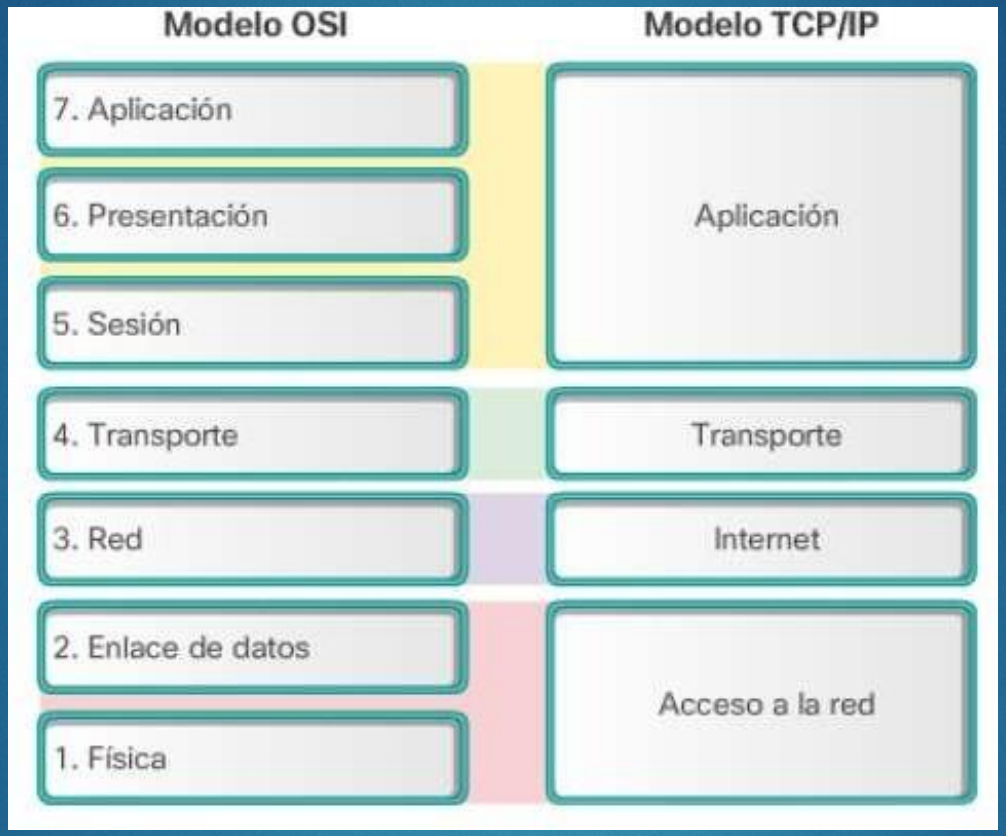
FIREWALL

Un **firewall** o cortafuegos es un dispositivo de hardware o software **que** nos permite gestionar y filtrar la totalidad de trafico entrante y saliente bloqueando los accesos no autorizados.



“ En un Firewall primero se deniega todo y se permite todo”



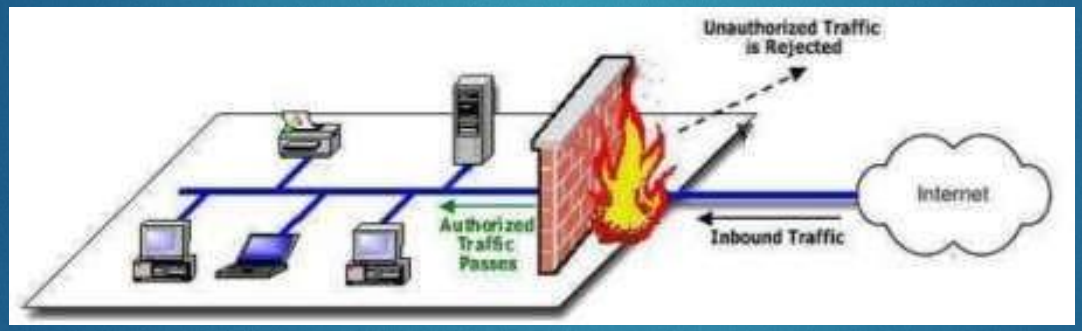

Modelo OSI
Modelo TCP/IP
7. Aplicación
6. Presentación
5. Sesión
4. Transporte
3. Red
2. Enlace de datos
1. Física
Aplicación
Transporte
Internet
Acceso a la red

FW de Host vs FW de Red

Firewall de Host: Cuando se aplican políticas de firewall un una PC o servidor



.Firewall de red: cuando se aplican políticas en un router para establecer politicas sobre una red.



FIREWALL

Contexto
La mayoría de las organizaciones dependen fuertemente de la tecnología y del acceso a Internet

- **Entre los dispositivos que se conectan a Internet podemos mencionar:**
  - Estaciones de trabajo
  - Servidores
  - Dispositivos móviles: Notebooks, Smartphones,**heladeras**.. etc.

- **Existe la necesidad de:**
  - Diseñar la red de modo de aislar servicios críticos de otros elementos más vulnerables. (Segmentación)
  - Gestionar controles de acceso entre las distintas red.

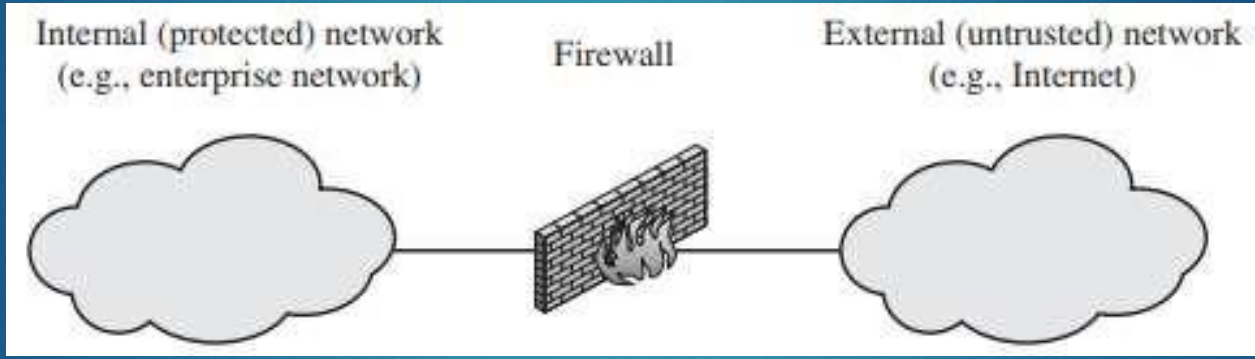
La segmentación permitirá proteger con tecnologías más adecuadas cada parte de la red. Esto ayuda a controlar mejor el grado de exposición y compromiso de cada parte.



FIREWALL

Ubicación de los Firewall

Un firewall está posicionado para proporcionar una barrera protectora entre una fuente de tráfico externa (potencialmente no confiable) y una red interna.



FIREWALL

Objetivos de diseño para un firewall:

Todo el tráfico de adentro hacia afuera, y viceversa, debe pasar por el firewall. Esto se logra bloqueando físicamente todo el acceso a la red local, excepto a través del firewall.

Solo se permitirá el paso del tráfico autorizado, según lo definido por la política de seguridad.

El firewall en sí mismo es inmune a la penetración. Esto implica el uso de un sistema reforzado con un sistema operativo seguro.



Diseño de la red

Se deberían separar por criticidad los hosts y servidores de una red en distintos segmentos de LAN:

- PC de usuarios
- Servidores externos (DNS, SMTP, WEB)
- Servidores internos (fileserver, intranet)
- Equipos WiFi

- **Teniendo esto en cuenta, los usuarios deberían estar en una red separada.**
- **Además, en caso de ser posible, la situación ideal es que los usuarios usen servidores proxy que hagan de proxy firewalls para controlar su actividad en Internet.**



FIREWALL

Políticas de acceso:

Filtrado de paquetes: Dirección IP y valores de protocolo: controla el acceso en función de las

direcciones de **origen** o **destino** y los **números de puerto**, la dirección del flujo **entrante** o **saliente**, y otras

características de la capa de red y transporte.

	Source Address	Souce Port	Dest Address	Dest Port	Action
1	Any	Any	192.168.1.0	>1023	Allow
2	192.168.1.1	Any	Any	Any	Deny
3	Any	Any	192.168.1.1	Any	Deny
4	192.168.1.0	Any	Any	Any	Allow
5	Any	Any	192.168.1.2	SMTP	Allow
6	Any	Any	192.168.1.3	HTTP	Allow
7	Any	Any	Any	Any	Deny

FIREWALL

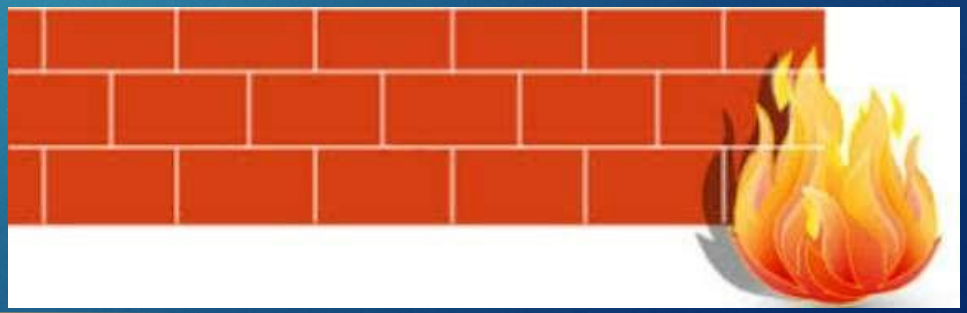
Características de un firewall: Capacidades

Un firewall define **un único punto** que intenta mantener a los usuarios no autorizados fuera de la red protegida, prohíbe que los servicios potencialmente vulnerables ingresen o salgan de la red.

El uso de un único punto **simplifica la gestión de seguridad** porque las capacidades de seguridad se consolidan en un único sistema o conjunto de sistemas.

Un firewall proporciona una ubicación para monitorear eventos relacionados con la seguridad. **Se centralizan los registros de ingreso y egreso de la red**.

El firewall se puede usar para implementar redes privadas virtuales (VPN).



FIREWALL

Características de un firewall: Limitaciones

- El firewall no puede proteger contra ataques que lo eluden.

- El firewall no puede proteger contra amenazas internas.

-El firewall no puede proteger contra amenazas que llegan desde un punto de acceso inalámbrico conectado a la red interna.

-El firewall no puede proteger contra una notebook que se infecta con virus fuera de la red de la organización.

-A diferencia del IDS o IPS el firewall estándar no identifica ataques en base a patrones o comportamientos.



FIREWALL

La DMZ (Desmilitarized Zone), es la red donde se alojan servidores de la organización que deben estar expuestos a Internet, por ejemplo:

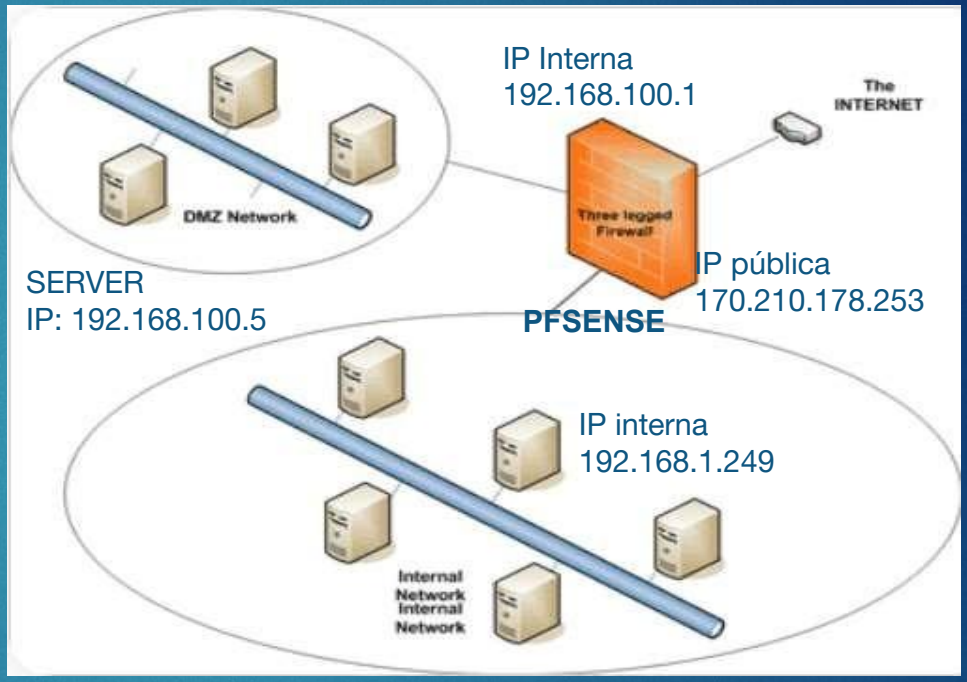
- **Servidor web , Mail server , DNS**

Ubicación de los Firewall

DMZ básica: Three legged firewall

En un mismo firewall se generan dos zonas. La zona desmilitarizada donde se alojan los servicios que deben ser accedidos desde internet y la zona interna donde se alojan los otros servicios.

Entre la DMZ y la zona interna se habilitan estrictamente los puertos mínimos necesarios.



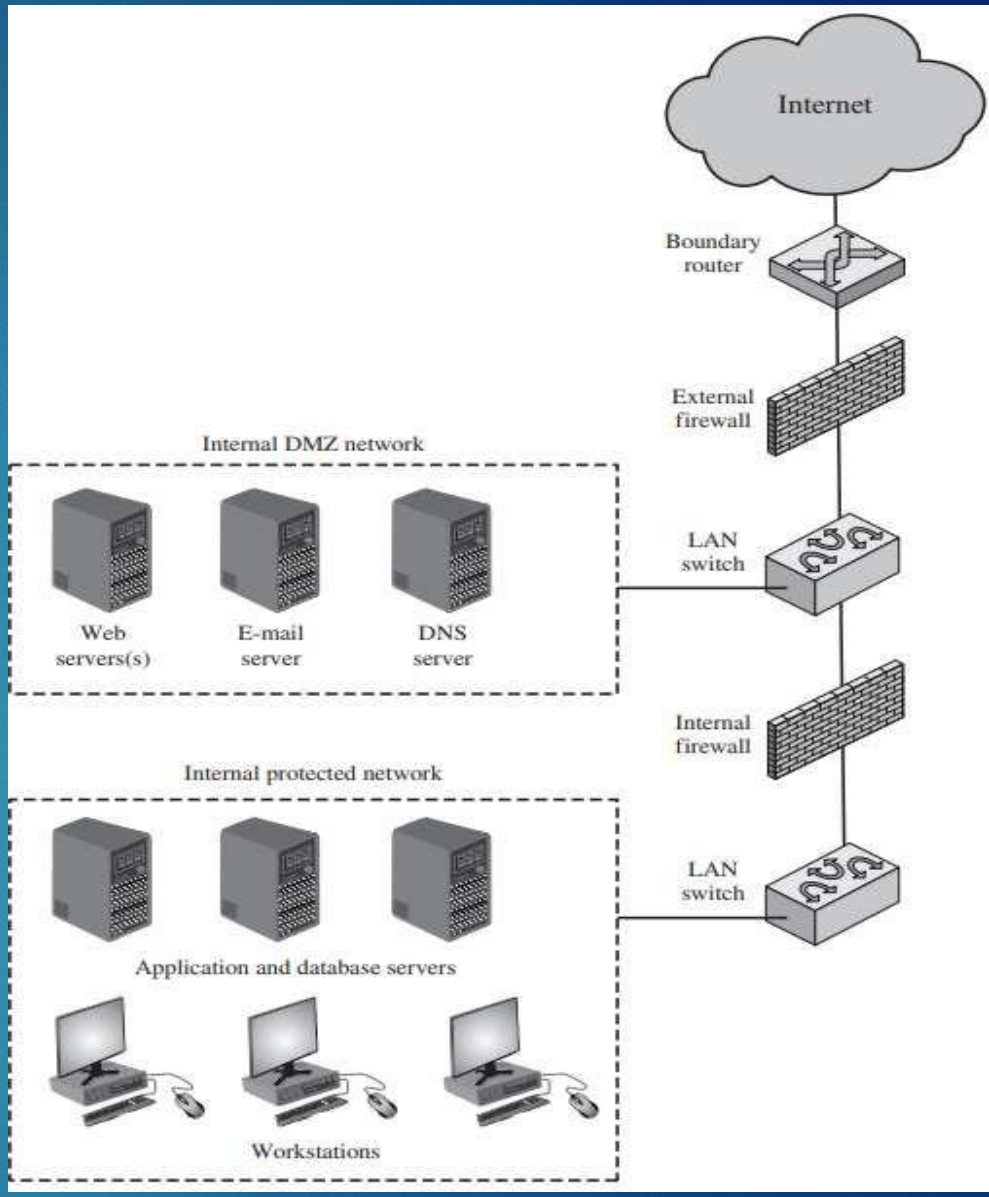
FIREWALL

Ubicación de los Firewall

DMZ: Front End / Firewall Interno

El firewall externo proporciona una medida de control de acceso y protección para los sistemas DMZ de acuerdo con su necesidad de conectividad externa.

El firewall interno brinda un nivel de protección mucho más estricto.



FIREWALL

Reglas

En todo firewall se definen reglas por protocolo, dirección y puerto de origen y destino. Todo tráfico que haga match con la regla es bloqueado o permitido según se haya definido. Siempre se recomienda por defecto DENEGAR todo y permitir solo lo estrictamente necesario.

Ver Laboratorio con Pfsense Instalado

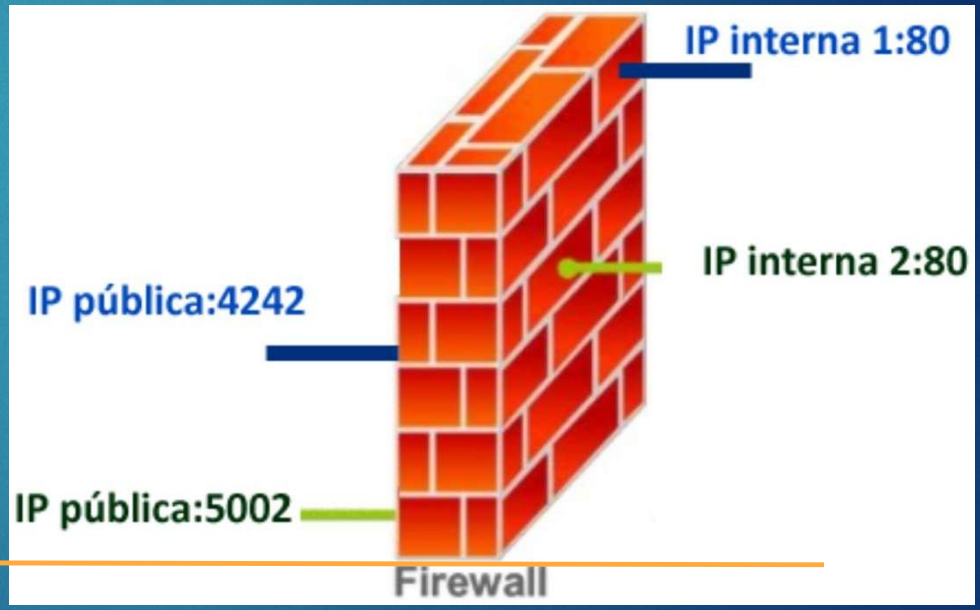


FIREWALL

NATEO

En el Nateo de puertos y direcciones el firewall realiza una “traducción” de una dirección IP de una red a la dirección correspondiente en otra red. Así mismo un puerto determinado puede traducirse en otro puerto diferente.

Se utiliza Nateo en la interfaz pública de un firewall para traducir la/s Ips públicas en las distintas IP internas, cambiar puertos por seguridad, entre otros.

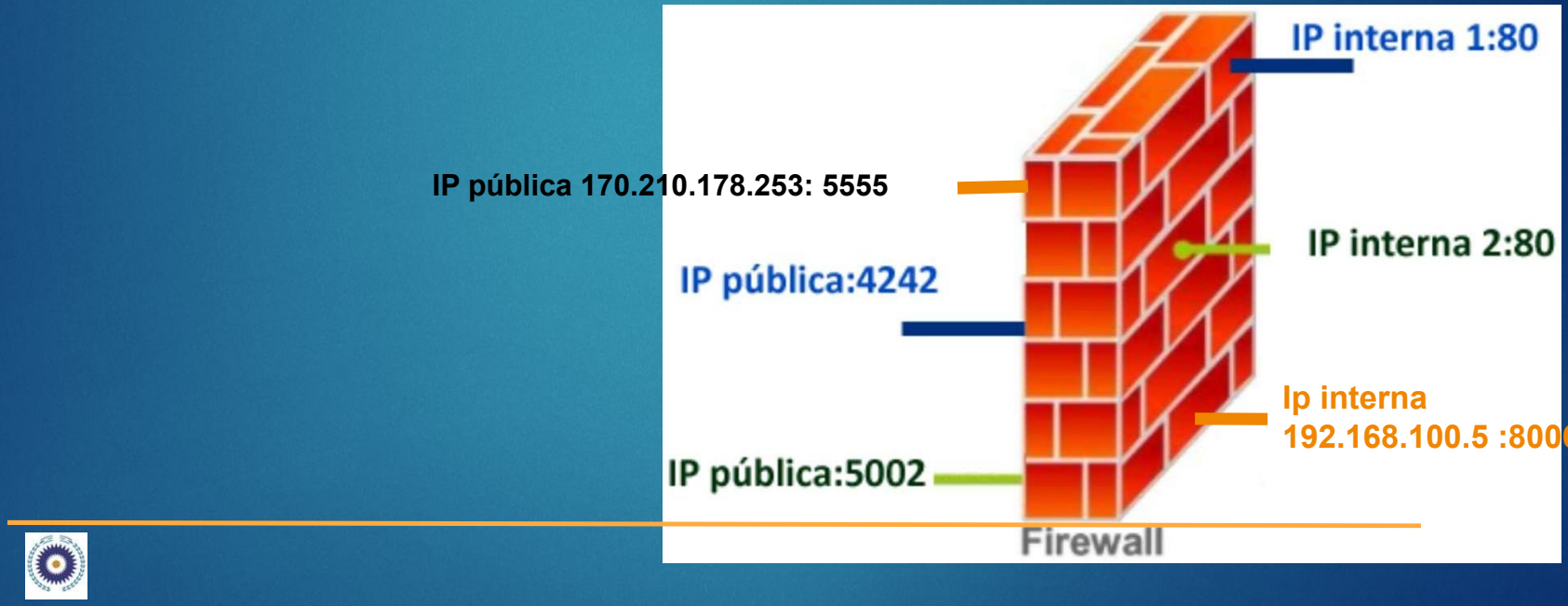


FIREWALL

NATEO

En el Nateo de puertos y direcciones el firewall realiza una “traducción” de una dirección IP de una red a la dirección correspondiente en otra red. Así mismo un puerto determinado puede traducirse en otro puerto diferente.

Se utiliza Nateo en la interfaz pública de un firewall para traducir la/s Ips públicas en las distintas IP internas, cambiar puertos por seguridad, entre otros.



Ejemplos de Firewalls

Firewalls de host o personales

– Permiten aplicar reglas de filtrado sobre los paquetes que intercambia una PC

- **Firewalls de red**

– Permiten aplicar reglas de filtrado sobre los paquetes intercambiados entre distintos segmentos de red

Firewalls físicos

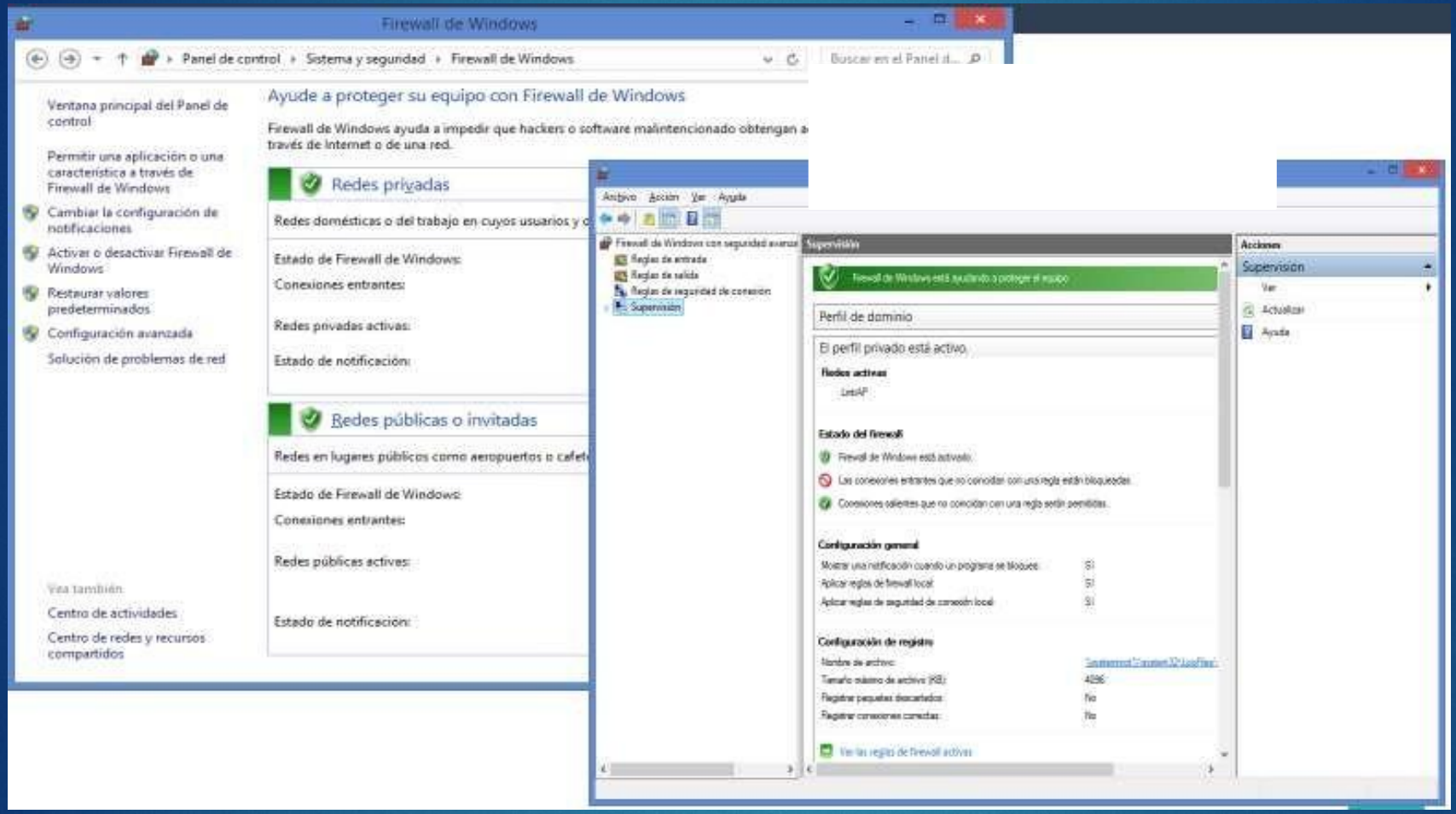
– Generalmente se colocan entre el router de la organización y la conexión a Internet. Tienen hardware y software optimizados para realizar las funciones de firewall.

- **Firewalls virtuales**

– Corre en un entorno virtualizado y puede ser utilizado como firewall tradicional o como firewall para el entorno de virtualización.



Firewall personal en Windows



Ejemplo Firewall de host con IPTables

Queremos una configuración de FW que:

- Permita a nuestro host iniciar cualquier comunicación.
- Que no permita a otros hosts iniciar comunicaciones hacia nuestro host

```
iptables -P INPUT DROP
iptables -P OUTPUT ACCEPT
```

sudo iptables –L
sudo apt-get install tcpdump



FIREWALL

Ubicación de los Firewall

DMZ: Front End + Honeypot / Firewall Interno

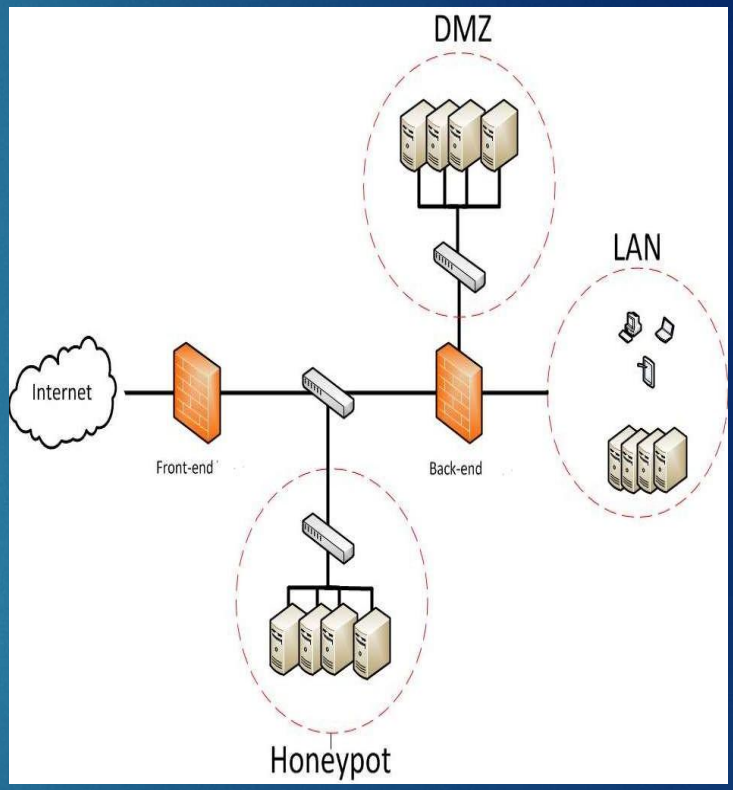
Otros esquemas de red pueden incluir varios firewalls, con varios zonas.

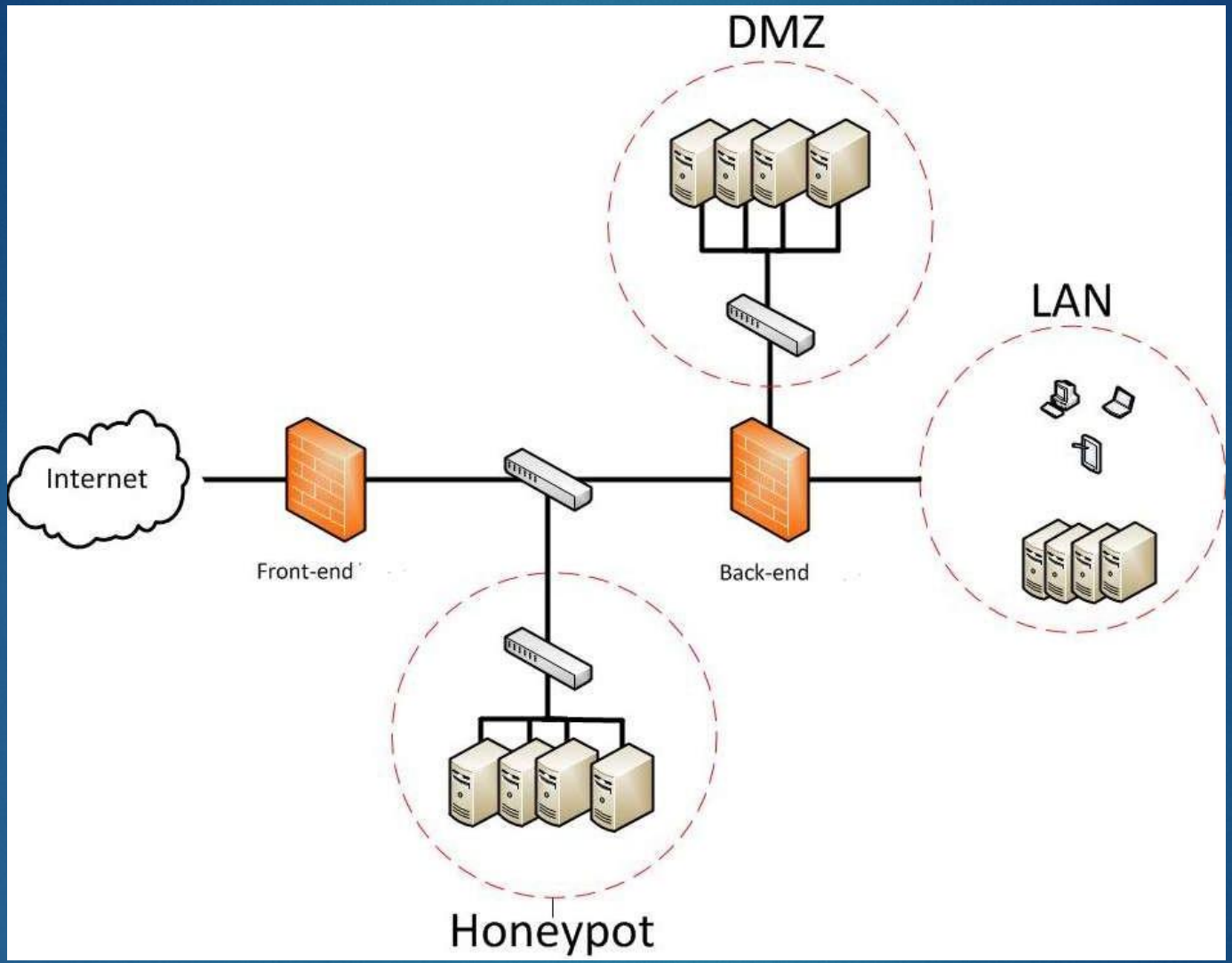
Los honeypot suelen usarse en un esquema complejo con varios firewalls.

-Los Honeypots son sistemas señuelo diseñados para atraer a un atacante potencial lejos de los sistemas críticos.

- Recopilar información sobre la actividad del atacante.

-Animar al atacante a permanecer en el sistema el tiempo suficiente para que los administradores respondan.




DMZ
LAN
Internet
Front-end
Back-end
Honeypot

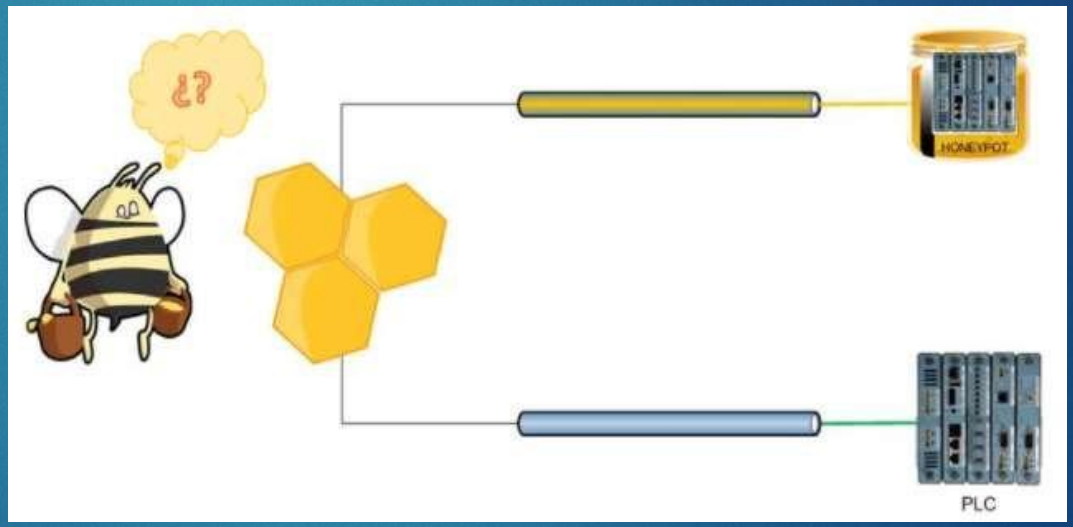
Honeypots



Es una herramienta que puede simular uno o más hosts vulnerables, siendo un blanco fácil de atacar.

Dado que los mismos no son reales, cualquier intento de conexión es sospechoso:

- Ataque
- Prueba
- Escaneo



Honeypots

"Todo arte de la guerra se basa en el engaño"

Permiten detectar ataques con un alto grado de certeza

Alternativamente pueden ser diseñados para ser comprometidos con el objeto de aprender sobre herramientas, tácticas y motivaciones que alientan a los intrusos.

Pueden ser usados para:

- Detección de actividad no autorizada
  - Prevención
  - Gestión de incidentes detectados
- Análisis e investigación de técnicas, herramientas...



Ampliando Honeypots

Ventajas:

- Gran valor de los datos de actividad recolectados.
- Uso de los recursos: no requieren tecnología de punta.
- Simplicidad

Desventajas

- Fingerprinting: Hay patrones y características que delatan su propósito.
- Riesgo: agregan un riesgo adicional ya que si son comprometidos pueden ser usados para atacar

De acuerdo al nivel de interacción que tendrá el atacante con el honeypot, los mismos pueden clasificarse como :

- Honeypots de baja interacción
- Honeypots de alta interacción



Ampliando Honeypots

Características de HoneyPots

De baja interacción:

- **Emulación** de servicios
- Fáciles de implantar, configurar, mantener y monitorear.
- Reunión de poca información.
- **Funcionalidad reducida**
- Su principal propósito es detectar escaneos e intentos de sesión no autorizados.
- Bajo riesgo.

De alta interacción:

- **Equipo real** con servicios reales
- **Se reúne bastante información sobre la actividad del intruso.**
- Difíciles de implantar, configurar, mantener y monitorear.
- Para mitigar riesgos se colocan dentro de un ambiente controlado, por ejemplo detrás de un firewall.
- Control de tráfico de salida
- Alto riesgo



VPN

Red Privada Virtual

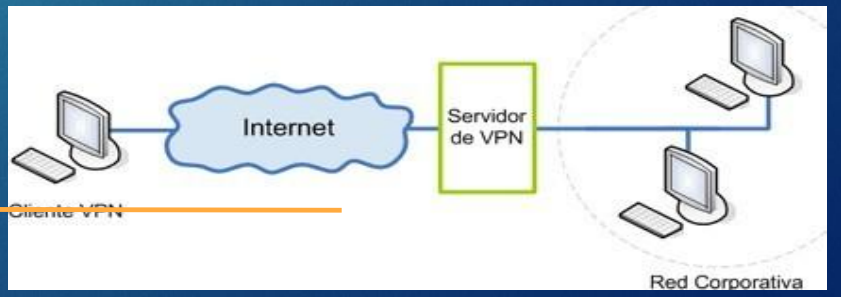
Una VPN consiste en un conjunto de computadoras que se interconectan por medio de una red relativamente insegura y que utilizan cifrado y protocolos especiales para proporcionar seguridad.

Protocolos para VPN

IPsec (Internet Protocol Security): permite mejorar la seguridad a través de algoritmos de cifrado robustos y un sistema de autentificación más exhaustivo.

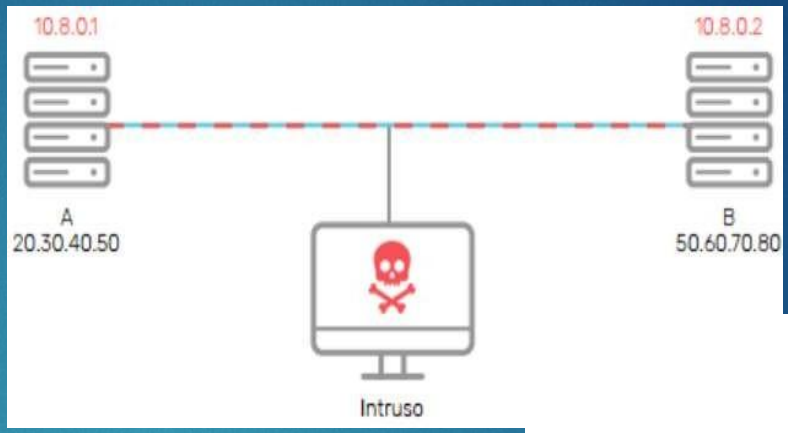
PPTP/MPPE: tecnología desarrollada por un consorcio formado por varias empresas. PPTP soporta varios protocolos VPN con cifrado de 40 bit y 128 bit utilizando el protocolo Microsoft Point to Point Encryption (MPPE).

L2TP/IPsec (L2TP sobre IPsec): tecnología capaz de proveer el nivel de protección de IPsec sobre el protocolo de túnel L2TP.

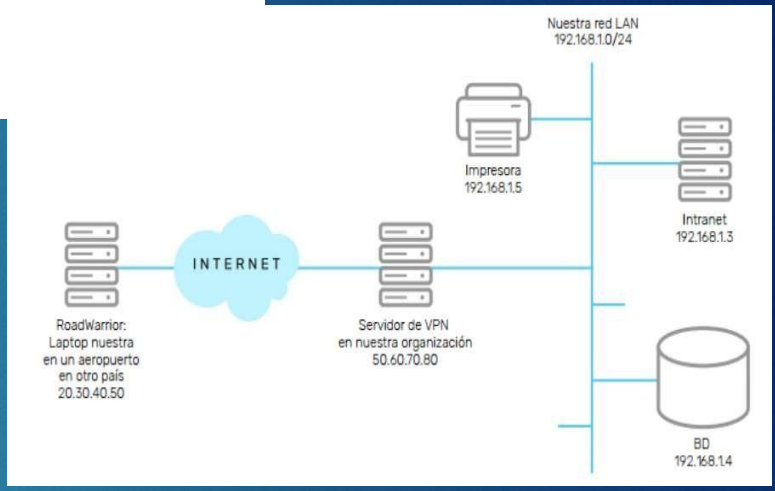


Tipos de VPN

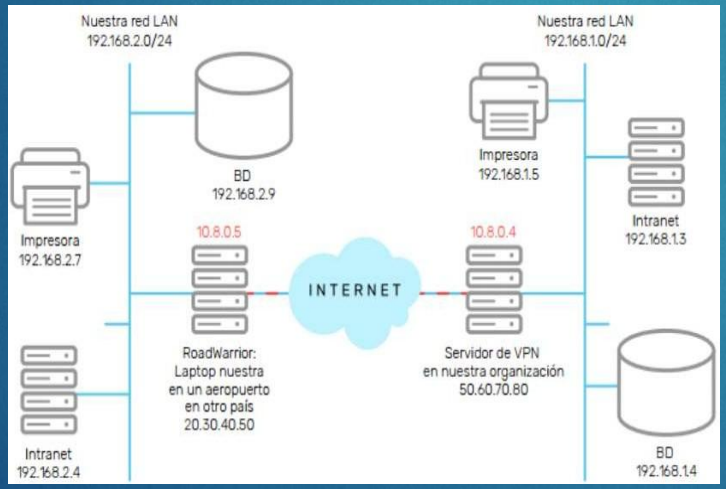
VPN de punto a punto o PC a PC



VPN de host a red o RoadWarrior (guerrero de la carretera)



Red a Red



IDS / IPS

En la seguridad física de una organización, **un firewall** es el equivalente a instalar una cerca alrededor de la propiedad con un custodio en la puerta de acceso.

Por otro lado, **un IDS** es el equivalente a las cámaras, sensores y alarmas internas que existen dentro de la propiedad. Estos guardan y analizan la información que reciben para detectar patrones de comportamiento sospechoso



IDS / IPS

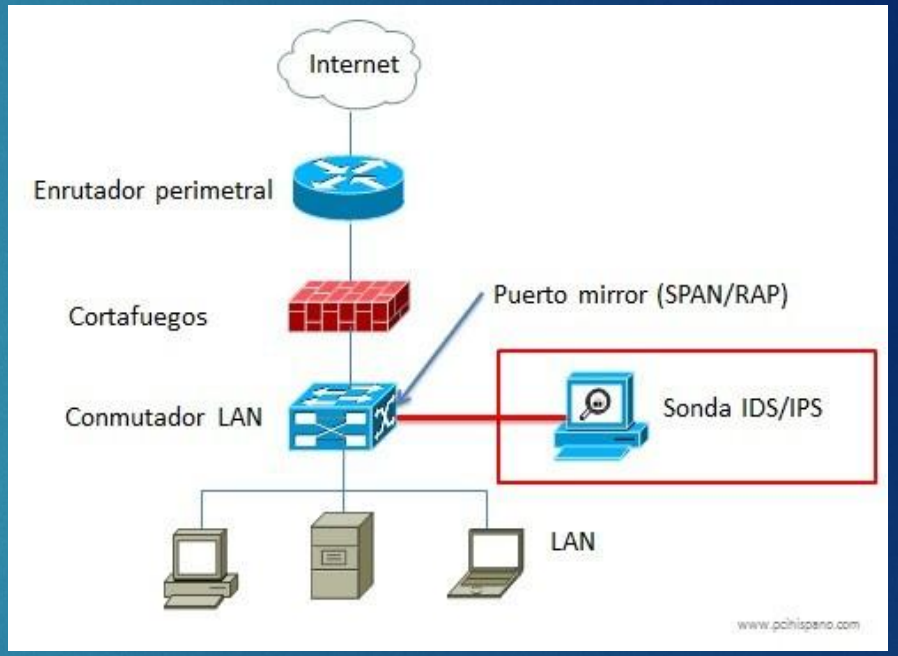
IDS o Intrusion Detection System

- La detección de intrusiones es el arte de detectar actividad sospechosa, incorrecta o inapropiada.

IPS o Intrusion Prevention System

- Los IPS son mecanismos de defensa proactivos diseñados para detectar actividad maliciosa y detener intrusiones, bloqueando dicha actividad “ofensiva” automáticamente antes de que realice algún daño.

Un antivirus es un ejemplo de un IPS



IDS

Un sistema de detección de intrusiones es un programa de detección de accesos no autorizados a un computador o a una red.

A diferencia del firewall el IDS analiza el contenido de los paquetes y toma acciones en base a ellos.

Un software IDS reconocido es SNORT.

```
01/10-13:52:32.440936 192.168.90.1 -> 192.168.90.134
ICMP TTL:64 TOS:0x0 ID:0 IpLen:20 DgmLen:84 DF
Type:8  Code:0  ID:976  Seq:1  ECHO
=+=+=+
```

AMPLIANDO IDS

TIPOS DE IDS

- Basados en red
- Basados en host
- Basados en filesystem



Ampliando IDS

TIPOS DE IDS

Basados en red





- IDS DE RED

- Monitorean todo el tráfico que pasa por un segmento de red en el que el IDS se encuentre.
- Reaccionan ante cualquier anomalía o signo de actividad sospechosa.
- Básicamente es un sniffer que busca patrones de ataq en los paquetes observados.



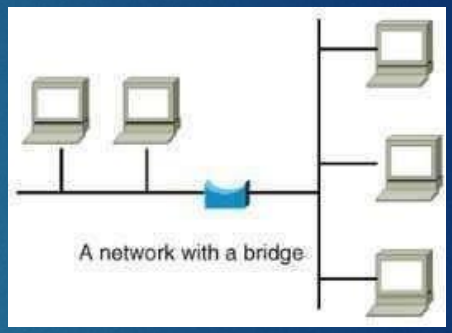
- **Ejemplo:** Snort, Zeek (BRO-IDS), Suricata



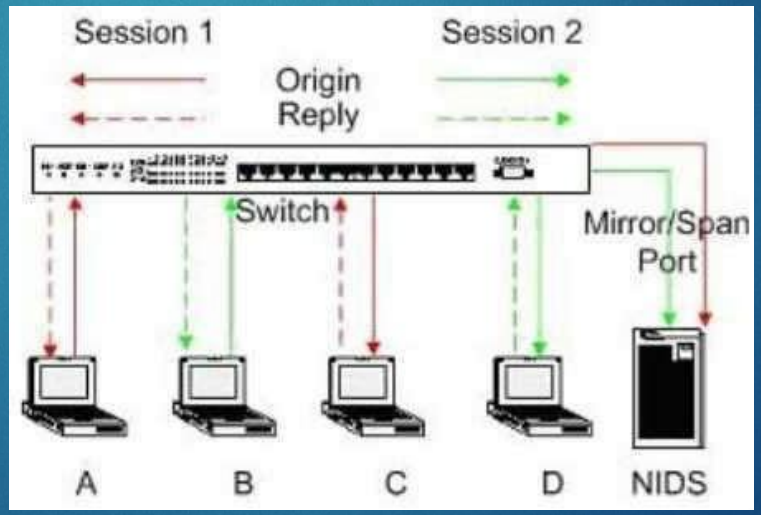
Ampliando IDS

TIPOS DE IDS

Basados en red



- **IDS de red o NIDS**
- **¿Cómo obtener el tráfico para monitorear?**
  - HUB
  - Puerto de SPAN (Security Port Analizer) en el Switch
  - Modo Inline



Ampliando IDS

TIPOS DE IDS

Basados en red | Basados en host | Basados en filesystem

LOGs SNORT

```
[**] [1:1421:11] SNMP AgentX/tcp request [**]
[Classification: Attempted Information Leak] [Priority: 2]
06/16-14:36:23.741771 172.16.1.203:49119 -> 172.16.1.202:705
TCP TTL:51 TOS:0x0 ID:50484 IpLen:20 DgmLen:44
******S* Seq: 0x7CBA7ABE  Ack: 0x0  Win: 0x400  TcpLen: 24
TCP Options (1) => MSS: 1460
[Xref => http://cve.mitre.org/cgi-bin/cvename.cgi?name=2002-0013][Xref => htt
p://cve.mitre.org/cgi-bin/cvename.cgi?name=2002-0012][Xref => http://www.secu
rityfocus.com/bid/4132][Xref => http://www.securityfocus.com/bid/4089][Xref =
> http://www.securityfocus.com/bid/4088]

[**] [1:1418:11] SNMP request tcp [**]
[Classification: Attempted Information Leak] [Priority: 2]
06/16-14:36:23.908504 172.16.1.203:49119 -> 172.16.1.202:161
TCP TTL:49 TOS:0x0 ID:63978 IpLen:20 DgmLen:44
******S* Seq: 0x7CBA7ABE  Ack: 0x0  Win: 0x400  TcpLen: 24
TCP Options (1) => MSS: 1460
[Xref => http://cve.mitre.org/cgi-bin/cvename.cgi?name=2002-0013][Xref => htt
p://cve.mitre.org/cgi-bin/cvename.cgi?name=2002-0012][Xref => http://www.secu
rityfocus.com/bid/4132][Xref => http://www.securityfocus.com/bid/4089][Xref =
> http://www.securityfocus.com/bid/4088]
```

Ampliando IDS

TIPOS DE IDS

Basados en red | Basados en host | Basados en filesystem

SNORT rules

```
nico@nico-PORTEGE-Z30-B:/etc/snort/rules$ ls
attack-responses.rules          community-nntp.rules          deleted.rules       netbios.rules     sql.rules
backdoor.rules                  community-oracle.rules        dns.rules           nntp.rules        telnet.rules
bad-traffic.rules               community-policy.rules        dos.rules           oracle.rules      tftp.rules
chat.rules                      community-sip.rules           experimental.rules  other-ids.rules   virus.rules
community-bot.rules             community-smtp.rules          exploit.rules       p2p.rules         web-attacks.rules
community-deleted.rules         community-sql-injection.rules finger.rules        policy.rules      web-cgi.rules
community-dos.rules             community-virus.rules         ftp.rules           pop2.rules        web-client.rules
community-exploit.rules         community-web-attacks.rules   icmp-info.rules     pop3.rules        web-coldfusion.rules
community-ftp.rules             community-web-cgi.rules       icmp.rules          porn.rules        web-frontpage.rules
community-game.rules            community-web-client.rules    imap.rules          rpc.rules         web-iis.rules
community-icmp.rules            community-web-dos.rules       info.rules          rservices.rules   web-misc.rules
community-imap.rules            community-web-iis.rules       local.rules         scan.rules        web-php.rules
community-inappropriate.rules   community-web-misc.rules      misc.rules          shellcode.rules   x11.rules
community-mail-client.rules     community-web-php.rules       multimedia.rules    smtp.rules
community-misc.rules            ddos.rules                    mysql.rules         snmp.rules
nico@nico-PORTEGE-Z30-B:/etc/snort/rules$
```

```
alert udp $EXTERNAL_NET any -> $HOME_NET 161 (msg:"SNMP request udp"; reference:bugtraq,4088; reference:bugtraq,4089; reference:bugtraq,4132; reference:cve,2002-0012; reference:cve,2002-0013; classtype:attempted-recon; sid:1417; rev:9;)
alert tcp $EXTERNAL_NET any -> $HOME_NET 161 (msg:"SNMP request tcp"; flow:stateless; reference:bugtraq,4088; reference:bugtraq,4089; reference:bugtraq,4132; reference:cve,2002-0012; reference:cve,2002-0013; classtype:attempted-recon; sid:1418; rev:11;)
alert udp $EXTERNAL_NET any -> $HOME_NET 162 (msg:"SNMP trap udp"; reference:bugtraq,4088; reference:bugtraq,4089; reference:bugtraq,4132; reference:cve,2002-0012; reference:cve,2002-0013; classtype:attempted-recon; sid:1419; rev:9;)
alert tcp $EXTERNAL_NET any -> $HOME_NET 162 (msg:"SNMP trap tcp"; flow:stateless; reference:bugtraq,4088; reference:bugtraq,4089; reference:bugtraq,4132; reference:cve,2002-0012; reference:cve,2002-0013; classtype:attempted-recon; sid:1420; rev:11;)
```

Ampliando IDS

TIPOS DE IDS

Basados en red | Basados en host | Basados en filesystem

red

LOGs BRO-IDS - Zeek

```
#separator \x09
#set_separator  ,
#empty_field    (empty)
#unset_field    -
#path   dns
#open   2017-11-01-11-00-13

#fields ts      uid     id.orig_h       id.orig_p       id.resp_h       id.resp_p       proto   trans_id        rtt     query   qclass
qclass_name     qtype   qtype_name      rcode   rcode_name      AA      TC      RDRA    Z       answers TTLs    rejected

#types  time    string  addr    port    addr    port    enum    count   interval        string  count   string  count   string  count   string
bool    bool    bool    bool    count   vector[string]  vector[interval]        bool
1509548389.658335       CIEYtjaCncTwoCOxe       192.168.95.199  42888   8.8.8.8 53      udp     15590   -
    www.google.com  -       -       -       0       NOERROR F       F       F       T       0
  172.217.28.164  68.000000       F
1509548389.669791       Cco9ic3rIBoyonCsQf      192.168.23.138  61366   8.8.8.8 53      udp     44069   -
    googlemail.l.google.com -       -       -       0       NOERROR F       F       F       T
  0       172.217.30.165  299.000000      F
1509548399.466479       Ca35Ky4VLmmejhFi7       192.168.72.101  37136   8.8.8.8 53      udp     40675   0.2
34620       96.102.170.113.cbl.abuseat.org  1       C_INTERNET      16      TXT     0       NOERROR F
  F       T       T       1       TXT 65 Blocked - see http://www.abuseat.org/lookup.cgi?ip=113.170.102.96
      2099.000000     F
1509548399.603786       CCOvEg32STXOr2zEI6      192.168.72.101  55620   8.8.8.8 53      udp     43573   0.1
72624       setup.update.avg.com    1       C_INTERNET      1       A       0       NOERROR F       F
  T       T       1       update.avg.com.edgekey.net,e11023.a.akamaiedge.net,104.104.17.151       135.00000
0,20666.000000,19.000000        F
1509548389.791128       CYEuCr2pWj0mLtjLuf      192.168.1.34    49209   8.8.8.8 53      udp     42758   -
    gob.ar  -       -       -       0       NOERROR F       F       F       T       0       ar.cct
ld.authdns.ripe.net,a.dns.ar,ns2.switch.ch,e.dns.ar,b.dns.ar,c.dns.ar     1607.000000,1607.000000,1607.0000
00,1607.000000,1607.000000,1607.000000 F
1509548389.815330       Clw9144tzfekcBmDCa      192.168.1.34    23988   8.8.8.8 53      udp     3027    -
    inta.gob.ar     -       -       -       0       NOERROR F       F       F       T       0
  200.61.223.6    48.000000       F
1509548389.901357       CM5vEk4v80063x34Le      192.168.23.138  55810   8.8.8.8 53      udp     2500    -
    googlemail.l.google.com -       -       -       0       NOERROR F       F       F       T
  0       2800:3f0:4002:807::2005 299.000000      F
```

Ampliando IDS

TIPOS DE IDS

Basados en red | Basados en host | Basados en filesystem



IDS de Host

- Monitorea y analiza diferentes aspectos del host en el que funciona.
- Hace una evaluación constante del estado general del sistema.
- Entre sus ventajas podemos mencionar la detección de patrones de ataques en tiempo real, pudiendo evitarlos (IPS) y reportarlos.

Ejemplos: OSSEC, Fail2ban, SAMHAIN, firewalls personales, etc.

TIPOS DE IDS

Ampliando IDS

Basados en red | Basados en host | Basados en filesystem

IDS de Host

Entre las caracteristicas que se evaluan, se pueden mencionar:

- Monitoreo y análisis de logs,
- Actividad de programas en ejecución,
- Estado de la red,
- Detección de rootkits,
- Detección de procesos ocultos,
- Monitoreo de la registry de Windows,
- Etc.

TIPOS DE IDS

Ampliando IDS

Basados en red Basados en host Basados en filesystem

IDS de filesystem

Cuando la seguridad de un sistema es comprometida, el atacante generalmente altera ciertos archivos claves para asegurarse nuevamente el acceso y para prevenir que lo detecten.

Un IDS basado en filesystem registra todas las propiedades de los elementos del filesystem para luego verificar periódicamente que cosas cambiaron.

Los cambios podrían ser una indicación de compromiso.

Ejemplo: Tripwire, OSSEC, SAMHAIN

TIPOS DE IDS

Ampliando IDS

Basados en red Basados en host Basados en filesystem

IDS de filesystem

Este tipo de herramientas puede detectar archivos o directorios con cambios sobre alguno de sus atributos del filesystem:

- Inodo
- Owner: Usuario y grupo
- Permisos
- Tiempos de acceso, modificación
- Tamaño
- Checksums

TIPOS DE IDS

Ampliando IDS

Basados en red Basados en host [illegible]

Basados en filesystem

Reporte de Tripwire

```
  Rule Name                         Severity Level    Added    Removed  Modified
  ---------                         --------------    -----    -------  --------
  Invariant Directories             66                0        0        0
  Tripwire Data Files               100               0        0        0
  Other binaries                    66                0        0        0
  Tripwire Binaries                 100               0        0        0
  Other libraries                   66                0        0        0
  Root file-system executables      100               0        0        0
  System boot changes               100               0
  Root file-system libraries        100               0
  (/lib)
  Critical system boot files        100               0
* Other configuration files         66                0
  (/etc)
  Boot Scripts                      100               0
  Security Control                  66                0
* Root config files                 100               0
  Devices & Kernel information      100               0
  (/dev)

Total objects scanned:  12253
Total violations found:  5
```

```
-------------------------------------------------------------------------------
Rule Name: Root config files (/root)
Severity Level: 100
-------------------------------------------------------------------------------
  ---------------------------------------
  Modified Objects: 2
  ---------------------------------------

Modified object name:  /root/.ssh/known_hosts

  Property:            Expected                    Observed
  ------------         -----------                 -----------
* Size                 1326                        1768
* Modify Time          Mon Dec  9 12:25:54 2013    Tue Dec 10 12:53:21 2013
* Change Time          Mon Dec  9 12:25:54 2013    Tue Dec 10 12:53:21 2013
* CRC32                C22e8G                      Cl9aWO
* MD5                  AihWs1J+C8uA4yWNHL7Uhy      Bpz8hem9DoB8wRMX8+hmEy
```

TIPOS DE IDS

Ampliando IDS

Basados en red

Basados en host

Basados en filesystem

filesystem

Reporte de OSSEC

De OSSEC HIDS <ossecm@notebook>

Asunto **OSSEC Notification - notebook - Alert level 7**

A Einar Felipe Lanfranco

```
OSSEC HIDS Notification.
2011 Jan 19 15:44:11

Received From: notebook->syscheck
Rule: 551 fired (level 7) -> "Integrity checksum changed again (2nd time)."
Portion of the log(s):

Integrity checksum changed for: '/etc/shadow'
Old md5sum was: 'ba39d79ce748e6aa5e801f7576febaff'
New md5sum is : '0ac7d7bd5b15fa0dfc26d2739487a721'
Old sha1sum was: 'd989e153871e6b9bafc5de194e6749b38a86dd64'
New sha1sum is : '3dfe3dab6a9f721ccbe18244c901d0245d9c1ef7'


--END OF NOTIFICATION
```

Ampliando IDS

TIPOS DE IDS

Basados en red

Basados en host

Basados en filesystem

filesystem

Md5

https://huayra.educar.gob.ar/descargas/

md5sum

UNIDAD 3:
Seguridad informática

DESCUBRIMIENTO

Seguridad informática

Lic. en Gestión de Tecnologías de la Información

OSINT

Acrónimo de Open Source Intelligence o inteligencia de fuentes abiertas.
Conjunto de técnicas y herramientas para recopilar información pública, correlacionar los datos y procesarlos.

OSINT en PHISHING

https://ar.linkedin.com

https://app.arba.gov.ar/AvisoDeudas http://www8.arba.gov.ar/AvisoDeudas/?imp=1

https://www.buenosaires.gob.ar/consulta-de-infracciones

https://servicioscf.afip.gob.ar/publico/crmcit/consulta.aspx

https://www.cuitonline.com

https://pipl.com

https://hunter.io/

Ver video de redes sociales. (https://www.youtube.com/watch?v=j-tFoYNHi1w)

PENETRATION TESTING

(Pentesting, Ethical Hacking)

Método que permite evaluar la seguridad de un sistema de información o de red simulando ataques como intrusos externos o internos.

- **Explotar vulnerabilidades y mucho más**
- **AUTORIZADO.**
- **ÉTICO (Para propósitos defensivos).**
- **En general, mucho procedimiento manual.**



FASES DEL ETHICAL HACKING (CEH)

1. Reconocimiento
2. Escaneo
3. Ganando acceso
4. Manteniendo acceso
5. Borrando Huellas



RECONOCIMIENTO

Se puede usar distintas técnicas para llevar a cabo el reconocimiento de un objetivo. Se intenta recolectar la mayor cantidad de información posible en la fase de preparación del ataque.

Objetivos

Conocer la postura de seguridad del objetivo Para reducir el área de enfoque

Identificar vulnerabilidades Dibujar mapa de red



TÉCNICAS DE RECONOCIMIENTO

Las técnicas pueden ser **ACTIVAS** (intrusivas) o **PASIVAS** (no intrusivas)

OSINT
Buscadores de Internet
Google Hacking
Footprinting
Ingeniería Social



OSINT

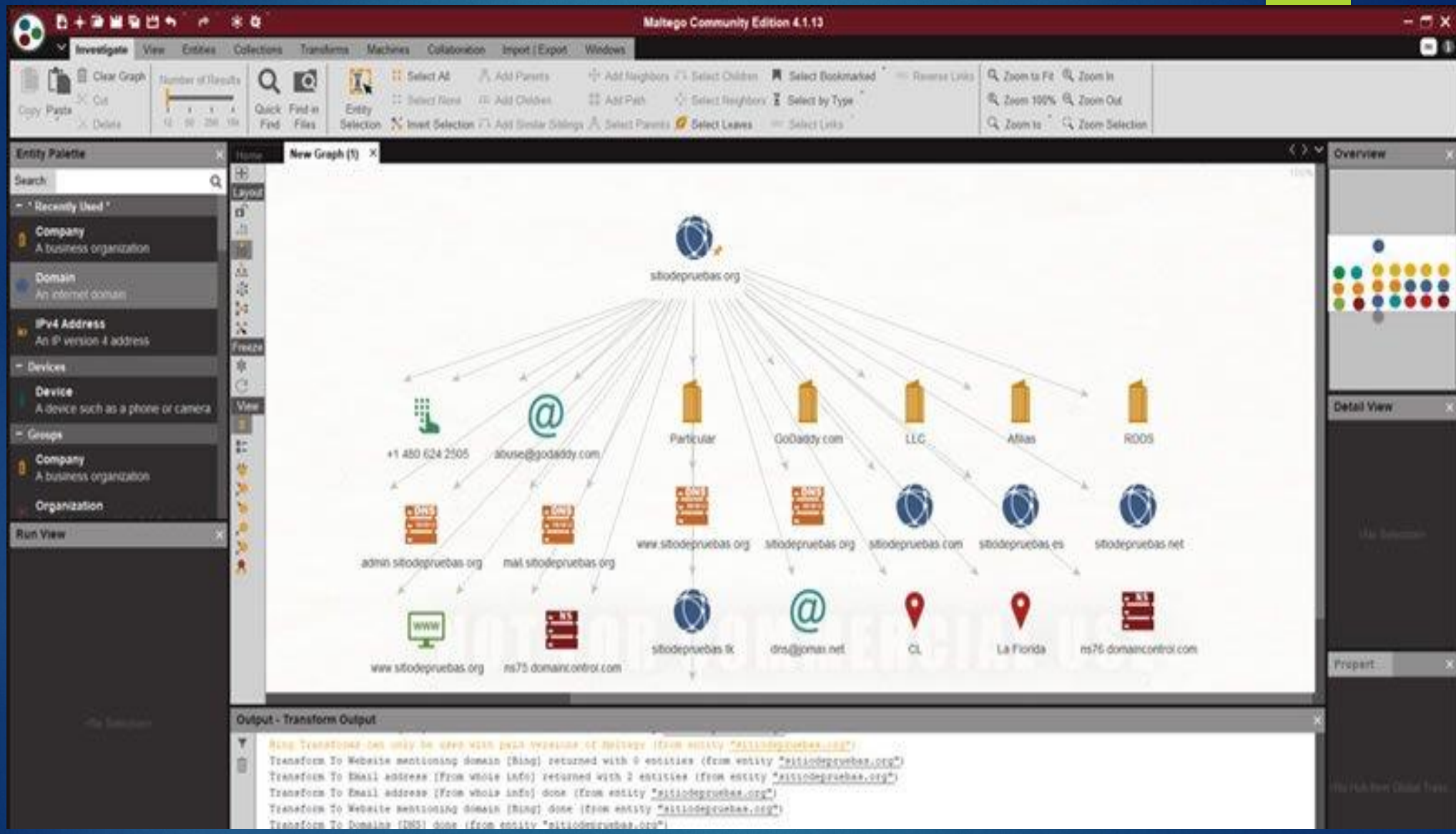
Acrónimo de Open Source Intelligence o inteligencia de fuentes abiertas. (aplicar inteligencia sobre fuentes abiertas)

Conjunto de técnicas y herramientas para recopilar información pública, correlacionar los datos y procesarlos

-Conocer la reputación online de un usuario o empresa.
-Realizar estudios sociológicos, psicológicos, lingüísticos, etc.
-Auditoría de empresas y diferentes organismos con el objetivo de evaluar el nivel de privacidad y seguridad.

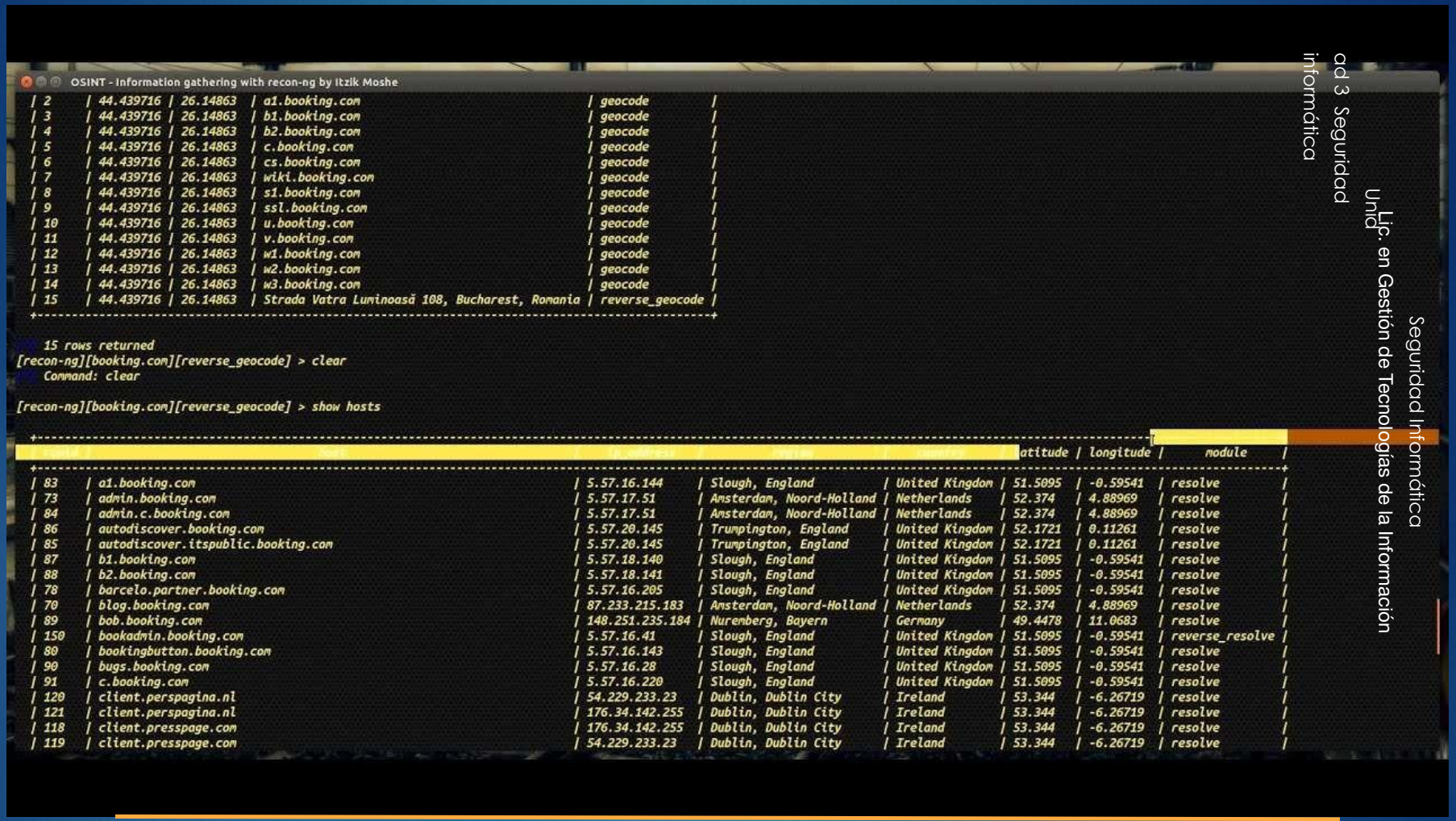


MALTEGO



Ver video de Maltego: https://www.youtube.com/watch?v=Ph_KmKY1yEM

RECON -NG


OSINT - Information gathering with recon-ng by Itzik Moshe
2	44.439716	26.14863	a1.booking.com	geocode
3	44.439716	26.14863	b1.booking.com	geocode
4	44.439716	26.14863	b2.booking.com	geocode
5	44.439716	26.14863	c.booking.com	geocode
6	44.439716	26.14863	cs.booking.com	geocode
7	44.439716	26.14863	wiki.booking.com	geocode
8	44.439716	26.14863	s1.booking.com	geocode
9	44.439716	26.14863	ssl.booking.com	geocode
10	44.439716	26.14863	u.booking.com	geocode
11	44.439716	26.14863	v.booking.com	geocode
12	44.439716	26.14863	w1.booking.com	geocode
13	44.439716	26.14863	w2.booking.com	geocode
14	44.439716	26.14863	w3.booking.com	geocode
15	44.439716	26.14863	Strada Vatra Luminoasă 108, Bucharest, Romania	reverse_geocode
15 rows returned
[recon-ng][booking.com][reverse_geocode] > clear
Command: clear
[recon-ng][booking.com][reverse_geocode] > show hosts
rowid	host	ip_address	region	country	latitude	longitude	module
83	a1.booking.com	5.57.16.144	Slough, England	United Kingdom	51.5095	-0.59541	resolve
73	admin.booking.com	5.57.17.51	Amsterdam, Noord-Holland	Netherlands	52.374	4.88969	resolve
84	admin.c.booking.com	5.57.17.51	Amsterdam, Noord-Holland	Netherlands	52.374	4.88969	resolve
86	autodiscover.booking.com	5.57.20.145	Trumpington, England	United Kingdom	52.1721	0.11261	resolve
85	autodiscover.itspublic.booking.com	5.57.20.145	Trumpington, England	United Kingdom	52.1721	0.11261	resolve
87	b1.booking.com	5.57.18.140	Slough, England	United Kingdom	51.5095	-0.59541	resolve
88	b2.booking.com	5.57.18.141	Slough, England	United Kingdom	51.5095	-0.59541	resolve
78	barcelo.partner.booking.com	5.57.16.205	Slough, England	United Kingdom	51.5095	-0.59541	resolve
70	blog.booking.com	87.233.215.183	Amsterdam, Noord-Holland	Netherlands	52.374	4.88969	resolve
89	bob.booking.com	148.251.235.184	Nuremberg, Bayern	Germany	49.4478	11.0683	resolve
150	bookadmin.booking.com	5.57.16.41	Slough, England	United Kingdom	51.5095	-0.59541	reverse_resolve
80	bookingbutton.booking.com	5.57.16.143	Slough, England	United Kingdom	51.5095	-0.59541	resolve
90	bugs.booking.com	5.57.16.28	Slough, England	United Kingdom	51.5095	-0.59541	resolve
91	c.booking.com	5.57.16.220	Slough, England	United Kingdom	51.5095	-0.59541	resolve
120	client.perspagina.nl	54.229.233.23	Dublin, Dublin City	Ireland	53.344	-6.26719	resolve
121	client.perspagina.nl	176.34.142.255	Dublin, Dublin City	Ireland	53.344	-6.26719	resolve
118	client.presspage.com	176.34.142.255	Dublin, Dublin City	Ireland	53.344	-6.26719	resolve
119	client.presspage.com	54.229.233.23	Dublin, Dublin City	Ireland	53.344	-6.26719	resolve

OSINT VÍA LEAKS

Data Breach: Intrusión en un sistema con información confidencial y/o sin la autorización del dueño, aprovechandose de una vulnerabilidad conocida o no, con el fin de controlar el propio sistema o pivotar a otros equipos de la red.

Data Leak: fuga de información expuesta y públicada.



TECNO

Filtraron los números de teléfono y datos personales de 533 millones de usuarios de Facebook

Se trata de información personal de perfiles de 106 países, muy valiosa para los ciberdelincuentes

3 de Abril de 2021



"100008776031164","","","+966595[redacted]82","","","Hussain","Radhwan","male","https://www.facebook.com/100008776031164","","","Hussain Radhwan","","","","","Qatif","","100008776031164@fac
"100009247154481","","","+9665[redacted]44","","","Hussain","Ali","male","https://www.facebook.com/100009247154481","","","Hussain Ali","","","","","","","100009247154481@facebook.com","
"100004163085721","","","+9665[redacted]63","","","Hussain","Bacha","male","https://www.facebook.com/100004163085721","","","Hussain Bacha","","","","Riyadh Saudi Arabia","Riyadh Saudi
"100001793696473","","","+9665[redacted]20","","","Hussain","Abu Reem","male","https://www.facebook.com/hussain.abureem","","hussain.abureem","Hussain Abu Reem","","","","","","","hussain
"100012549164768","","","+9665[redacted]36","","","Hussain","Ali","male","https://www.facebook.com/100012549164768","","","Hussain Ali","","","","","","","100012549164768@facebook.com","
"100009466258233","","","+96659[redacted]87","","","Hussain","Ali","male","https://www.facebook.com/100009466258233","","","Hussain Ali","","","","","","","100009466258233@facebook.com","
"659031340","","","+9665959[redacted]99","""12/02","Hussain","Zulfiqar","male","https://www.facebook.com/hussain.zulfiqar2","","hussain.zulfiqar2","Hussain Zulfiqar","","","","","","","huss
"100010506973297","","","+966595[redacted]83","","","Hussain","Attique","male","https://www.facebook.com/hussain.attique.7","","hussain.attique.7","Hussain Attique","","","","","","","huss
"100009101735021","","","+966[redacted]07","","","Hussain","Gull","male","https://www.facebook.com/100009101735021","","","Hussain Gull","","","","","","","100009101735021@facebook.com",
"100002603571063","","","+966[redacted]38","","","Hussain","Khan","male","https://www.facebook.com/100002603571063","","","Hussain Khan","","Riyadh Saudi Arabia","Supervisor","Khas Dir

Número de celular ID interno de FB Nombre
Apellido
Email (en algunos casos) Sexo
Actividad laboral Relación sentimental Ubicación
Fecha de último login



ANONIMATO

Tor (sigla de **T**he **O**nion **R**outer -en español- **El Enrutador Cebolla**)

Tor, que significa "The Onion Router" (El Enrutador Cebolla) en inglés, es una red de comunicaciones anónima diseñada para proteger la privacidad y la identidad en línea de los usuarios. Fue desarrollada originalmente por la Marina de los Estados Unidos y posteriormente se convirtió en un proyecto de código abierto mantenido por la comunidad.

El principal objetivo de Tor es ocultar la dirección IP y la ubicación geográfica de un usuario, así como su actividad en línea, de manera que sea difícil para cualquier entidad, como gobiernos, empresas o hackers, rastrear sus acciones en la web. Esto se logra mediante el enrutamiento de las comunicaciones a través de una serie de servidores voluntarios distribuidos por todo el mundo.

GOOGLE HACKING

Utilizando las busquedas avanzadas de Google es posible dar rápidamente con algún tipo de información.

¿Qué podemos encontrar con Google Hacking?

Productos WEB vulnerables
Sitios con algún error en particular
Archivos con información sensible Portales de autenticación de usuarios
Listado de directorios
Interfaz de management de distintos dispositivos: APS, UPS, impresoras, cámaras web, etc.

Comando Descripción

site: Busca los resultados en el dominio dado related: Busca páginas similares
link: Lista webs que tengan links a la página especifcada allintext: Busca sitios que tengan determinada palabra intext: Busca documentos que tengan determinada palabra
intitle: Busca documentos que tengan determinada palabra en el título
inurl: Busca documentos que tengan determinada palabra en su URL filetype: Busca documentos que tengan determinada extensión

Archivos PDF con el texto "dni" y "apellido" en sitios *gba.gob.ar: filetype:pdf site:*gba.gob.ar dni apellido

Portales de autenticación WordPress gubernamentales: inurl:wp-login.php site:gov.ar

EXPLOIT-DB
https://www.exploit-db.com/google-hacking-database

SHODAN

Es un buscador de servicios o dispositivos expuestos en internet.
Escanea puertos y recupera el banner (firma del producto/tecnología); luego permite indexar los banners para la búsqueda.

Permite buscar por diferentes criterios como puerto y protocolo de transporte.

Permite a los usuarios buscar dispositivos (computadoras, impresoras, cámaras, switches, routers, etc) con un contenido específico con en el banner
.
Algunos oltros de búsqueda avanzados requieren que el usuario esté autenticado. Ejemplo: búsquedas por país y red.

Demo: https://www.shodan.io/

Ip camera
Octoprint

OTROS BUSCADORES SIMILARES A SHODAN

https://censys.io/
https://zoomeye.org/
http://fofa.so

FOOTPRINTING

Se recolecta información de la organización usando métodos **no intrusivos**.

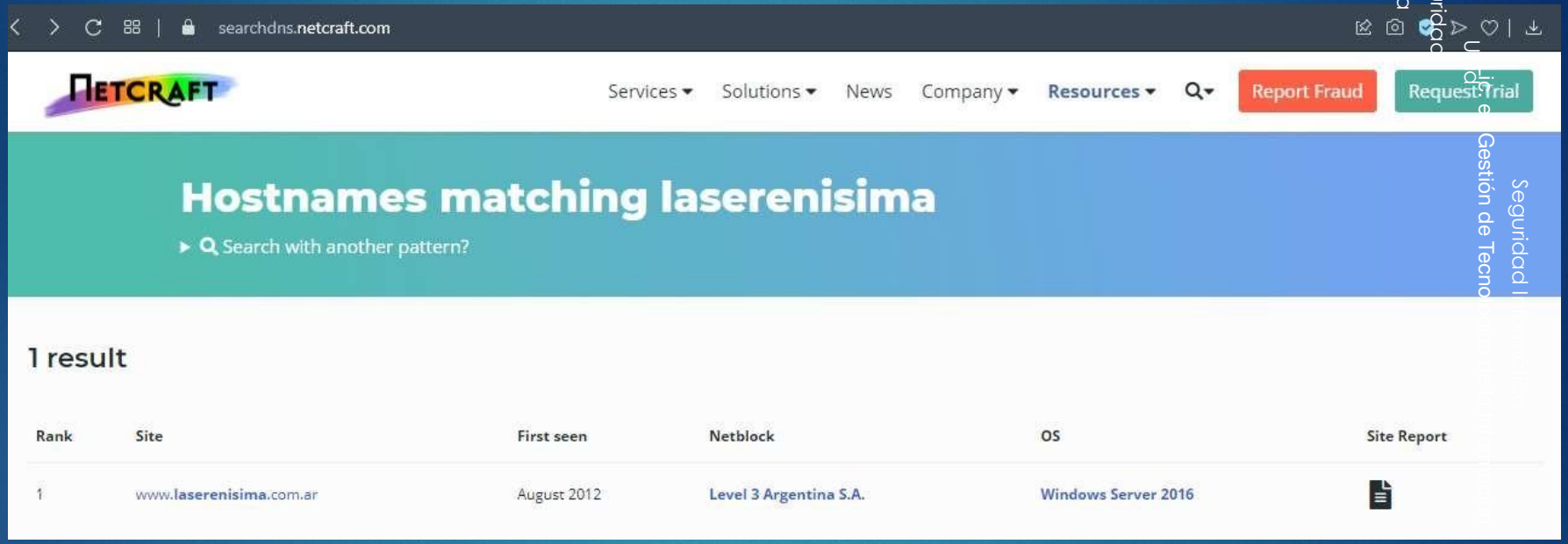
Se vale de información pública disponible en la página WEB, a través de consultas de DNS, a través de requerimientos de WHOIS, etc
La información resultante (números de TEL, direcciones, direcciones IP, direcciones de mail) es obtenida de forma legal.



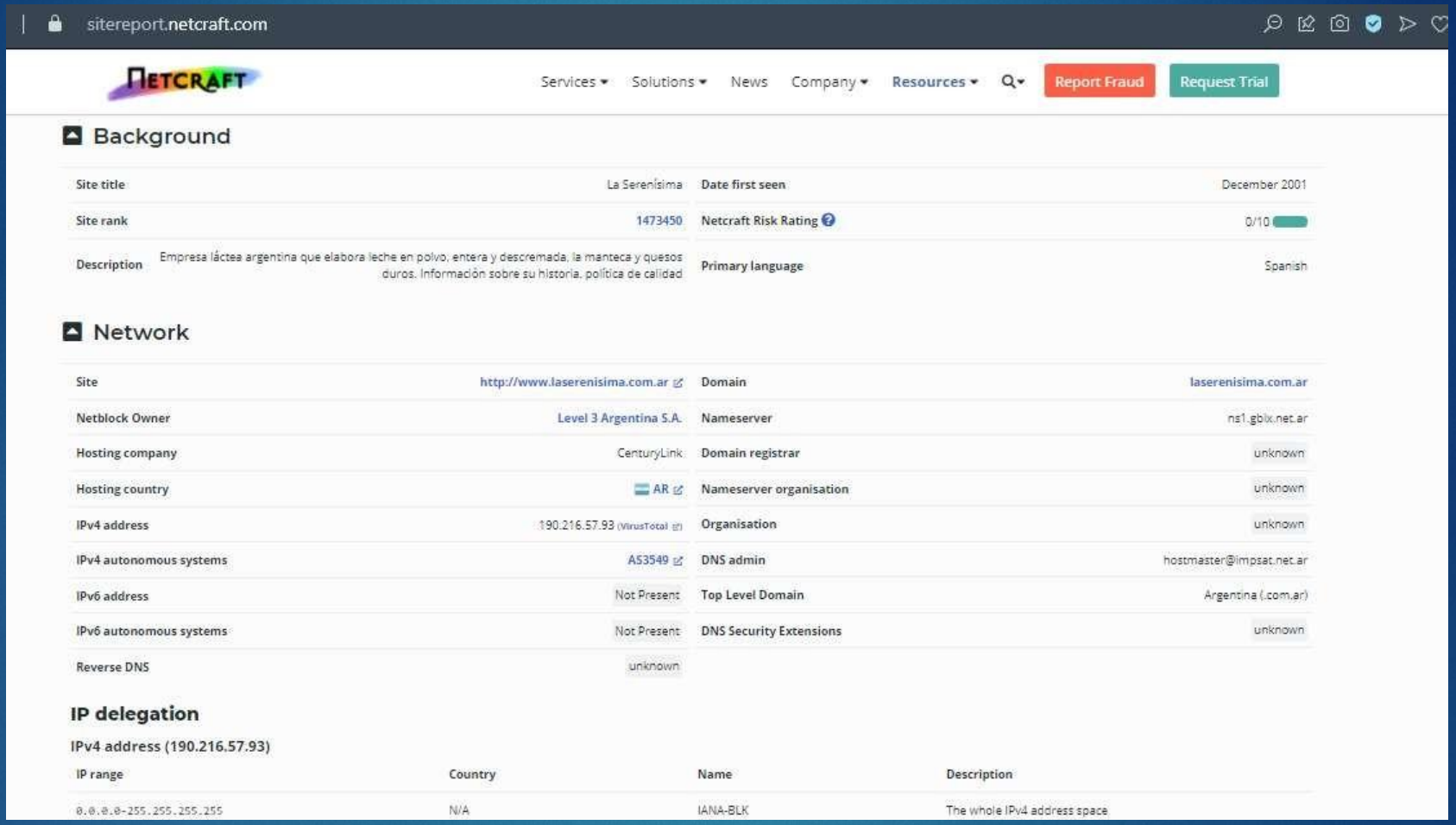
Algunos ejemplos:

El servicio DNS
El servicio WHOIS / RDAP
Netcraft
Webarchive
Common Crawl
DomainRegisters
El sitio web de la organización
Análisis de metadatos

NETCRAFT


searchdns.netcraft.com
NETCRAFT
Services
Solutions
News
Company
Resources
Report Fraud
Request Trial
Hostnames matching laserenisima
Search with another pattern?
1 result
Rank
Site
First seen
Netblock
OS
Site Report
1
www.laserenisima.com.ar
August 2012
Level 3 Argentina S.A.
Windows Server 2016

NETCRAFT


sitereport.netcraft.com
NETCRAFT
Services
Solutions
News
Company
Resources
Report Fraud
Request Trial
Background
Site title
La Serenísima
Date first seen
December 2001
Site rank
1473450
Netcraft Risk Rating
0/10
Description
Empresa láctea argentina que elabora leche en polvo, entera y descremada, la manteca y quesos duros. Información sobre su historia, política de calidad
Primary language
Spanish
Network
Site
http://www.laserenisima.com.ar
Domain
laserenisima.com.ar
Netblock Owner
Level 3 Argentina S.A.
Nameserver
ns1.gblx.net.ar
Hosting company
CenturyLink
Domain registrar
unknown
Hosting country
AR
Nameserver organisation
unknown
IPv4 address
190.216.57.93 (VirusTotal)
Organisation
unknown
IPv4 autonomous systems
AS3549
DNS admin
hostmaster@impsat.net.ar
IPv6 address
Not Present
Top Level Domain
Argentina (.com.ar)
IPv6 autonomous systems
Not Present
DNS Security Extensions
unknown
Reverse DNS
unknown
IP delegation
IPv4 address (190.216.57.93)
IP range
Country
Name
Description
0.0.0.0-255.255.255.255
N/A
IANA-BLK
The whole IPv4 address space

DNS – IP DE WWW.GOOGLE.COM

```
$dig www.google.com

; <<>> DiG 9.11.3-1ubuntu1.12-Ubuntu <<>> www.google.com
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 19405
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 65494
;; QUESTION SECTION:
;www.google.com.                        IN      A

;; ANSWER SECTION:
www.google.com.         87      IN      A       172.217.172.68

;; Query time: 0 msec
;; SERVER: 127.0.0.53#53(127.0.0.53)
;; WHEN: Tue Jun 09 13:13:33 -03 2020
;; MSG SIZE  rcvd: 59
```



DNS – SERVIDORES DNS DE LA ZONA GOOGLE.COM

```
$dig ns google.com

; <<>> DiG 9.11.3-1ubuntu1.12-Ubuntu <<>> ns google.com
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 40560
;; flags: qr rd ra; QUERY: 1, ANSWER: 4, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 65494
;; QUESTION SECTION:
;google.com.                    IN      NS

;; ANSWER SECTION:
google.com.             1757    IN      NS      ns1.google.com.
google.com.             1757    IN      NS      ns3.google.com.
google.com.             1757    IN      NS      ns2.google.com.
google.com.             1757    IN      NS      ns4.google.com.

;; Query time: 19 msec
;; SERVER: 127.0.0.53#53(127.0.0.53)
;; WHEN: Tue Jun 09 13:38:49 -03 2020
;; MSG SIZE  rcvd: 111
```



DNS – SERVIDOR PRIMARIO DE ZONA

```
$dig soa google.com

; <<>> DiG 9.11.3-1ubuntu1.12-Ubuntu <<>> soa google.com
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 41732
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 65494
;; QUESTION SECTION:
;google.com.                    IN      SOA

;; ANSWER SECTION:
google.com.             51      IN      SOA     ns1.google.com. dns-admin.google.com. 315449991 900 900 1800 60

;; Query time: 18 msec
;; SERVER: 127.0.0.53#53(127.0.0.53)
;; WHEN: Tue Jun 09 13:15:58 -03 2020
;; MSG SIZE  rcvd: 89
```



DNS – SERVIDORES DE MAIL DE PARA @GOOGLE.COM

```
$dig mx google.com

; <<>> DiG 9.11.3-1ubuntu1.12-Ubuntu <<>> mx google.com
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 2333
;; flags: qr rd ra; QUERY: 1, ANSWER: 5, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 65494
;; QUESTION SECTION:
;google.com.                    IN      MX

;; ANSWER SECTION:
google.com.             228     IN      MX      50 alt4.aspmx.l.google.com.
google.com.             228     IN      MX      20 alt1.aspmx.l.google.com.
google.com.             228     IN      MX      10 aspmx.l.google.com.
google.com.             228     IN      MX      30 alt2.aspmx.l.google.com.
google.com.             228     IN      MX      40 alt3.aspmx.l.google.com.

;; Query time: 0 msec
;; SERVER: 127.0.0.53#53(127.0.0.53)
;; WHEN: Tue Jun 09 13:16:39 -03 2020
;; MSG SIZE  rcvd: 147
```

CONSULTAS RECURSIVAS

```
$dig www.laserenisima.com.ar @4.2.2.2

; <<>> DiG 9.11.3-1ubuntu1.12-Ubuntu <<>> www.laserenisima.com.ar @4.2.2.2
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 51764
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 8192
;; QUESTION SECTION:
;www.laserenisima.com.ar.       IN      A

;; ANSWER SECTION:
www.laserenisima.com.ar. 86400  IN      A       190.216.57.93

;; Query time: 311 msec
;; SERVER: 4.2.2.2#53(4.2.2.2)
;; WHEN: Tue Jun 09 13:17:27 -03 2020
;; MSG SIZE  rcvd: 68
```

BÚSQUEDA DE SUBDOMINIOS

http://crt.sh/
https://rapiddns.io/
https://github.com/OWASP/Amass

Video de Amass
https://www.youtube.com/watch?v=wcfxpr1xpsI



WHOIS

```
$whois 64.233.169.99

#
# ARIN WHOIS data and services are subject to the Terms of Use
# available at: https://www.arin.net/resources/registry/whois/tou/
#
# If you see inaccuracies in the results, please report at
# https://www.arin.net/resources/registry/whois/inaccuracy_reporting/
#
# Copyright 1997-2020, American Registry for Internet Numbers, Ltd.
#


NetRange:       64.233.160.0 - 64.233.191.255
CIDR:           64.233.160.0/19
NetName:        GOOGLE
NetHandle:      NET-64-233-160-0-1
Parent:         NET64 (NET-64-0-0-0-0)
NetType:        Direct Allocation
OriginAS:
Organization:   Google LLC (GOGL)
RegDate:        2003-08-18
Updated:        2012-02-24
Ref:            https://rdap.arin.net/registry/ip/64.233.160.0



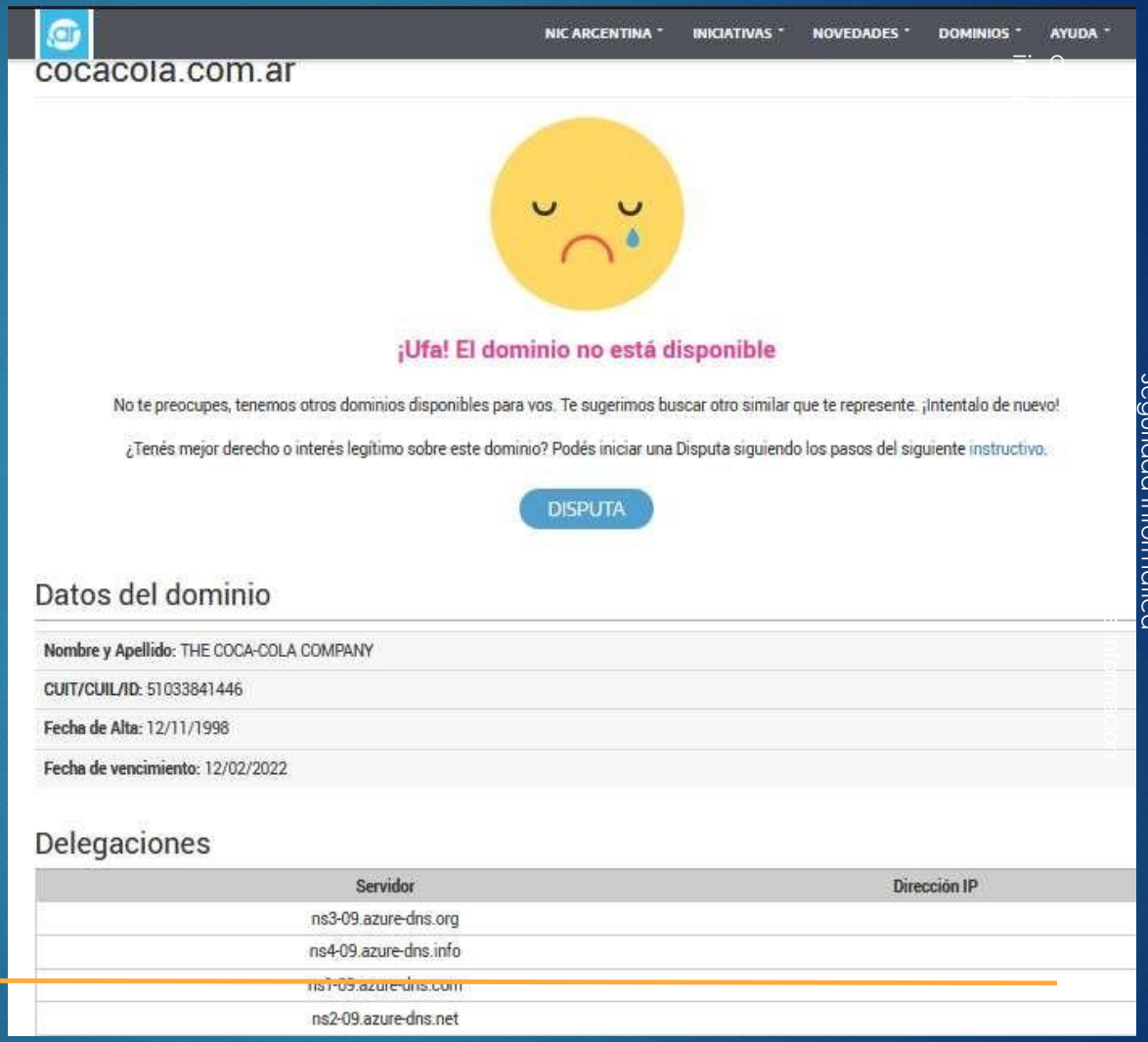
OrgName:        Google LLC
OrgId:          GOGL
Address:        1600 Amphitheatre Parkway
City:           Mountain View
StateProv:      CA
PostalCode:     94043
Country:        US
RegDate:        2000-03-30
Updated:        2019-10-31
Comment:        Please note that the recommended way to file abuse complaints are located in the following links.
Comment:
Comment:        To report abuse and illegal activity: https://www.google.com/contact/
Comment:
Comment:        For legal requests: http://support.google.com/legal
Comment:
Comment:        Regards,
Comment:        The Google Team
Ref:            https://rdap.arin.net/registry/entity/GOGL


OrgAbuseHandle: ABUSE5250-ARIN
OrgAbuseName:   Abuse
OrgAbusePhone:  +1-650-253-0000
OrgAbuseEmail:  network-abuse@google.com
OrgAbuseRef:    https://rdap.arin.net/registry/entity/ABUSE5250-ARIN
```



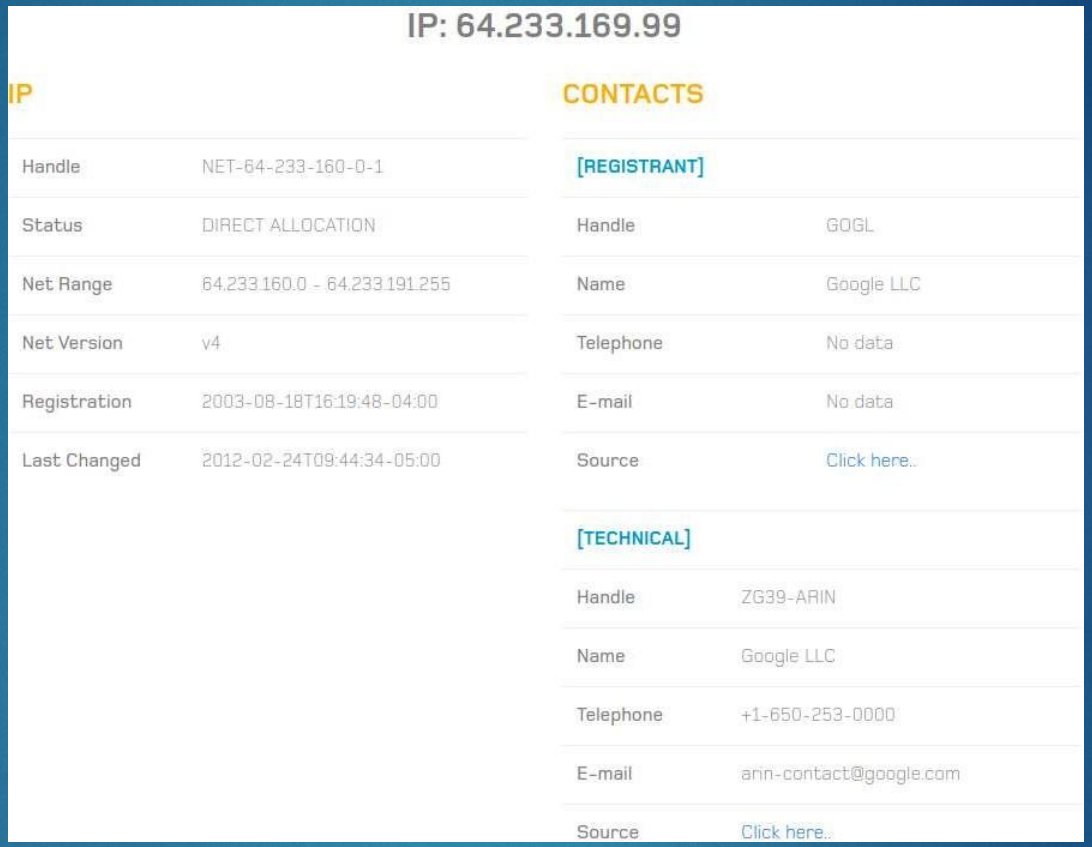
DOMAIN REGISTERS (ARGENTINA)

https://nic.ar/



RDAP

https://rdap-web.lacnic.net



IP: 64.233.169.99

IP

Handle	NET-64-233-160-0-1
Status	DIRECT ALLOCATION
Net Range	64.233.160.0 - 64.233.191.255
Net Version	v4
Registration	2003-08-18T16:19:48-04:00
Last Changed	2012-02-24T09:44:34-05:00

CONTACTS

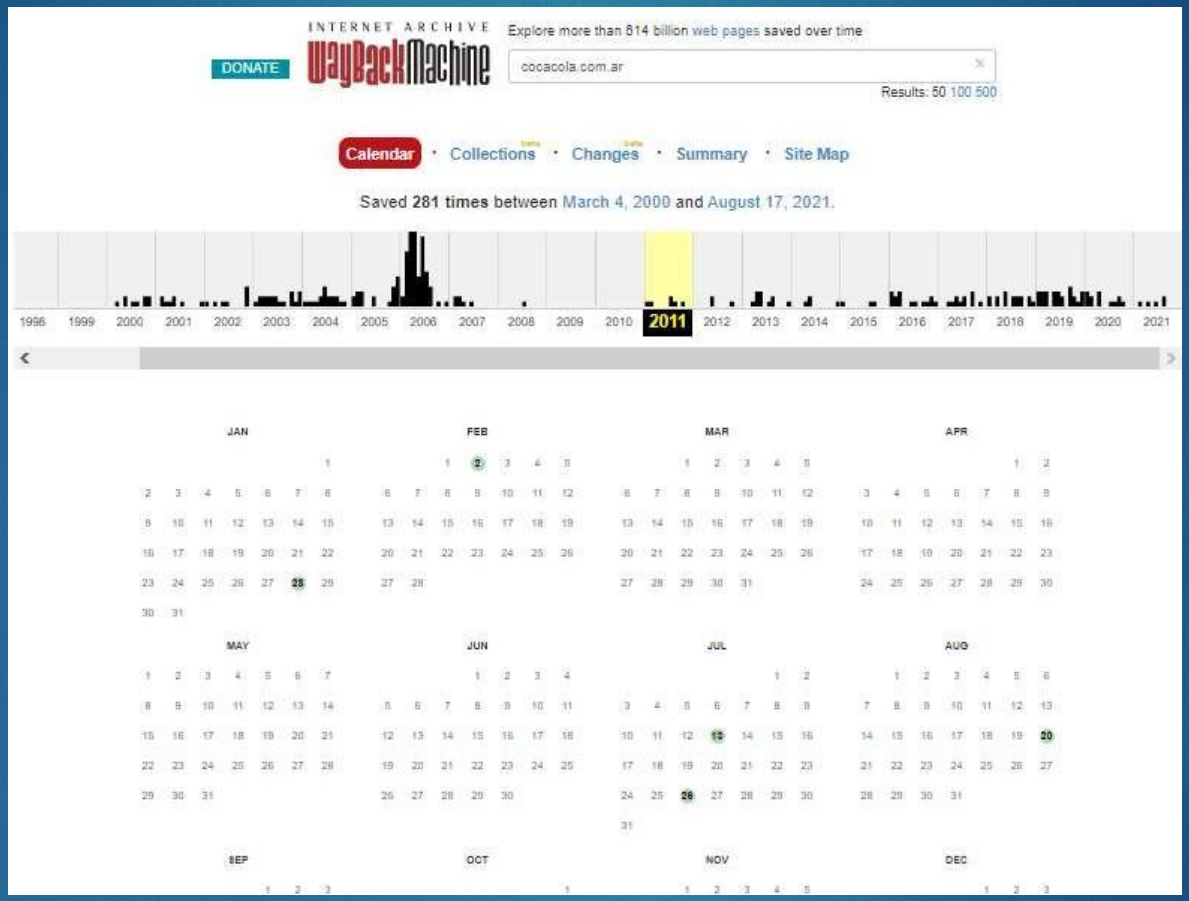
[REGISTRANT]

Handle	GOGL
Name	Google LLC
Telephone	No data
E-mail	No data
Source	Click here..

[TECHNICAL]

Handle	ZG39-ARIN
Name	Google LLC
Telephone	+1-650-253-0000
E-mail	arin-contact@google.com
Source	Click here..

INTERNET ARCHIVE – WAYBACK MACHINE



ANÁLISIS DEL SITIO WEB

Los sitios web suelen mostrar datos respecto a la misma organización

Suelen tener información sobre su estructura organizacional, empleados y cargos

Múltiples datos de contacto

Información sobre sus productos y servicios.

METADATOS

Simplemente son datos de los datos

Tienen distintas utilidades:
- Análisis Forenses
- Obtener información para un ataque
- Aplicaciones que utilicen los mismos para realizar ordenaciones o categorias de cosas.

Por ej:
Ordenación de fotos por fechas
Correlación de fotos por coordenadas geográficas

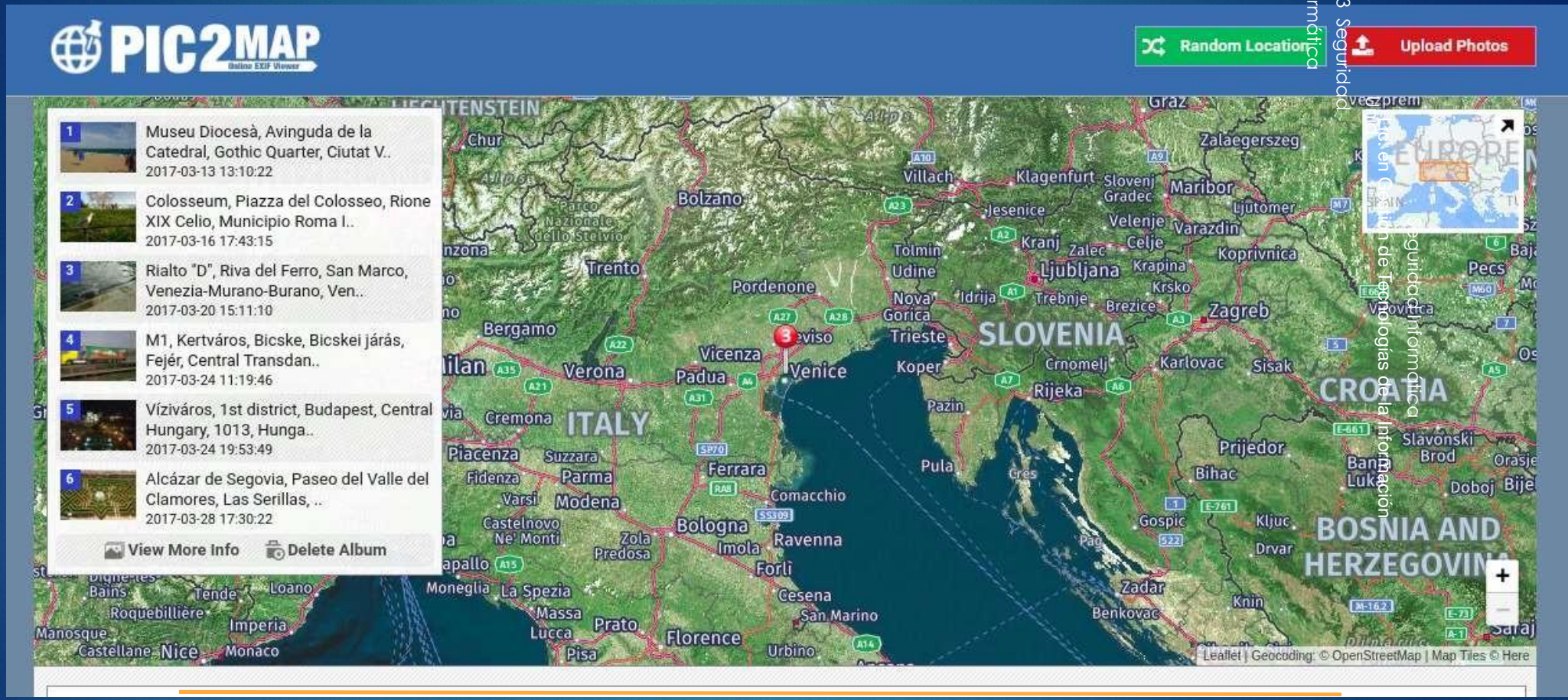


ANÁLISIS DE METADATA - EXIFTOOL

```
vagrant@kali:/vagrant$ exiftool formulario.pdf
ExifTool Version Number         : 11.99
File Name                       : formulario.pdf
Directory                       : .
File Size                       : 562 kB
File Modification Date/Time     : 2020:06:09 11:17:59-04:00
File Access Date/Time           : 2020:06:09 11:18:26-04:00
File Inode Change Date/Time     : 2020:06:09 11:18:20-04:00
File Permissions                : rw-rw-r--
File Type                       : PDF
File Type Extension             : pdf
MIME Type                       : application/pdf
PDF Version                     : 1.6
Linearized                      : No
Author                          : usuario
Create Date                     : 2020:06:07 18:46:14-03:00
Modify Date                     : 2020:06:07 20:52:28-03:00
Has XFA                         : No
Language                        : en-US
Tagged PDF                      : Yes
XMP Toolkit                     : Adobe XMP Core 5.6-c017 91.164374, 2020/03/05-20:41:30
Format                          : application/pdf
Creator                         : usuario
Creator Tool                    : Microsoft® Word 2016
Metadata Date                   : 2020:06:07 20:52:28-03:00
Producer                        : Microsoft® Word 2016
Document ID                     : uuid:44b64176-b2ee-41a6-acaf-4ebcdc5c448e
Instance ID                     : uuid:b61f58b2-73dc-43d7-9557-a5ab06087447
Page Count                      : 2
```

ANÁLISIS DE METADATA - PIC2MAP

https://www.pic2map.com/



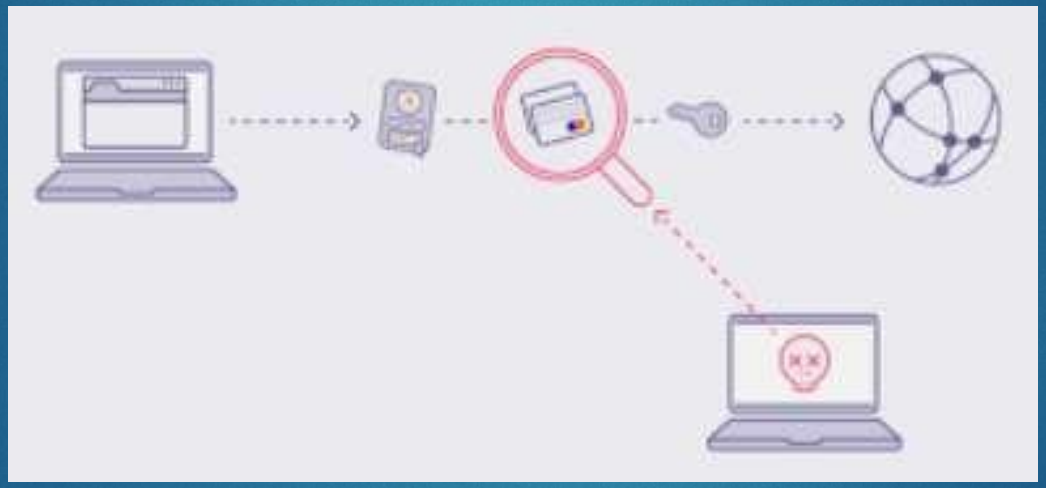
UNIDAD 3:
Seguridad informática
SEGURIDAD TCP/IP

UNPAZ
Universidad Nacional de José C. Paz

Seguridad informática
Lic. en Gestión de Tecnologías de la Información

Sniffer

Un sniffer es una herramienta que se utiliza para acceder a comunicaciones a las que normalmente no tendríamos acceso. Suelen ser utilizados con fines de espionaje.



Sniffing

Ataques de sniffing

Un ataque de sniffing puede ocasionar que:

– Se pierda la confidencialidad de las comunicaciones atacadas.

–Se pierda la integridad de las comunicaciones si se alteran los datos que se intercambian.

Si las comunicaciones utilizan cifrado, como por ejemplo SSL, el ataque de sniffing permite acceder a tráfico cifrado.

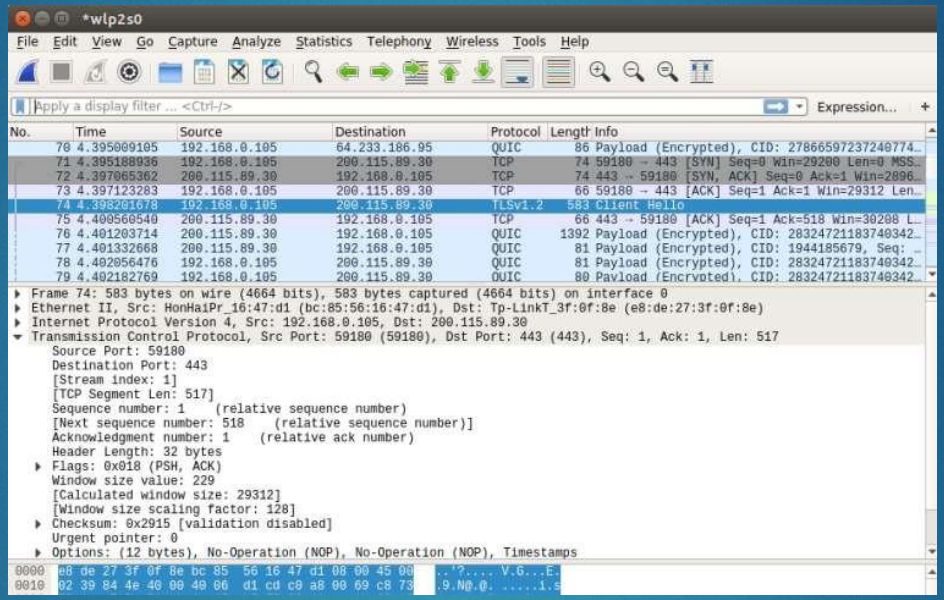
– El atacante puede ver el tráfico cifrado pero no puede interpretar los datos que se intercambian.

–Las comunicaciones estan protegidas extremo a extremo, pero esto no es efectivo si el compromiso es en el cliente o en el servidor



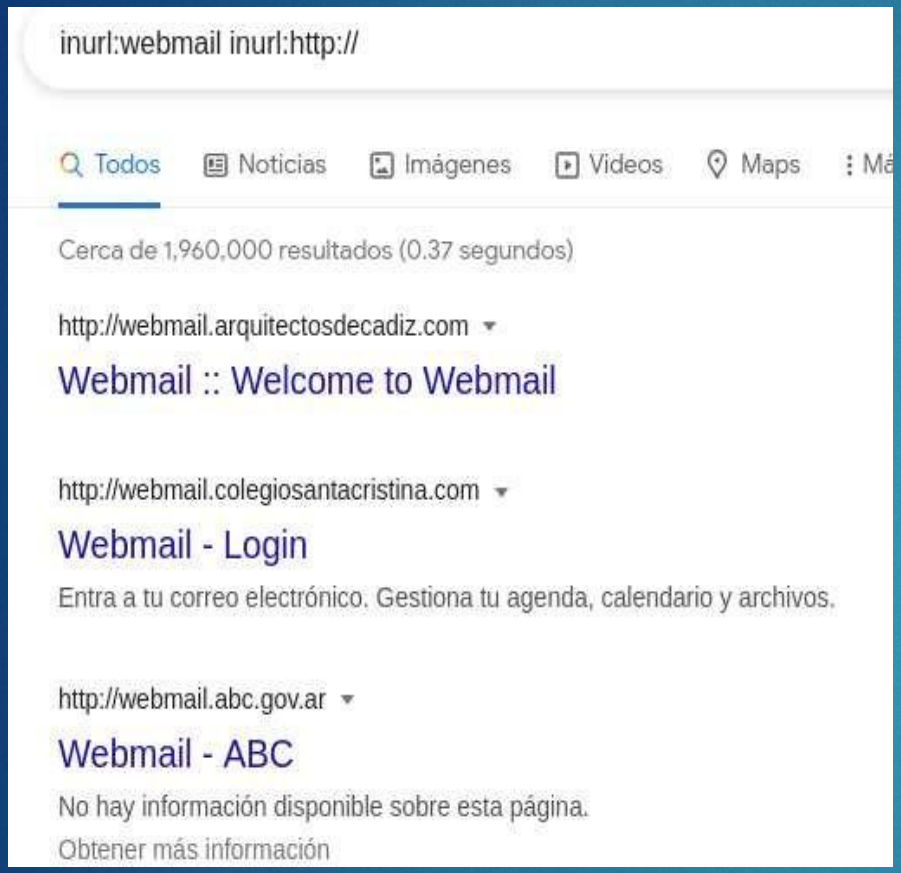
Sniffers- Analizador de protocolo – Wireshark

Es un analizador de protocolos que corre en plataformas Unix y Windows. Es una herramienta OpenSource.
Es posible analizar tráfico en vivo o a partir de archivos (capturas de tráficos).



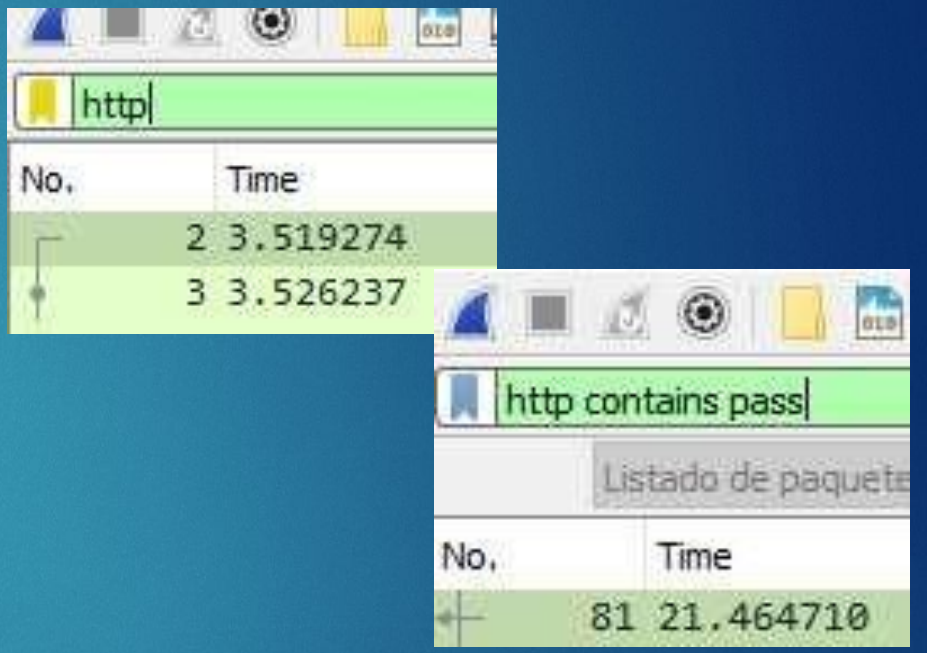
https://www.youtube.com/watch?v=C4vOgLVgVMw

Inurl:webmail
inurl:http://



http://webmail.abc.gov.ar

Archivo -> exportar objetos -> http



Analizar -> Seguir -> Flujo HTTP

Denegación de servicio

Ataque DoS

Una denegación de servicio (DoS) es una acción que impide o perjudica el uso autorizado de redes, sistemas o aplicaciones al agotar recursos tales como unidades centrales de procesamiento (CPU), memoria, ancho de banda y espacio en disco.

Atenta contra el pilar de la DISPONIBILIDAD.



Denegación de servicio

Un ataque **DoS** dirigido a los recursos del sistema generalmente tiene como objetivo sobrecargar o bloquear su software de manejo de red.

Hay ataques que buscan consumir ancho de banda con grandes volúmenes de tráfico, u otros que **envían tipos específicos de paquetes** que consumen los recursos limitados disponibles en el sistema.

Estos incluyen buffers temporales utilizados para contener paquetes entrantes, tablas de conexiones abiertas, consumo de grandes archivos y estructuras de datos de memoria similares.



DoS distribuido (DDoS)

DoS Distribuido

Cuando el ataque DoS se origina desde varias fuentes, se le llama ataque de denegación de servicio distribuido. Varios atacantes se pueden poner de acuerdo para inundar la red al mismo tiempo, o también pueden utilizar botnets para realizar el ataque.

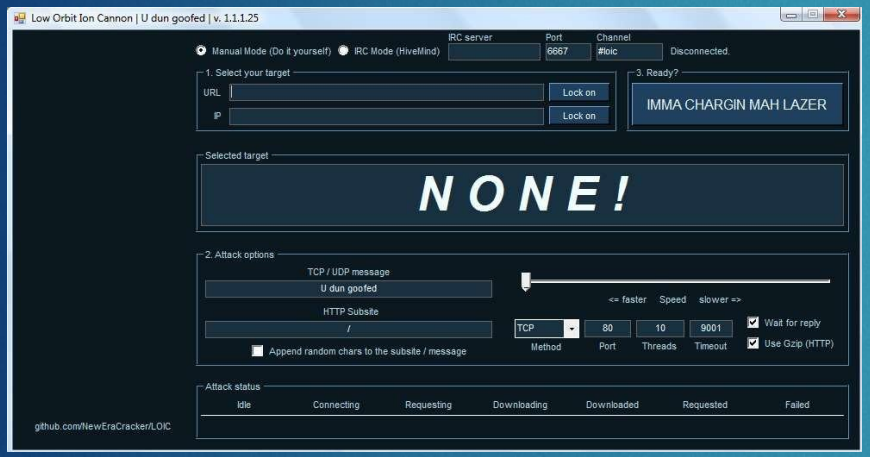
Generado por
- Malware
- Botnets

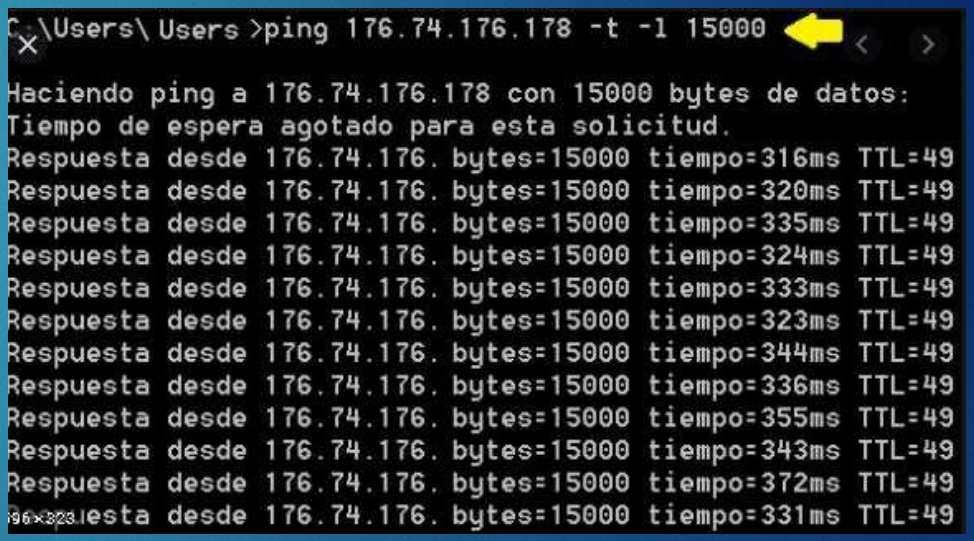


Paquetes Envenenados

Poison packets

Una forma de ataque de recursos del sistema que utiliza paquetes cuya estructura desencadena un error en el software de manejo de red del sistema, causando que el mismo se detenga.



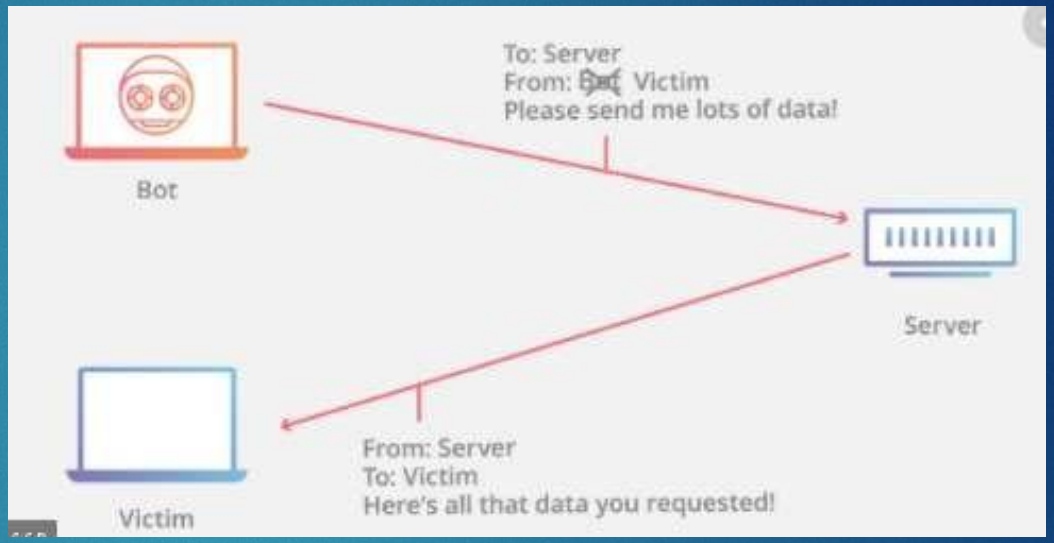


Suplantación de dirección de origen

IP Spoofing

La suplantación de IP es la creación de paquetes de Protocolo de Internet con una dirección IP de origen falsa, con el fin de hacerse pasar por otro sistema informático.

- Hacer cambios
- Obtener acceso a un sistema
- Sniffing



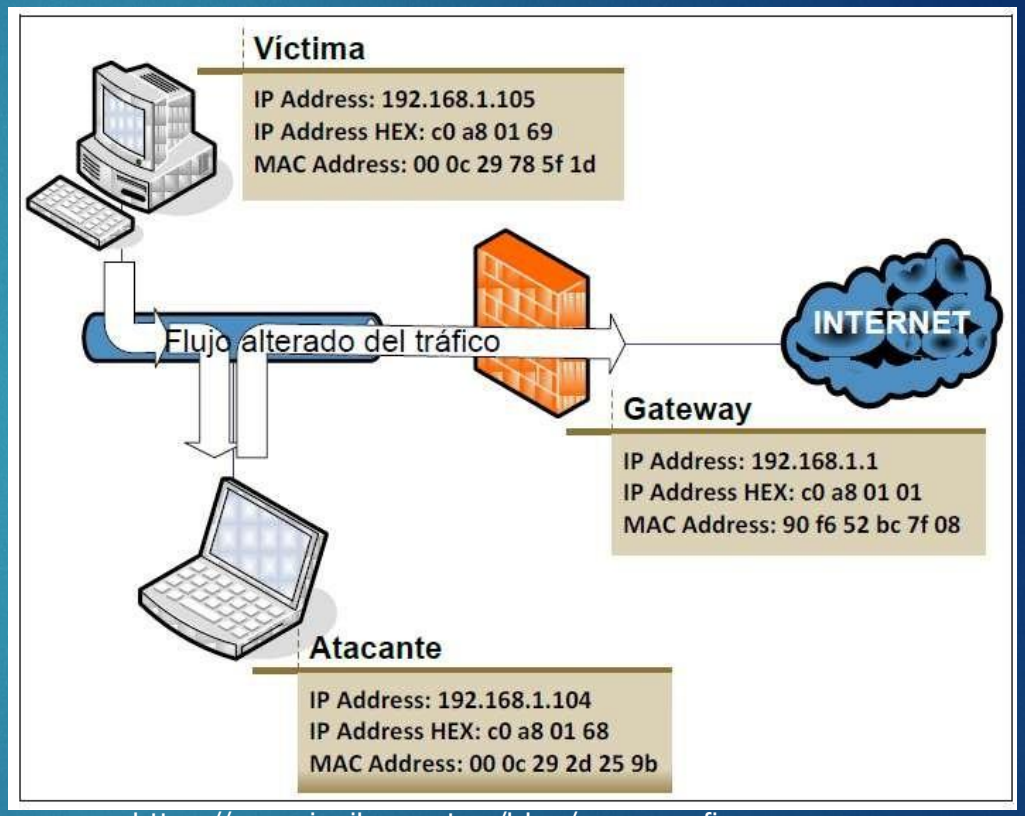

```
~# iptables -t nat -APOSTROUTING -j SNAT --to-source 192.168.173.2
```

Suplantación de dirección de origen

ARP Spoofing

La suplantación de ARP es enviar mensajes ARP falsos a la Ethernet. Normalmente la finalidad es asociar la dirección MAC del atacante con la dirección IP de otro nodo, como por ejemplo la puerta de enlace predeterminada.





https://www.incibe-cert.es/blog/arp-spoofing

Suplantación de dirección de origen

ARP Spoofing

De denegación de servicio ataques (Denial-of-service attacks): ataques DoS utilizan ARP Spoofing para enlazar varias direcciones IP en una LAN con la dirección MAC de un solo objetivo. Debido a esto, el tráfico que está destinada a diferentes direcciones IP será redirigido a la dirección MAC del destino, sobrecargando así el objetivo con el tráfico.

Secuestro de sesiones (Session hijacking): ataques de secuestro de sesión pueden hacer uso de ARP Spoofing para robar los identificadores de sesión, garantizando así el acceso a los atacantes y los sistemas privados de datos.

Ataques tipo Hombre en el Medio (Man-in-the-middle Attacks): Los ataques MITM pueden utilizar ARP Spoofing para interceptar y/o modificar el tráfico entre dos víctimas.

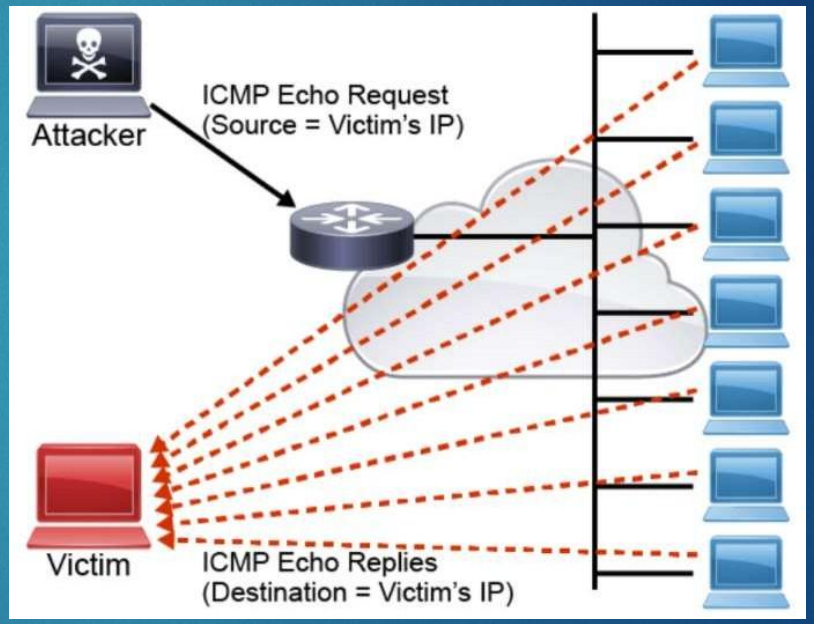


https://www.incibe-cert.es/blog/arp-spoofing

ICMP flood

ICMP flood es un tipo de ataque DoS que busca saturar un canal de comunicación mediante un excesivo número de paquetes ICMP.

A diferencia de **ICMP flood**
Que ataca directo a la víctima, la variante **SMURF** usa
IP Spoofing para cambiar la dirección origen
para que las respuestas vayan a la víctima.



Características de los ataques de inundación

Los **ataques de inundación** toman una variedad de formas, según el protocolo de red que se utiliza para implementar el ataque.

En todos los casos, la intención es generalmente **sobrecargar la capacidad de la red en algún enlace** a un servidor.

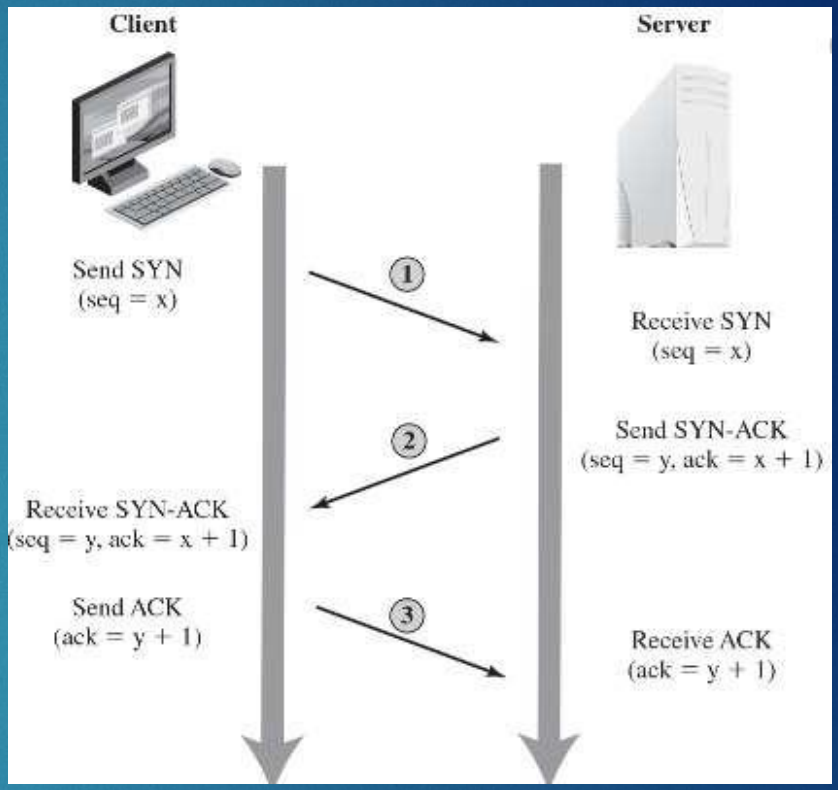
El ataque puede apuntar alternativamente a sobrecargar la capacidad del servidor para manejar y responder a este tráfico.

Estos ataques inundan el enlace de red al servidor con un torrente de paquetes maliciosos que compiten y, por lo general, un tráfico válido y abrumador que fluye hacia el servidor.



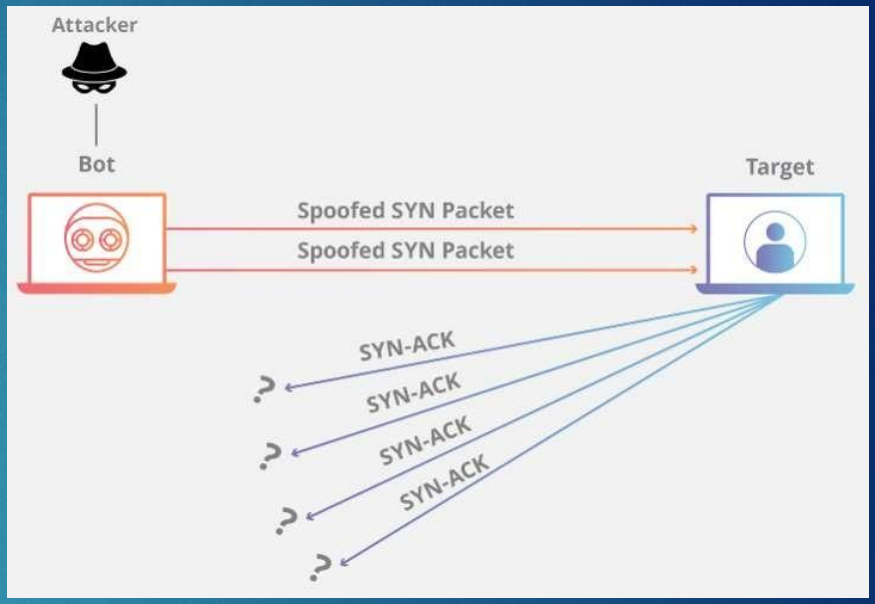
Inundación TCP SYN

Los ataques **de inundación SYN** funcionan mediante la explotación del proceso de protocolo de enlace de una conexión TCP.
Bajo condiciones normales, la conexión TCP exhibe tres procesos distintos para lograr una conexión.
Primero, el cliente envía un paquete SYN al servidor para iniciar la conexión.
El servidor responde al paquete inicial con un paquete SYN/ACK para reconocer la comunicación.
Finalmente, el cliente devuelve un paquete ACK para reconocer la recepción del paquete del servidor. Tras finalizar esta secuencia, la conexión TCP está abierta y puede enviar y recibir información.



Inundación TCP SYN

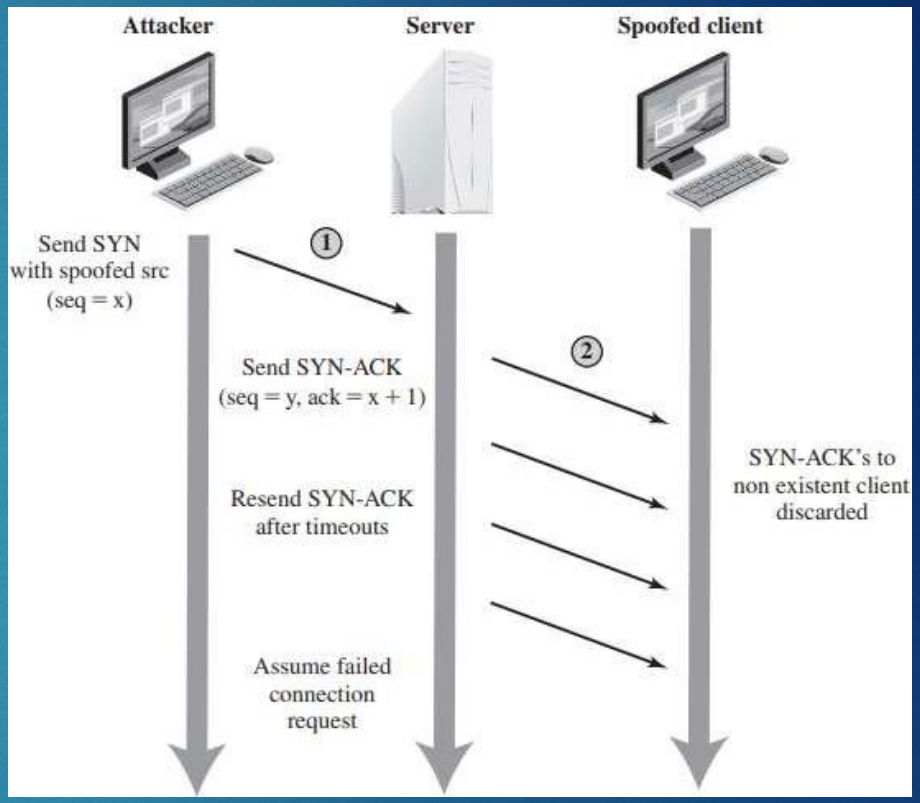
Tras la recepción de un paquete SYN inicial, el servidor responderá con uno o más paquetes SYN/ACK, y espera el último paso del protocolo de enlace. Opera de la siguiente manera:
El atacante envía un volumen alto de paquetes SYN al servidor fijado como objetivo, a menudo con direcciones IP falsas.
Luego, el servidor responde a cada una de las solicitudes de conexión y deja abierto un puerto, listo para recibir la respuesta.
Mientras el servidor espera el último paquete ACK, que nunca llega, el atacante continúa enviando paquetes SYN. La llegada de cada paquete SYN nuevo provoca que el servidor mantenga temporalmente una conexión de puerto abierto nueva. Una vez utilizados todos los puertos disponibles, el servidor ya no puede funcionar con normalidad.



https://www.cloudflare.com/es-la/learning/ddos/syn-flood-ddos-attack/

SYN Spoofing (suplantación)

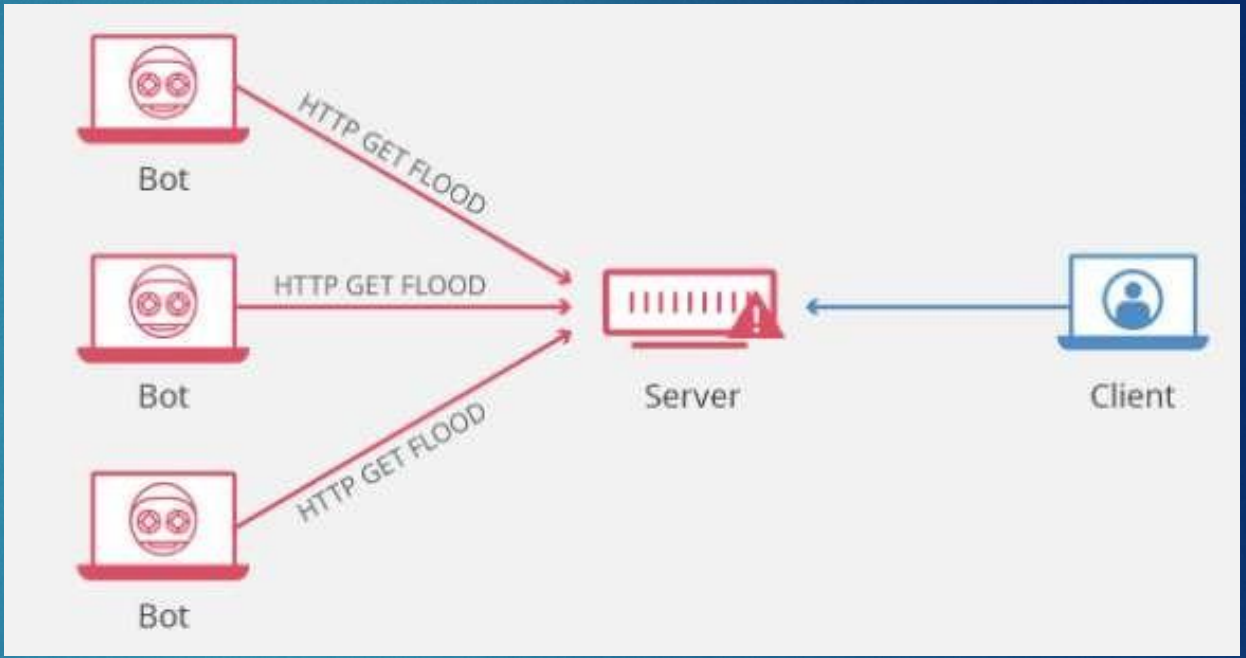
El atacante genera varios paquetes de solicitud de conexión SYN con direcciones de origen falsificadas. Para cada uno de estos, el servidor registra los detalles de la solicitud de conexión TCP y envía el paquete SYN-ACK a la dirección de origen reclamada.





Inundación HTTP (HTTP flood)

Una inundación HTTP se refiere a un ataque que bombardea servidores web con solicitudes HTTP. Por lo general, este es un ataque DDoS, con solicitudes HTTP provenientes de muchos bots diferentes. Las solicitudes pueden diseñarse para consumir recursos considerables.



Otros ataques DoS/DDoS

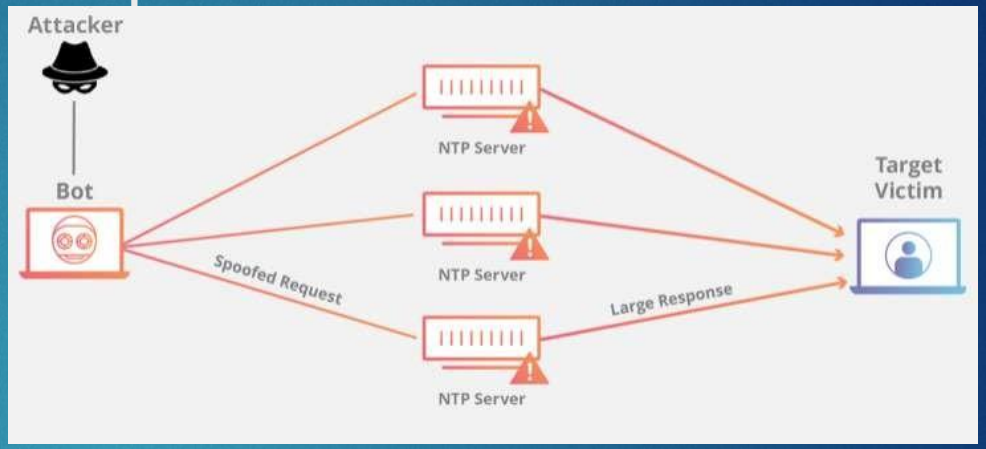
- Amplificación de NTP:
- Amplificación DNS

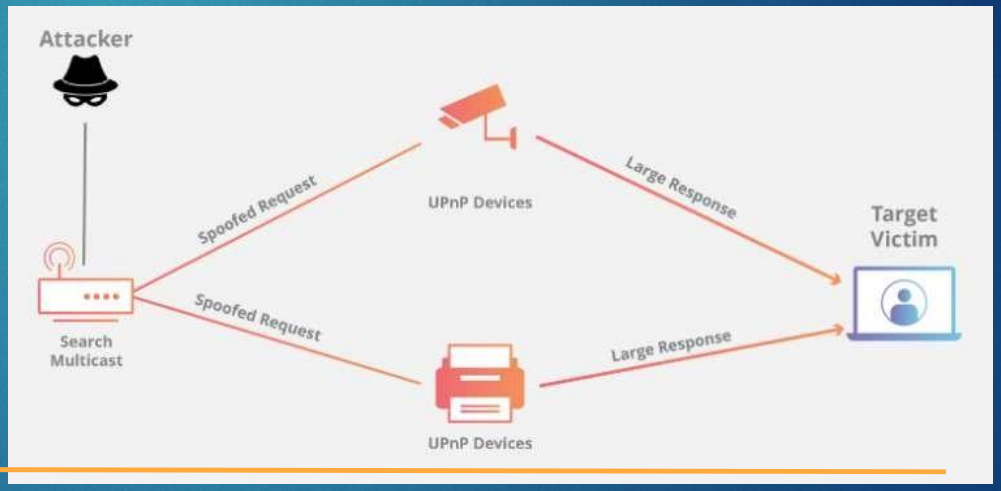
  Perturbar la infraestructura de red y la disponibilidad de los servici po DDOS

- Ataque SSDP

El Protocolo Simple de Descubrimiento de Servicios (Simple Service Discovery Protocol) es un protocolo que sirve para la búsqueda de dispositivos UPnP en una red.

-Lento y bajo





Contramedidas para ataques DoS

Prevención (antes del ataque): Las técnicas incluyen la aplicación de políticas para el consumo de recursos y el suministro de recursos de respaldo disponibles bajo demanda. Servicios como **Cloudflare** (https://www.cloudflare.com/es-es/)

Detección y filtrado de ataques (durante el ataque): estos mecanismos intentan detectar el ataque cuando comienza y responden de inmediato. Esto implica buscar patrones de comportamiento sospechosos. La respuesta implica filtrar los paquetes que probablemente sean parte del ataque. Firewall.

Seguimiento e identificación del origen del ataque (durante y después del ataque): este es un intento de identificar el origen del ataque como un primer paso para prevenir futuros ataques.

Reacción de ataque (después del ataque): se trata de un intento de eliminar o reducir los efectos de un ataque.



Seguridad en redes WIFI

Las distintas tecnologías tienen distintos tipos de problemas:

- Redes abiertas WEP (Wired Equivalent Privacy)
- WPA/WPA2 (Wi-Fi Protected Access)
- WPS (Wifi Protected Setup)



Caso Fibertel

Hacking Redes Wifi.

https://www.youtube.com/watch?v=sW8hvBnC1gU

Seguridad en redes WIFI

Ataques a clientes

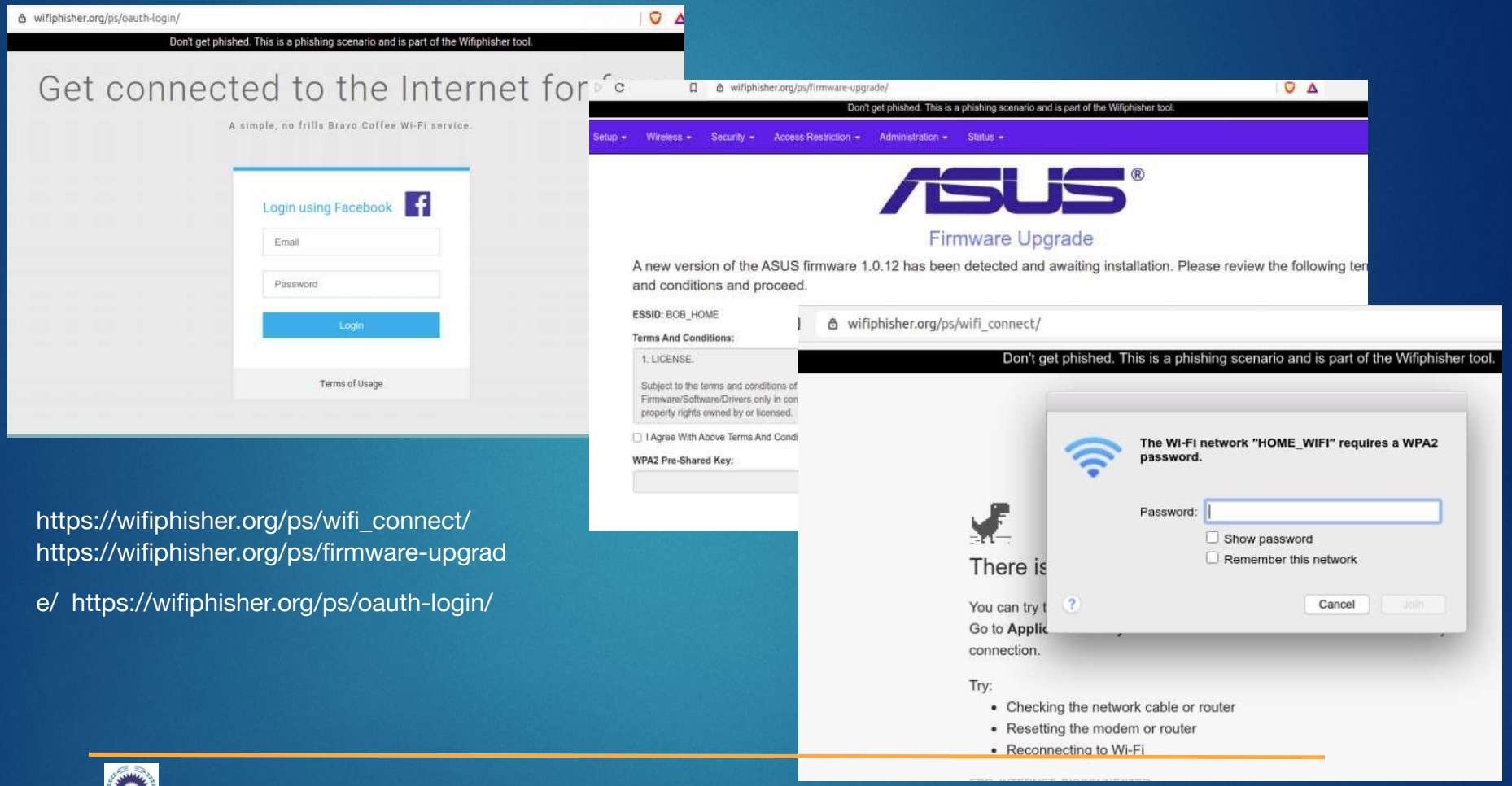
Rogue AP: Acces Point no autorizado conectado a la red de la empresa o institución y
manejado por alguien que no ha sido aprobado. simulando redes abiertas como:

- "internet gratis"
- "aeropuerto"
- "cafeteria wifi"
- "McCafé“

Evil Twin Attack (Gemelo Malvado):

- Rogue AP
- Deauth a clients: Enviar paquetes de desautenticacion
- Portal cautivo

Seguridad en redes WIFI



https://wifiphisher.org/ps/wifi_connect/
https://wifiphisher.org/ps/firmware-upgrad

e/ https://wifiphisher.org/ps/oauth-login/

https://www.youtube.com/watch?v=hpF7LhMXu5I

Video de Chema Alonso



Demo Atack SYN flood

- Identificar ip de ambos equipos
- Probar ping desde el atacante a la victima
- Encontrar puerto abierto en la pc victima

- Nmap (sudo apt-get install nmap / sudo apt install nmap)
- Nmap 172.16.56.1-254
- nmap -p1-65535 80 172.16.56.20

- Generar ataque

hping3 --help
hping3 -S iporigen -a ipvictima -p puerto --flood
hping3 -S 172.16.56.10 -a 172.16.56.20 -p puerto –flood

Otra opción

sudo hping3 -S --flood -V -p 80 170.155.9.185



UNIDAD 3:
Seguridad informática
CRIPTOGRAFIA

UNPAZ
Universidad Nacional de José C. Paz

Seguridad informática
Lic. en Gestión de Tecnologías de la Información

Encoding -Codificacion

Representar un repertorio de caracteres en algún tipo de sistema de codificación

Morse - ASCII / Representación numérica en otras bases – EBCDIC - Base64 – Braile - Lenguaje de Señas

BASE 64

Source character	V								m								0							
ASCII number	86								109								48							
Bit pattern	0	1	0	1	0	1	1	0	0	1	1	0	1	1	0	1	0	0	1	1	0	0	0	0
Base64 number	21								38								52							
Base64 character	V								m								0							

ES REVERSIBLE

Value	Char	Value	Char	Value	Char	Value	Char
0	A	16	Q	32	g	48	w
1	B	17	R	33	h	49	x
2	C	18	S	34	i	50	y
3	D	19	T	35	j	51	z
4	E	20	U	36	k	52	0
5	F	21	V	37	l	53	1
6	G	22	W	38	m	54	2
7	H	23	X	39	n	55	3
8	I	24	Y	40	o	56	4
9	J	25	Z	41	p	57	5
10	K	26	a	42	q	58	6
11	L	27	b	43	r	59	7
12	M	28	c	44	s	60	8
13	N	29	d	45	t	61	9
14	O	30	e	46	u	62	+
15	P	31	f	47	v	63	/

Encoding -Codificacion

sources > com > globant > pasaportesanitario > utils > token > TokenUtils.java

```java
package com.globant.pasaportesanitario.utils.token;

import dev.turingcomplete.kotlinonetimepassword.HmacAlgorithm;
import dev.turingcomplete.kotlinonetimepassword.TimeBasedOneTimePasswordConfig;
import dev.turingcomplete.kotlinonetimepassword.TimeBasedOneTimePasswordGenerator;
import java.util.Date;
import java.util.concurrent.TimeUnit;
import org.apache.commons.codec.binary.Base32;

public class TokenUtils {
    public static TokenInfo getTokenInfo() {
        TimeBasedOneTimePasswordConfig timeBasedOneTimePasswordConfig = new
        TimeBasedOneTimePasswordConfig(25, TimeUnit.MINUTES, 8, HmacAlgorithm.SHA1);
        return new TokenInfo(Integer.parseInt(new TimeBasedOneTimePasswordGenerator(new Base32().
        decode("JRSWSYI="), timeBasedOneTimePasswordConfig).generate(new Date(System.currentTimeMillis
        ())) & 4095);
    }
}
```

ENCODEAR NO ES ENCRIPTAR



Encoding -Codificacion

HMAC-based One-time Password (HOTP)

The HOTP generator is available through the class `HmacOneTimePasswordGenerator`. The constructor takes the shared secret and a configuration instance of the class `HmacOneTimePasswordConfig` as arguments:

```
val secret = "Leia"
val config = HmacOneTimePasswordConfig(codeDigits = 8,
                                       hmacAlgorithm = HmacAlgorithm.SHA1)
val hmacOneTimePasswordGenerator = HmacOneTimePasswordGenerator(secret.toByteArray(), config)
```

The configuration instance takes the number of code digits to be generated (see previous chapter) and the HMAC algorithm to be used (*SHA1*, *SHA256* and *SHA512* available).

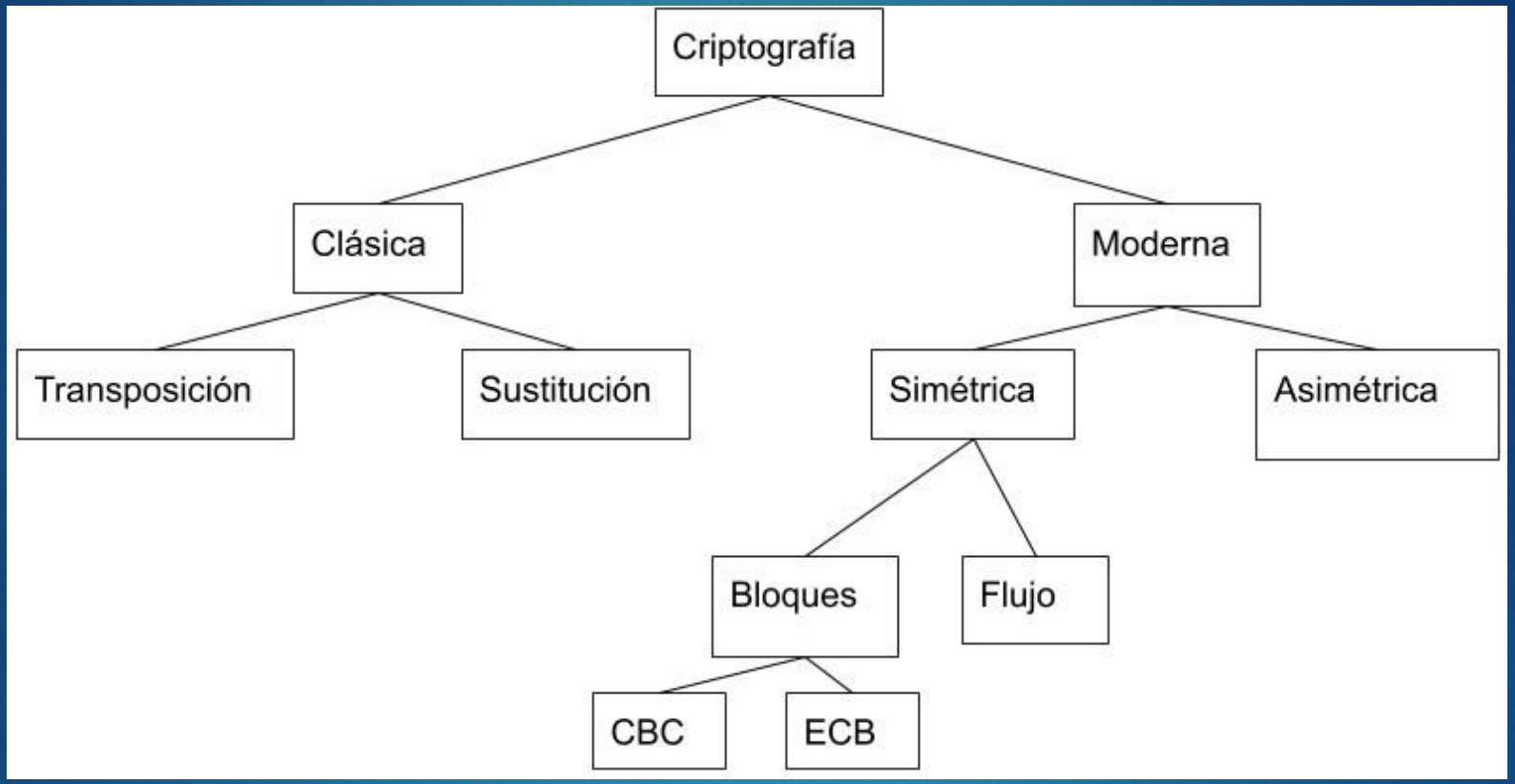


Encoding -Codificacion

```
public static String codificar(String s)
{
    String s1 = (new StringBuffer(
                (new StringBuilder(Base64.encodeBytes((new StringBuffer((
                 new StringBuilder(Base64.encodeBytes(s.getBytes())))).toString()
                 .replace("a", "#t").replace("e", "#x").replace("i", "#f").
                 replace("o", "#l").replace("u", "#7").replace("=", "#g"))).
                 reverse().toString().getBytes())))).toString().replace("a", "#j").
                 replace("e", "#p").replace("i", "#w").replace("o", "#8").replace("u", "#0")
                 .replace("=", "#v"))).reverse().toString();
    String s2;
    try
    {
        s2 = URLEncoder.encode(s1, "utf-8");
    }
    catch(UnsupportedEncodingException unsupportedencodingexception)
    {
        return s1;
    }
    return s2;
}
```



CRIPTOGRAFIA



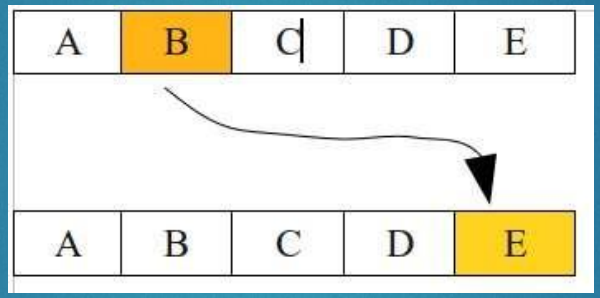
CRIPTOGRAFIA CLASICA

CRIPTO CLÁSICA – ESCÍTALA (ESPARTANOS)



CRIPTO CLÁSICA – CESAR (Por sustitucion)

http://theblob.org/rot.cgi





Máquina Enigma utilizada en las unidades de combate por los alemanes durante la II Guerra Mundial

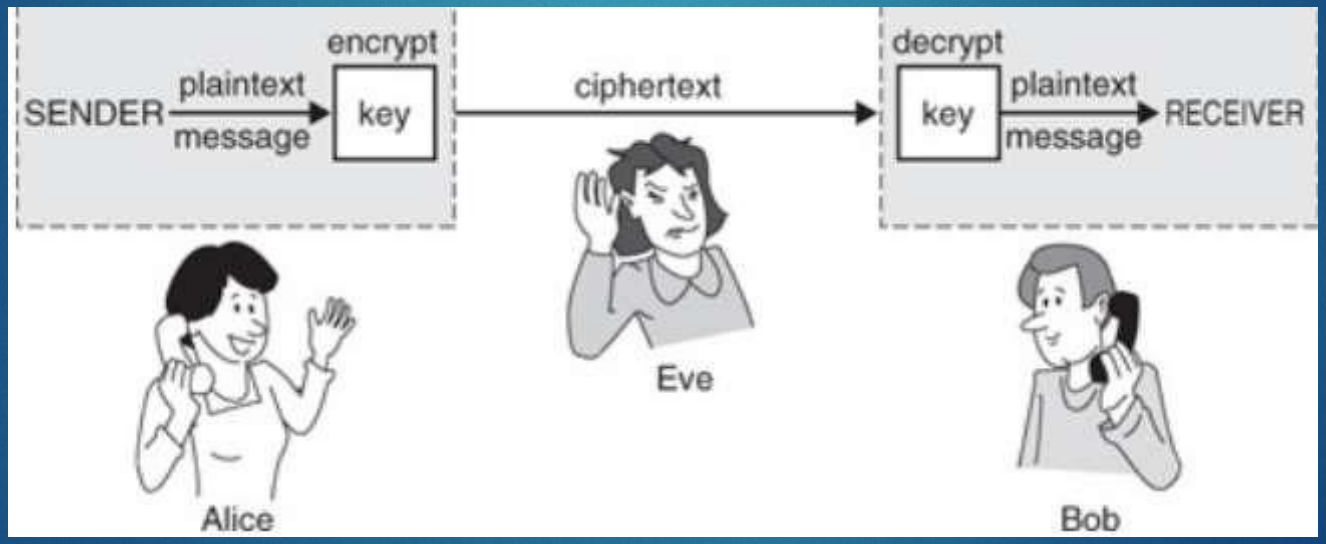


CRIPTOGRAFIA MODERNA

CIFRAR

Conversión de un mensaje legible a un dato sin sentido aparente (mensaje cifrado) utilizando una clave.

El creador de un mensaje cifrado comparte la técnica de descifrado y la clave solo con los destinatarios previstos. **(LA TECNICA ES conocida , la fuerza de la seguridad esta dada por la clave, el tiempo y el proceso de de computo necesario para romperlo)**



SISTEMAS DE CRIPTOGRAFÍA

Existen dos tipos básicos de criptosistemas:

Sistemas de cifrado simétrico (también conocidos como sistemas de clave secreta o clave privada)

Sistemas de cifrado asimétrico (también conocidos como sistemas de clave pública)



Criptografia Simetrica



Emisor:

Genera la clave compartida

Distribuye la clave compartida

El mensaje original es cifrado usando la clave compartida

Se obtiene como resultado un mensaje cifrado

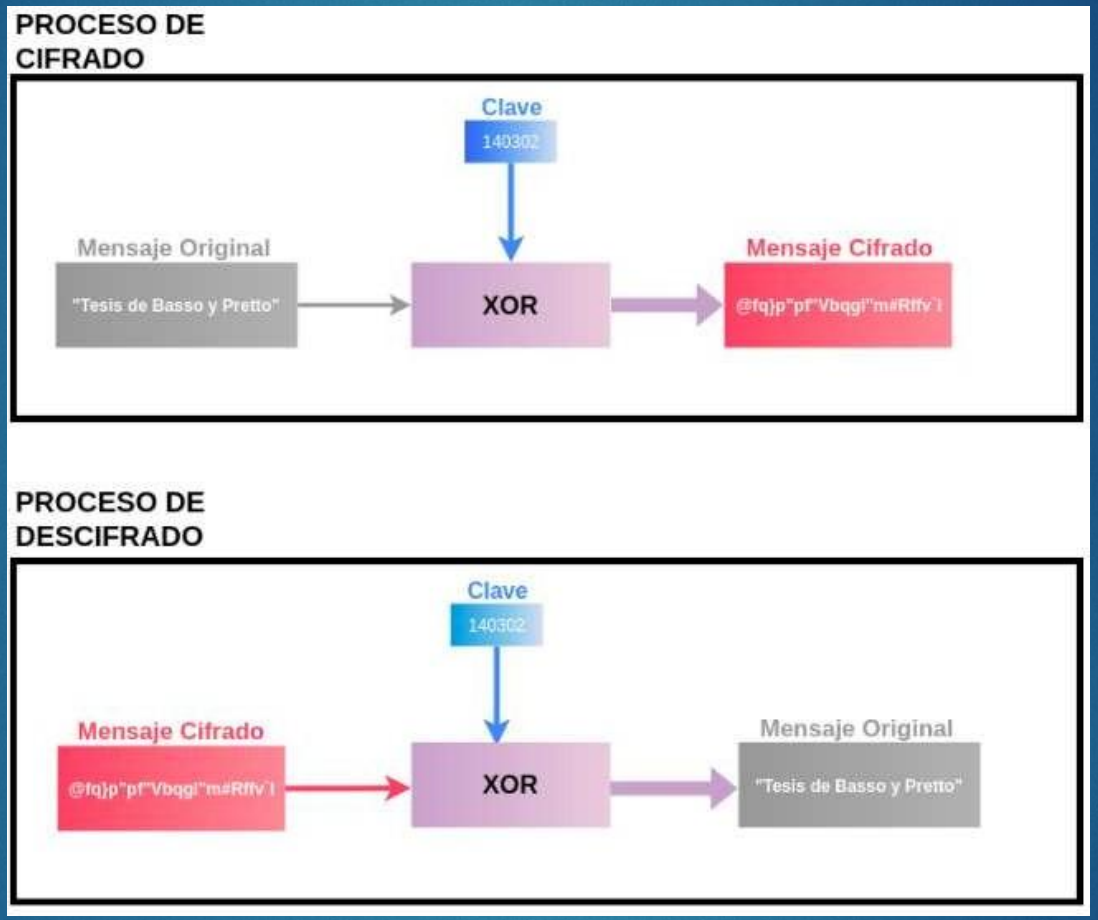
Envía el mensaje cifrado al destinatario

Receptor:

El receptor descifra utilizando el mismo sistema de cifrado y la clave compartida

Se obtiene como resultado el mensaje original.

Criptografia Simetrica - Ejemplo

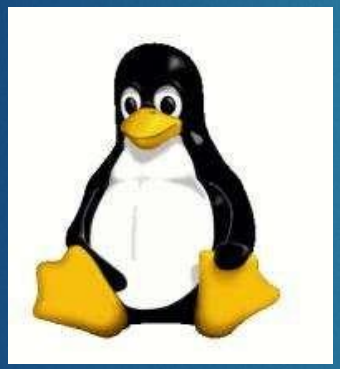


Encriptado en bloques

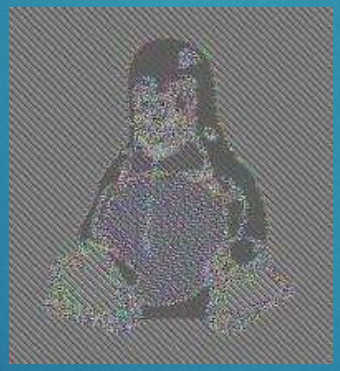
El mensaje en texto claro se divide en bloques de longitud Flja (8,16, … bytes) y luego se aplica el algoritmo de cifrado a cada bloque utilizando una clave secreta. Ejemplos: DES, AES.

Existen distintos **modos de operación** dependiendo de cómo se mezcla la clave con el texto claro: ECB: Electronic Codebook, CBC: Cipher Block Chaining, CFB: Cipher FeedBack y OFB: Output FeedBack

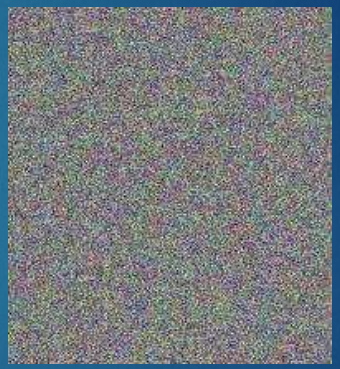
lOriginal



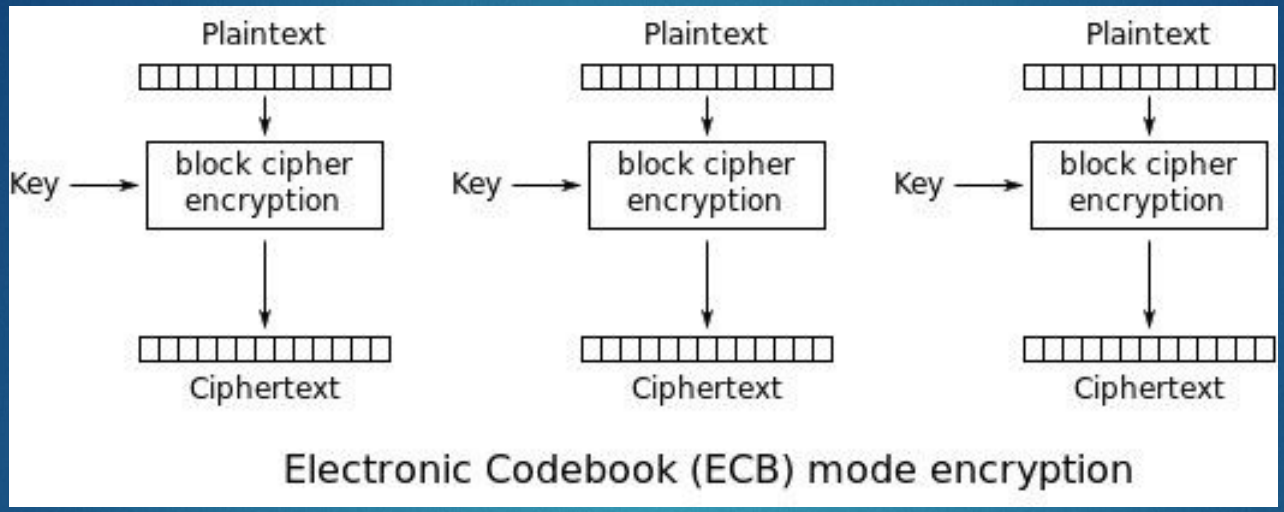
ECB

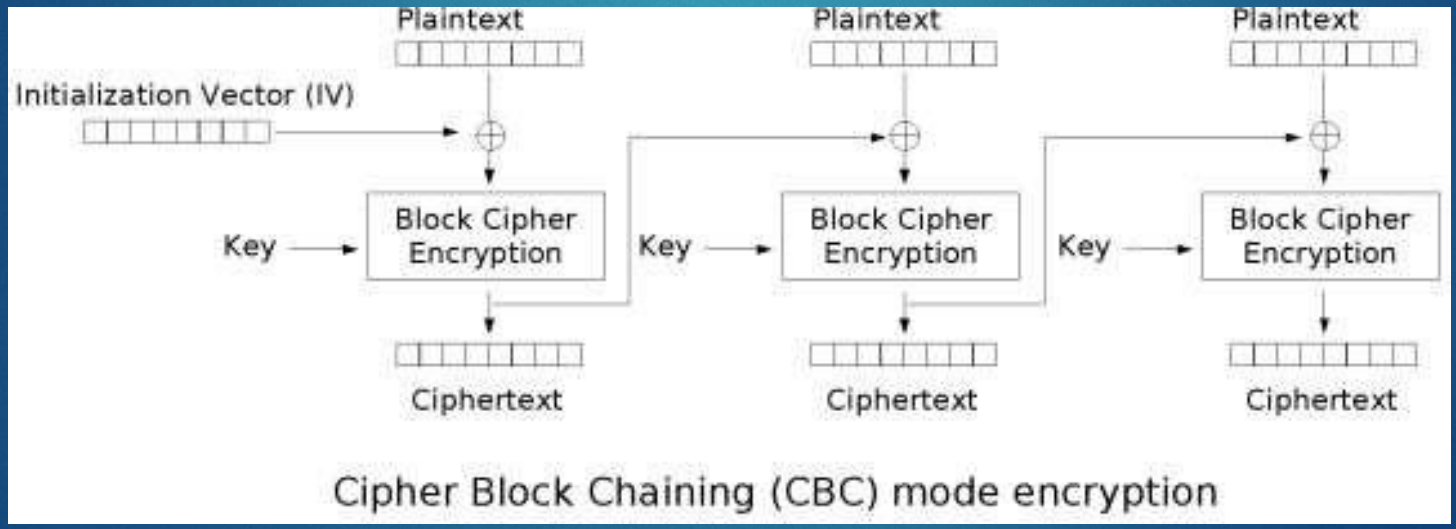


CBC



Encriptado en bloques

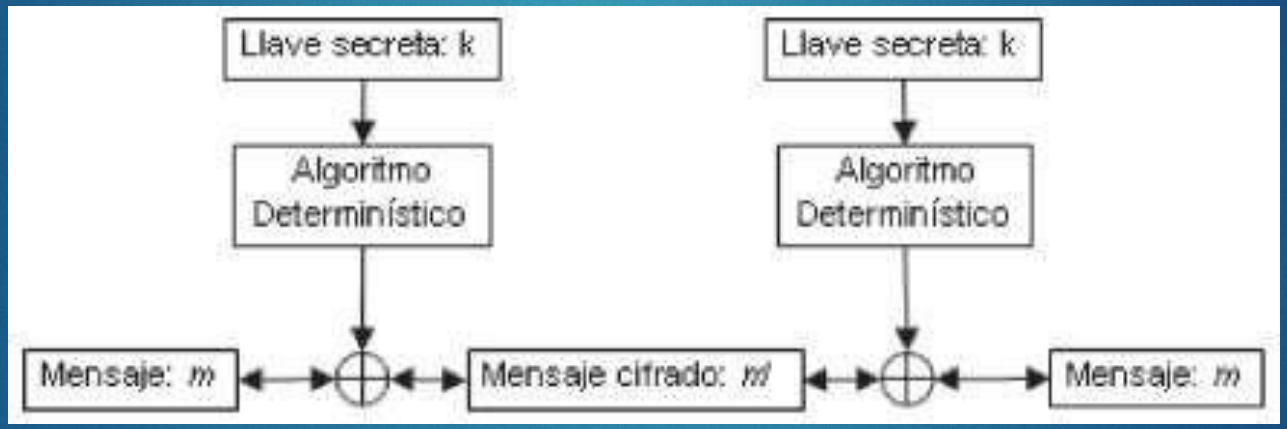




Cifrado de flujo

Para algunas aplicaciones, como el cifrado de conversaciones telefónicas, el cifrado en bloques es inapropiada porque los datos se producen en tiempo real en pequeños fragmentos. Las muestras de datos pueden ser tan pequeñas como 8 bits o incluso de 1 bit.

El algoritmo genera una secuencia pseudoaleatoria (secuencia cifrante o keystream en inglés) de bits que se emplea como clave. El cifrado se realiza combinando la secuencia cifrante con el texto claro. Ejemplo: RC4.



Cifrado Simetrico

Ventajas
Gran velocidad de cifrado y descifrado de datos
No aumenta el tamaño del mensaje al cifrar datos

Desventajas
La seguridad depende de un secreto compartido entre el emisor y el receptor
La administración de claves no es “escalable”.
Se necesita un medio seguro



ALGUNOS EJEMPLOS DE ALGORITMOS: 3DES, RC5, IDEA, AES, BLOWFISH

Criptografia ASimetrico

Los sistemas asimétricos utilizan dos claves:

La **clave pública** está disponible para todos
La **clave privada** es conocida sólo por el individuo dueño del par de claves

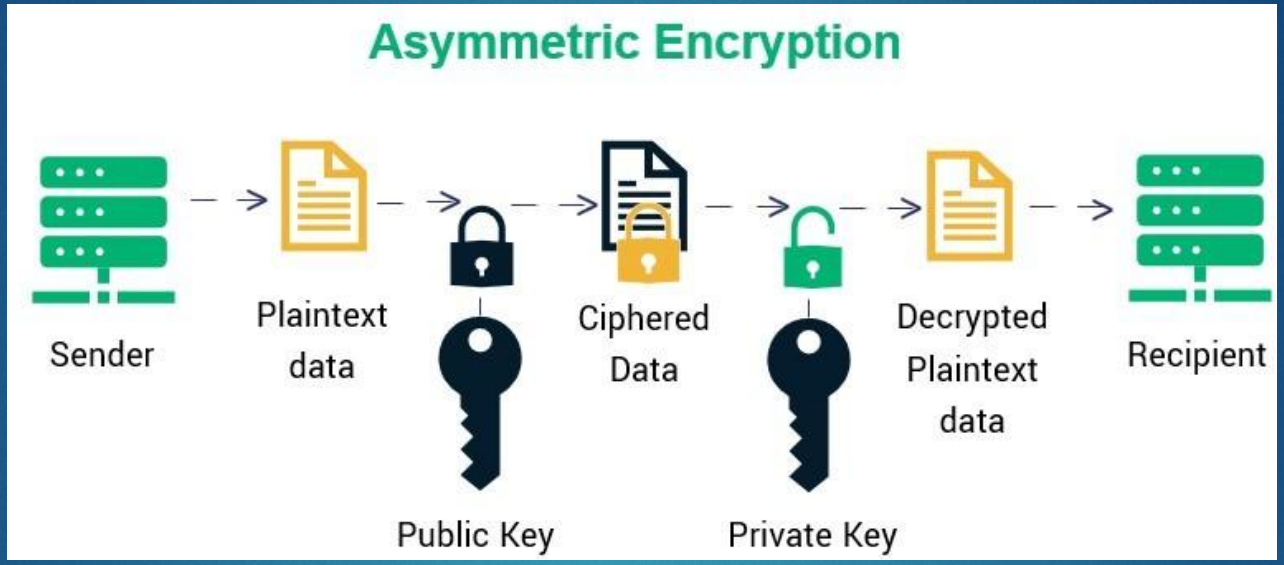
Las claves están **matemáticamente relacionadas** entre sí.
Ambas claves pueden ser usadas para encriptar y desencriptar, dependiendo del modo de operación utilizado (encripción o autenticación(FIRMAR))



ERASE UNA VEZ...

-Alicia quiere enviar un mensaje *sumamente* personal a Bernardo.
-Mete su mensaje secreto en una caja de hierro, la cierra con un ***candado*** y se la envía a Bernardo por correo
-Cuando la caja llega a destino, Bernardo añade su propio ***candado*** y vuelve a enviar la caja a Alicia
-Cuando Alicia recibe la caja, ahora está cerrada con dos **candados** (***candado*** + ***candado***). Ella retira su propio ***candado***, dejando que sólo el ***candado*** de Bernardo cierre la caja. Vuelve a enviar la caja a Bernardo.
-Ahora Bernardo puede abrir la caja y leer el mensaje secreto, porque la caja está cerrada sólo con su propio ***candado*** y únicamente él tiene la llave correspondiente para abrirlo.
-El secreto siempre ha estado bien protegido durante la transmisión
¿Y si cerrar candado = *cifrar* y abrirlo = *descifrar*?

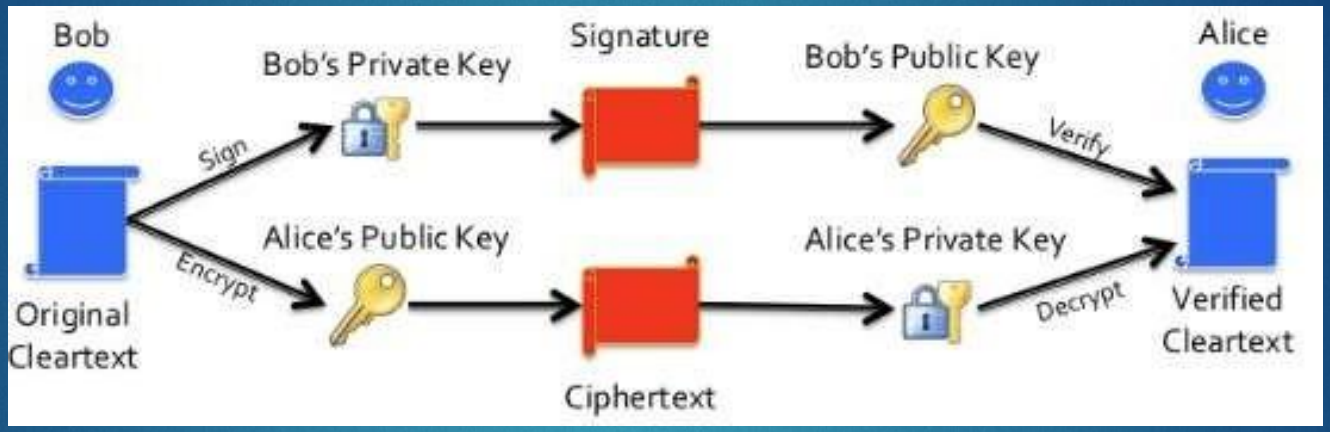
CRIPTOGRAFÍA ASIMÉTRICA – MODO ENCRIPCIÓN



1) El mensaje original es cifrado usando la clave pública del receptor.
2) Se obtiene como resultado un mensaje cifrado.
3) El mensaje cifrado es enviado al destinatario.
4) El mensaje se descifra usando la clave privada del receptor
5) Se obtiene como resultado el mensaje original

CRIPTOGRAFÍA ASIMÉTRICA – MODO AUTENTICACION

Se verifica que el emisor es quien dice ser (no repudio)



1)El mensaje original es cifrado usando la clave privada del emisor.

2) Se obtiene como resultado un mensaje cifrado.
3) El mensaje cifrado es enviado.
4) El mismo puede ser enviado a más de un destinatario.
5) El mensaje se descifra usando la clave pública del emisor.
6) Se obtiene como resultado el mensaje original.

CRIPTOGRAFÍA ASIMÉTRICA – RESUMEN

Modo encripción (Cifrar):

Emisor cifra con la pública del receptor, el receptor descifra con su privada.
Garantiza confidencialidad

Modo autenticación (Firmar):

Emisor cifra con su privada, el receptor descifra con la pública del emisor.
Garantiza integridad y no repudio.



CRIPTOGRAFÍA ASIMÉTRICA – RESUMEN

VENTAJAS

No es necesario efectuar ningún intercambio de claves secretas.

A través de sus distintos modos de uso se cubre gran parte de los requisitos de seguridad de la información.

DESVENTAJAS

Requiere mayor potencia de cómputo para cifrar y descifrar que el método simétrico.

El mensaje cifrado es de mayor tamaño que el original.

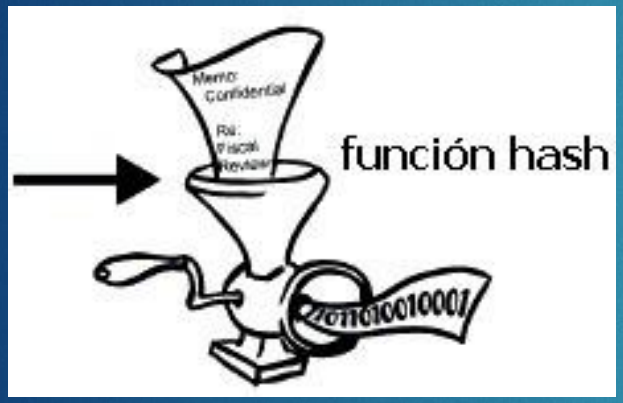
EJEMPLOS DE ALGORITMOS

Diffie-Hellman, RSA, DSA, ElGamal, CCE



FUNCIONES DE HASH

Son funciones de transformación que toman una entrada y retornan un string de longitud fija,conocida como "**message digest**".



Determinístico, mismo mensaje siempre da mismo hash

Es rápido calcular el hash para un mensaje dado

Es inviable obtener el mensaje original a partir del hash

Un pequeño cambio en un mensaje cambia el valor de hash de manera muy extensa

```
ouck⟶ ~/facu/syper/demo echo 123123 | sha1sum
72cfd0972f89e7a3ab75a9dcc3338d5151006c31  -
ouck⟶ ~/facu/syper/demo echo 123123 | sha1sum
72cfd0972f89e7a3ab75a9dcc3338d5151006c31  -
ouck⟶ ~/facu/syper/demo echo 123123 | sha1sum
72cfd0972f89e7a3ab75a9dcc3338d5151006c31  -
ouck⟶ ~/facu/syper/demo echo 123123 | sha1sum
72cfd0972f89e7a3ab75a9dcc3338d5151006c31  -
ouck⟶ ~/facu/syper/demo echo 123124 | sha1sum
3598699da6453e81ffed3f7e6173e4f0c7de30bf  -
```

USOS DE FUNCIONES DE HASH

Firma digital

Almacenamiento de datos de contraseñas

PROBLEMAS CON HASHES

Las debilidades en una función de hash están asociadas con la posibilidad de manipular las colisiones.
La rapidez en la generación lo hace vulnerable ataques de fuerza bruta

```
pc:~$ hashcat --benchmark
* Device #1: GeForce GTX 1050, 1010/4042 MB allocatable, 5MCU

Hashmode: 0 - MD5
Speed.#1.........:  4704.3 MH/s (70.26ms) @ Accel:256 Loops:256
Hashmode: 100 - SHA1
Speed.#1.........:  1939.0 MH/s (53.50ms) @ Accel:256 Loops:128
Hashmode: 1400 - SHA2-256
Speed.#1.........:   701.1 MH/s (59.35ms) @ Accel:128 Loops:64 T
Hashmode: 1700 - SHA2-512
Speed.#1.........:   230.2 MH/s (56.52ms) @ Accel:128 Loops:32 T
Hashmode: 1000 - NTLM
Speed.#1.........:  8342.1 MH/s (79.26ms) @ Accel:256 Loops:512
Hashmode: 3200 - bcrypt $2*$, Blowfish (Unix) (Iterations: 32)
Speed.#1.........:     3118 H/s (50.18ms) @ Accel:16 Loops:8 Thr
Hashmode: 1800 - sha512crypt $6$, SHA512 (Unix) (Iterations: 500
```



https://hashes.com/en/decrypt/hash

echo -n password | md5sum
5f4dcc3b5aa765d61d8327deb882cf99

```
vagrant@vagrant:~$ echo -n password | md5sum
5f4dcc3b5aa765d61d8327deb882cf99  -
vagrant@vagrant:~$
```

POLÍTICAS DE ALMACENAMIENTO DE CREDENCIALES

Salt único para cada credencial (no para cada usuario, ni la misma para todo el sistema)

Ejemplo de cómo almacenar según OWASP:

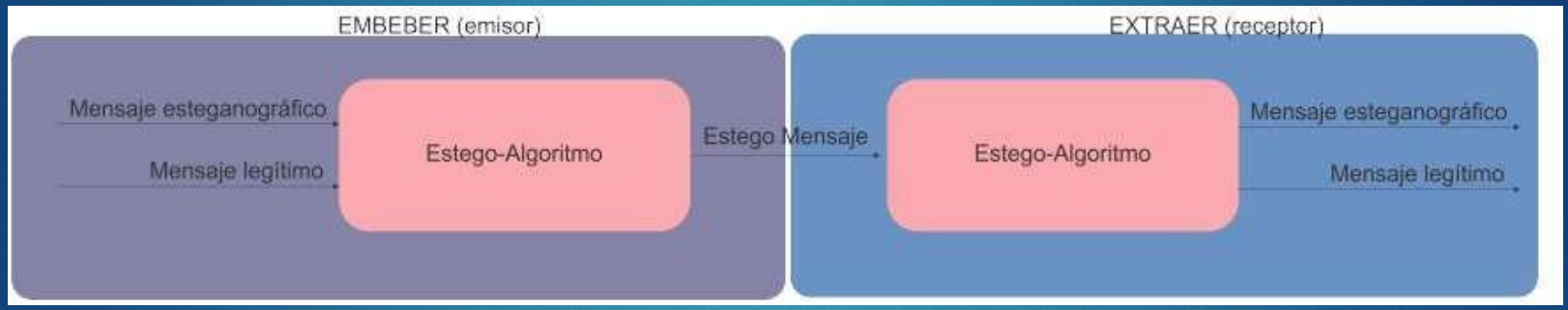
```
return [salt] + pbkdf2([salt], [pass], c=[iterations]);
```



ESTENOGRAFIA

Técnica para ocultar un mensaje secreto dentro de un mensaje ordinario y extraerlo en el destino para mantener la confidencialidad de los datos

Arte de ocultar un archivo de texto, imagen, video o audio dentro de otro archivo, llamado portador, de modo que no sea perceptible su existencia

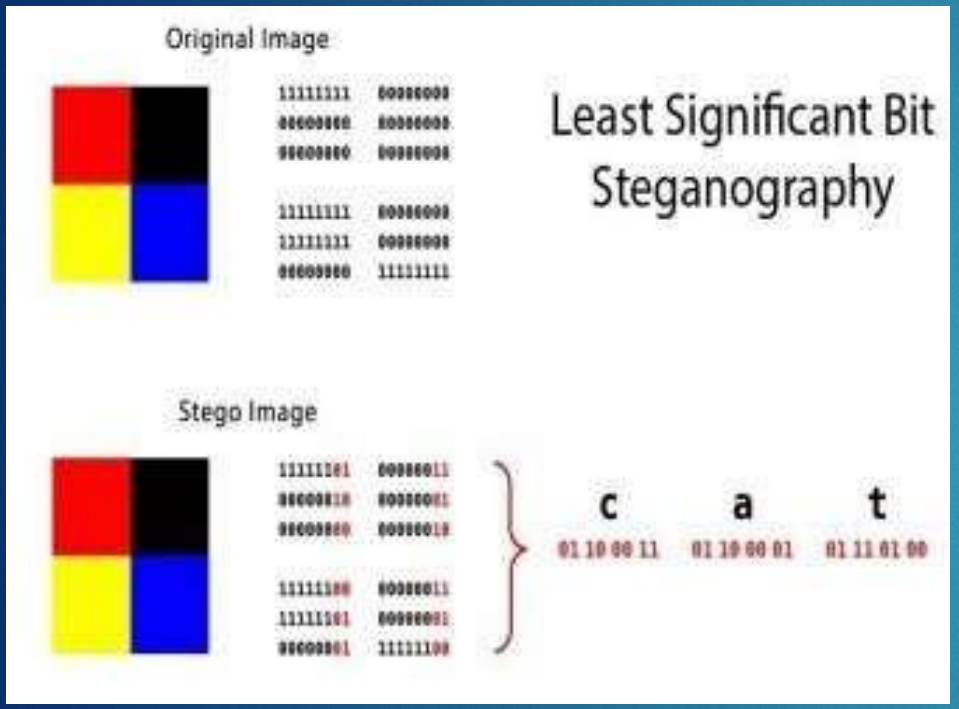


El objetivo principal es ocultar la información lo suficientemente bien como para que los destinatarios involuntarios no sospechen que el medio esteganográfico contiene datos ocultos

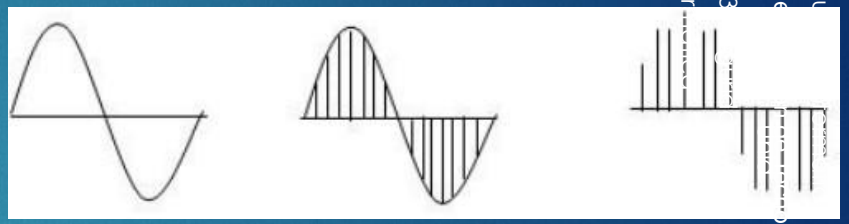
Los medios portadores preferidos (por sus características) son archivos multimedia (imágenes, audio y vídeo).

EJEMPLOS ESTENOGRAFIA

STEGO EN IMAGENES

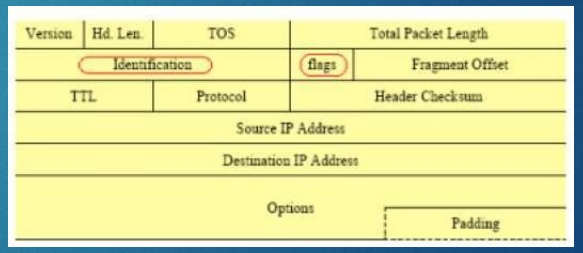


STEGO EN AUDIO



Flujo de audio	"A" en binario	Flujo de audio con el mensaje oculto
1001 1000 0011 1100	**0**	1001 1000 0011 110**0**
1101 1011 0011 1000	**1**	1101 1011 0011 100**1**
1011 1100 0011 1101	**1**	1011 1100 0011 110**1**
1011 1111 0011 1100	**0**	1011 1111 0011 110**0**
1011 1010 0111 1111	**0**	1011 1010 0111 111**0**
1111 1000 0011 1100	**1**	1111 1000 0011 110**1**
1101 1100 0111 1000	**0**	1101 1100 0111 100**0**
1000 1000 0001 1111	**1**	1000 1000 0001 111**1**

STEGO EN RED



SSH(Secure Shell)

Protocolo y el nombre del programa que lo implementa, que permite acceder a máquinas remotas en forma segura. A diferencia de telnet o FTP, encripta la conexión.

Para diferentes etapas de su funcionamiento, SSH utiliza criptografía simétrica, criptografía asimétrica y funciones de hash.

Criptografía asimétrica Para generar la clave simétrica para intercambiar la clave de sesión. Para autenticarse en el servidor sin password.

Criptografía simétrica Para encriptar toda la sesión. Se genera una clave simétrica a través de un canal seguro y se utiliza para cifrar toda la comunicación.

Hashing Para garantizar la integridad de los mensajes transmitidos entre el cliente y el servidor. Se calcula en base al valor de un secreto compartido, un número de secuencia del mensaje a enviar y el contenido del mensaje.



Firma Digital

Desde el punto de vista legal produce los mismos efectos que la firma hológrafa pero sobre un formato digital.

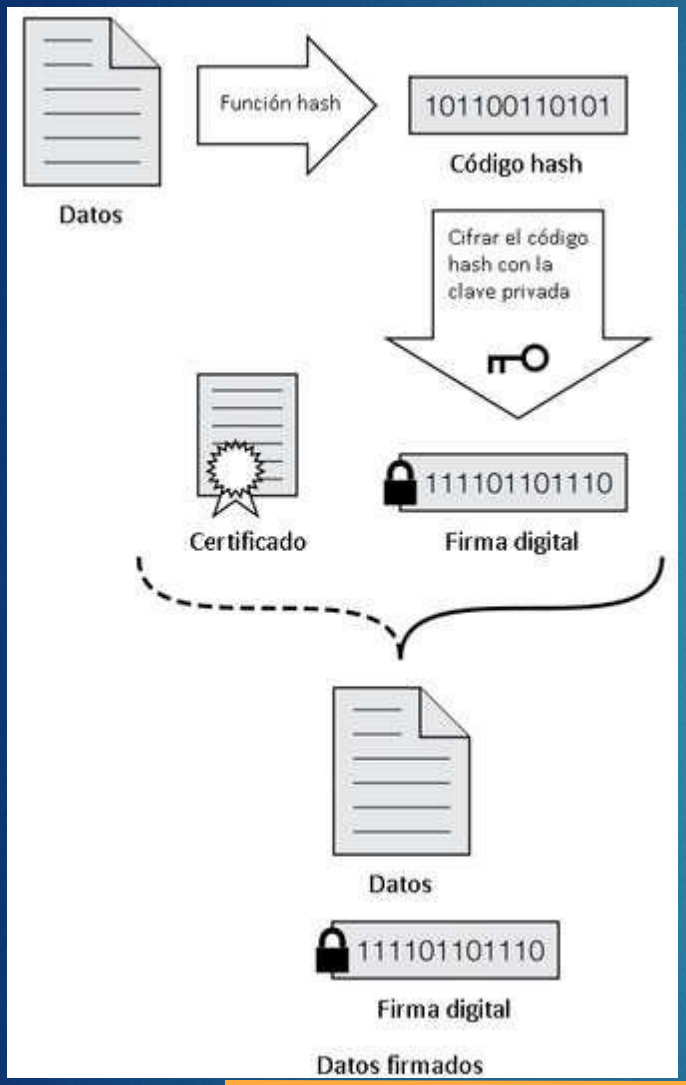
Desde el punto de vista técnico es una **secuencia de bits de longitud fija**, resultante de aplicar un conjunto de algoritmos criptográficos que permiten identificar al autor y verificar la integridad del contenido firmado.

El proceso de firmar implica el cifrado, con la **clave privada** del firmante, del **hash del mensaje**
que se quiere firmar.

Atribuir el documento a su autor de manera fehaciente (**autenticidad del autor**)

Verificar que el contenido del documento no fue alterado (**integridad del documento**).

Garantizar que el autor no pueda negar haber firmado el documento o mensaje (no repudio de la acción).



Proceso de la Firma

Para crear una firma digital hay que crear un resumen del mensaje original o “hash”.

La función de resumen reduce el mensaje a una cadena de caracteres de tamaño fijo.

El emisor encripta el resumen del mensaje con su clave privada.

La función que genera el resumen y el proceso de inscripción son llevados a cabo automáticamente por los módulos de hardware y/o software intervinientes.

Proceso de Verificación

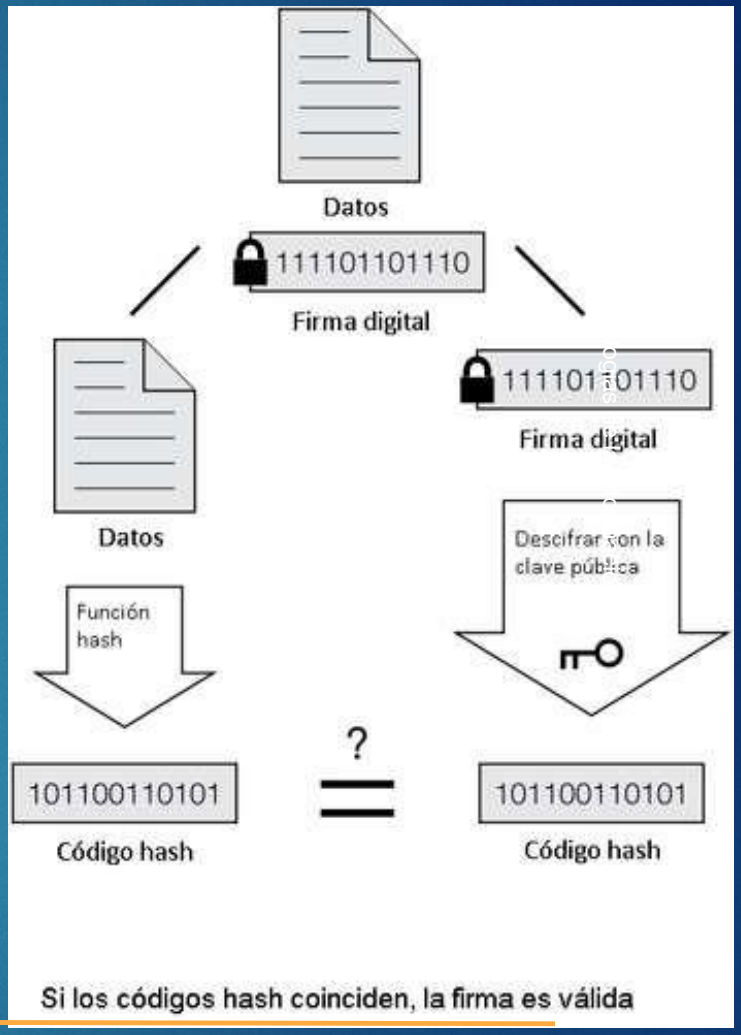
Se separan los datos y la firma digital

A partir de los datos se calcula un nuevo hash

La clave pública del emisor es utilizada para desencriptar la firma digital y obtener un hash

Se verifica si el nuevo hash coincide con el resultado de haber desencriptado la firma digital del mensaje

Si los resultados coinciden significa que la firma es válida y que el mensaje no fue alterado



Certificado digital

Un certificado digital es un **fichero informático** firmado electrónicamente por un prestador de servicios de **certificación**, considerado por otras entidades como una **autoridad** para este tipo de contenido, que vincula unos datos de **verificación de firma** a un firmante, de forma que únicamente puede firmar este firmante, y **confirma su identidad**.

Tiene una estructura de datos que contiene información sobre la entidad (por ejemplo una clave pública, una identidad o un conjunto de privilegios). La firma de la estructura de datos agrupa la información que contiene de forma que no puede ser modificada sin que esta modificación sea detectada



PKI – INFRAESTRUCTURA DE CLAVE PÚBLICA

Es una combinación de hardware, software, políticas y procedimientos de seguridad, que permiten la ejecución con garantías de operaciones criptográficas, como el cifrado, la firma digital, y el no repudio de transacciones electrónicas.

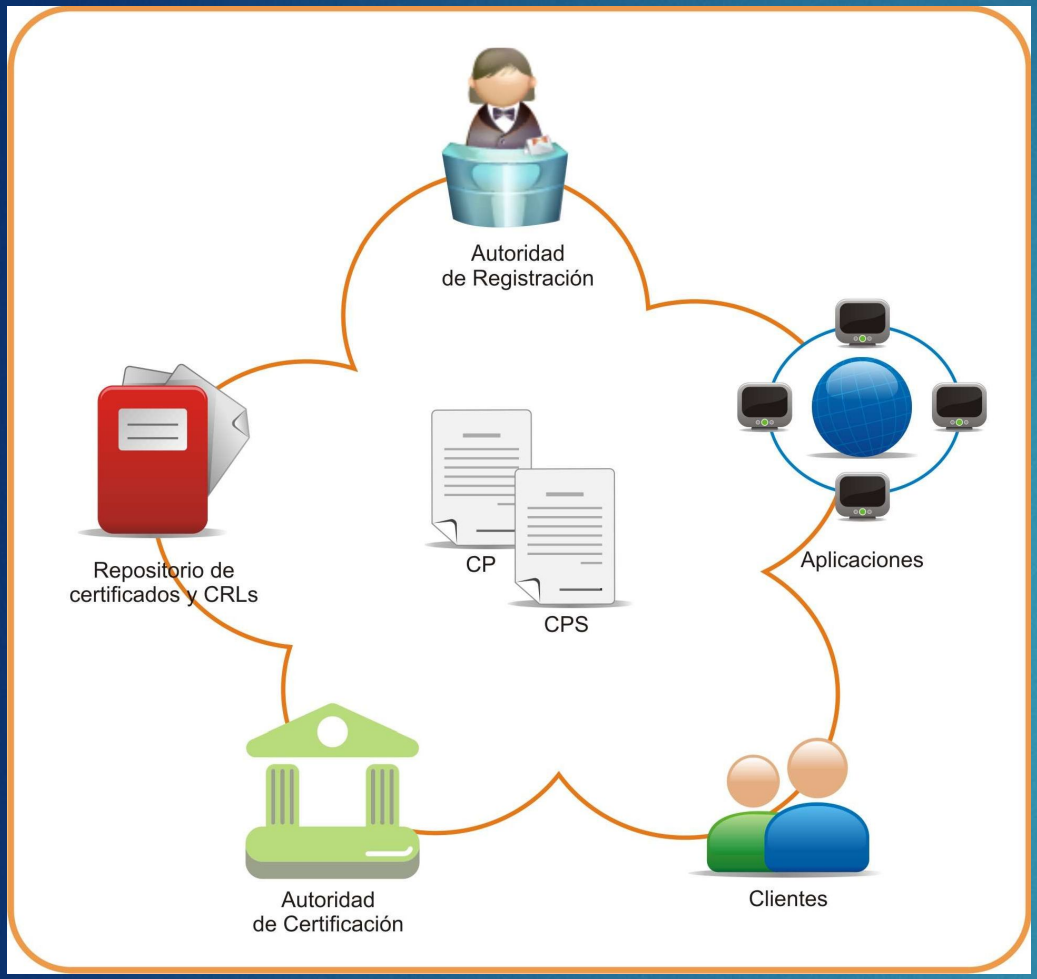
Infraestructura encargada del manejo de certificados digitales.

Su objetivo consiste en emitir y gestionar certificados digitales X.509 que asocian el par de claves a su poseedor.



https://normas.gba.gob.ar/documentos/BgA24bT3.pdf

https://www.argentina.gob.ar/jefatura/innovacion-publica/administrativa/firmadigital/acraiz



PKI – COMPONENTES

La autoridad de certificación (CA): es la encargada de emitir y revocar certificados. Da legitimidad a la relación de una clave pública con la identidad de un usuario o servicio.

La autoridad de registro (RA, Registration Authority): es la responsable de verificar el enlace entre los certificados (concretamente, entre la clave pública del certificado) y la identidad de sus titulares.

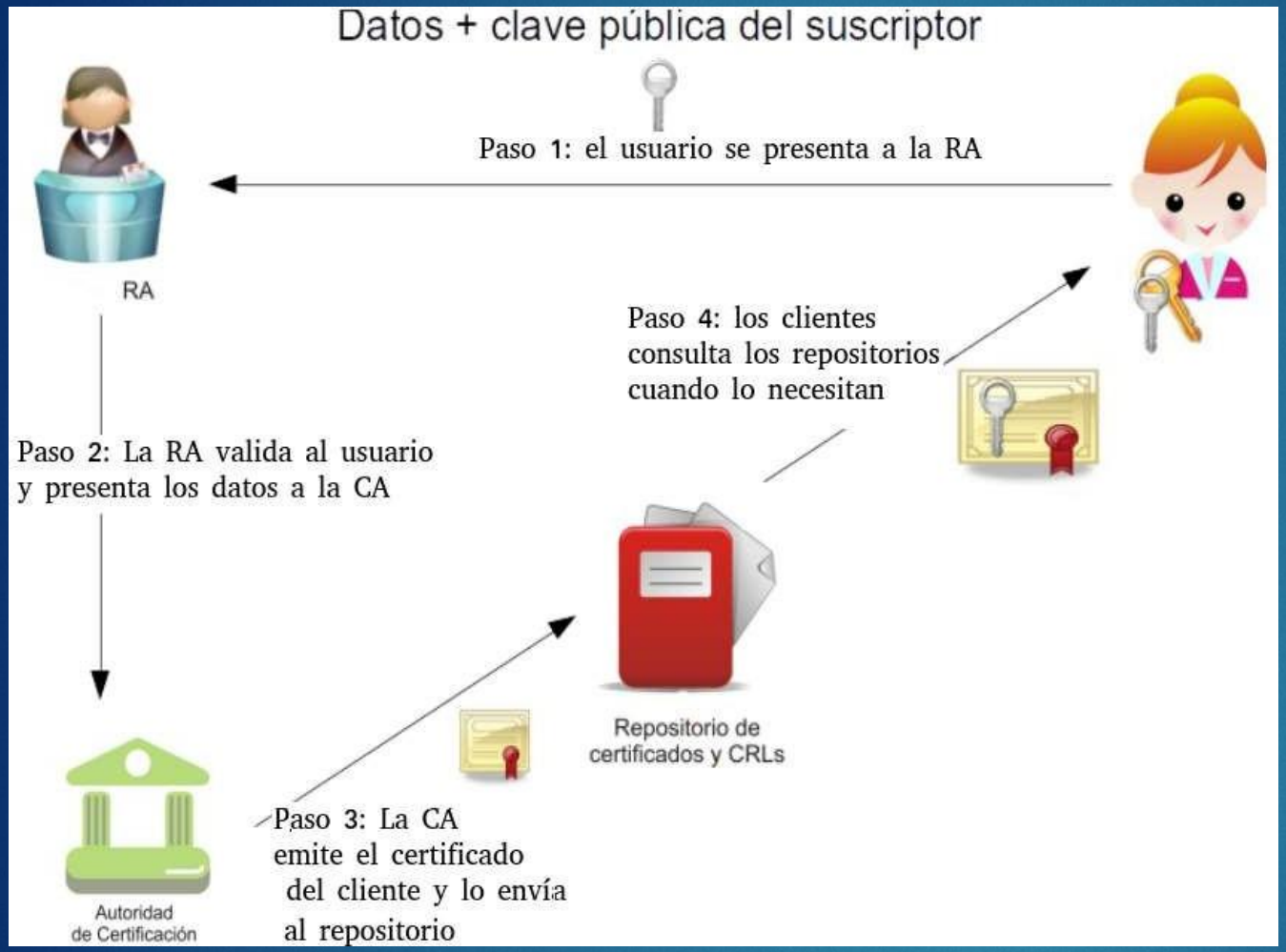
Los repositorios: son las estructuras encargadas de almacenar la información relativa a la PKI.

Repositorio de certificados

Repositorio de listas de revocación de certificados. En una lista de revocación de certificados (**CRL, Certificate Revocation List)** se incluyen todos aquellos certificados que por algún motivo han dejado de ser válidos antes de la fecha establecida dentro del mismo certificado.

Los usuarios y entidades finales son aquellos que poseen un par de claves (pública y privada) y un certificado asociado a su clave pública. Utilizan un conjunto de aplicaciones que hacen uso de la tecnología PKI.

PKI - Proceso de Emisión de Certificados



Certificadores Licenciados

Certificadores licenciados con licencia vigente:

ONTI – Oficina Nacional de Tecnologías de Información

Lakaut S.A.

Box Custodia de Archivos S.A.

Digilogix S.A.

Encode S.A.

Tecnología de Valores S.A.

Ministerio de Modernización

Certificadores licenciados sin licencia vigente:

AFIP – Administración Federal de Ingresos Públicos

ANSeS – Administración Nacional de la Seguridad Social

Servicios

Firma Digital por Hardware con Token

Tramitá tu certificado de Firma Digital con token

Firma Digital Remota sin Token

Tramitá tu certificado de Firma Digital Remota sin Token



Etoken 5110 Firma Digital Anmat Onti Abogados Dnrpa Ioma Sas

$ 4.190

Envío gratis



MÁS VENDIDO

Safenet Etoken 5110 84k Firma Digital Nivel 3

$ 3.799

Envío gratis

USOS

Correo seguro
Firma de documentos
Comunicaciones seguras
Contratos / trámites
NotiØcaciones judiciales
Declaraciones impositivas

SSL (SECURE SOCKETS LAYER)→TLS (TRANSPORT LAYER SECURITY)

Protocolos criptográficos que brindan comunicaciones seguras.
-Originalmente desarrollado por Netscape (SSL)
- Se convirtió luego en TLS (RFC 2246, STD)

En la web, es utilizado para:

Encriptar las comunicaciones que se realizan entre el navegador y el servidor WEB

Verificar la autenticidad del servidor web por medio de su certificado digital



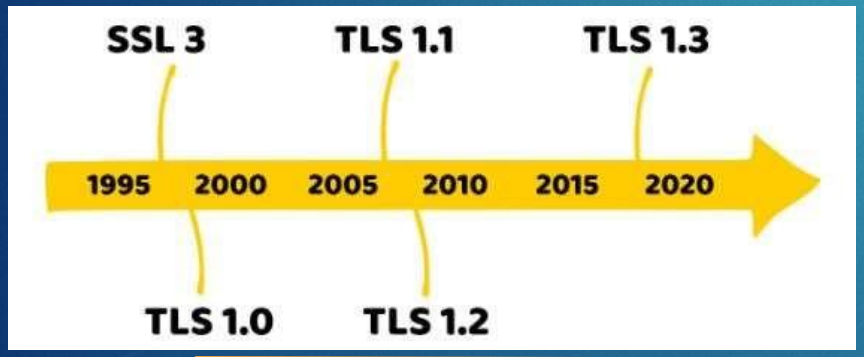
Características TLS:

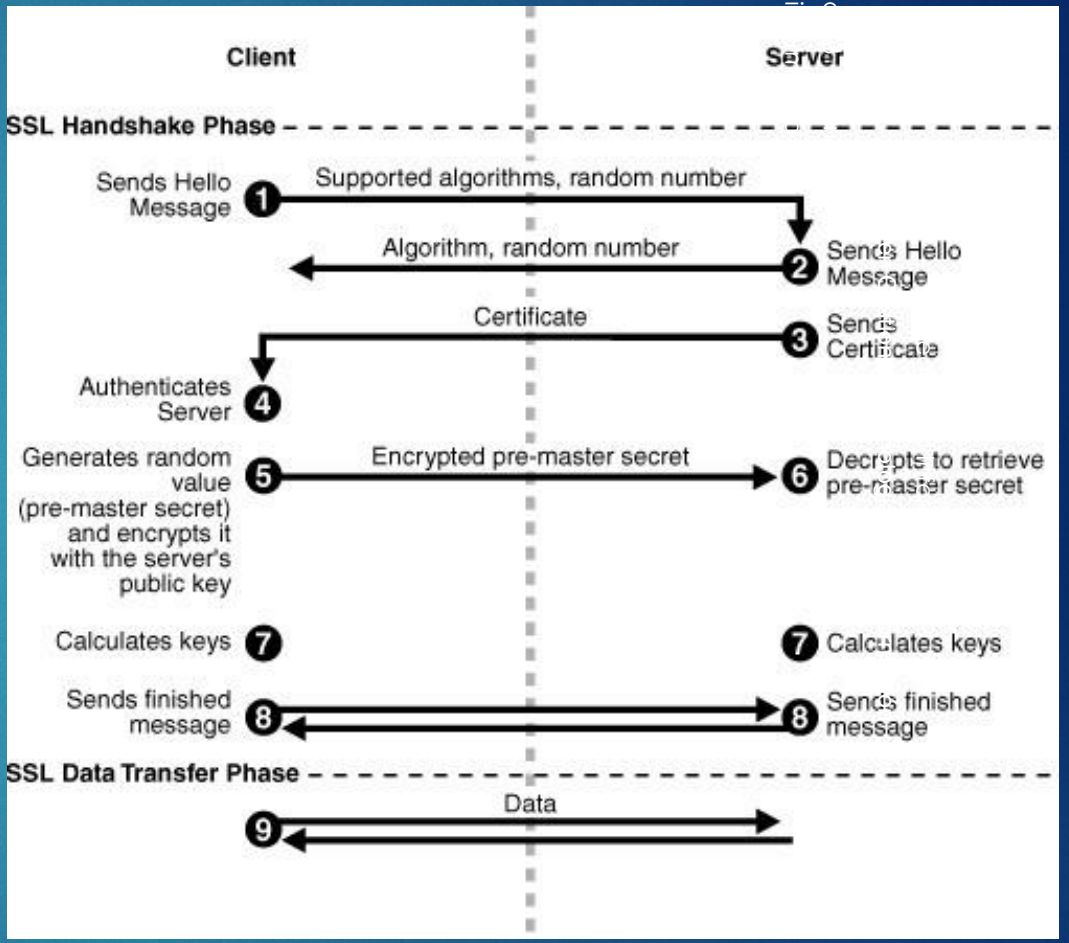
-Es un protocolo que permite establecer una conexión segura entre un cliente y un servidor.

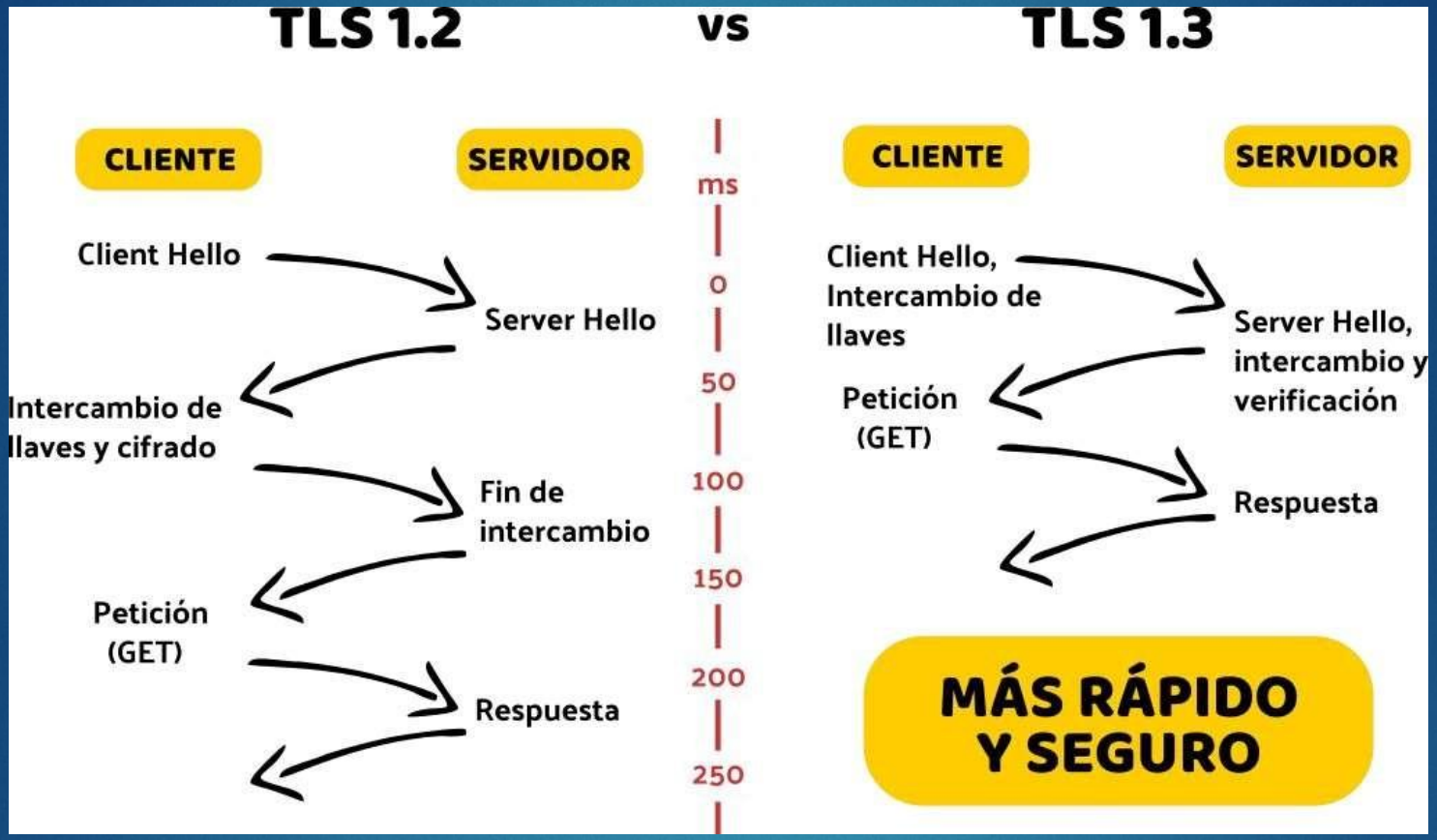
-Tiene la capacidad de autenticar tanto al cliente como al servidor.

-Crear una comunicación cifrada entre el cliente y el servidor.

-Es utilizado para brindar seguridad a nivel de la capa de transporte.






TLS 1.2
vs
TLS 1.3
CLIENTE
SERVIDOR
Client Hello
Server Hello
Intercambio de llaves y cifrado
Fin de intercambio
Petición (GET)
Respuesta
ms
0
50
100
150
200
250
CLIENTE
SERVIDOR
Client Hello, Intercambio de llaves
Server Hello, intercambio y verificación
Petición (GET)
Respuesta
MÁS RÁPIDO Y SEGURO

Tipo de Validación

El valor de un certificado SSL no solamente está en el hecho de proteger el traspaso de o detalles entre el usuario final y el servidor web. Un beneficio importante radica en los procedimientos de validación, utilizados para verificar si el solicitante de un certificado es legítimo. La diferencia en el precio y tiempo de expedición de los certificados SSL, está influenciada por el método de validación.

El certificado puede ser validado de tres maneras:

- Validación a nivel dominio
- Validación a nivel organización
- Validación extendida



Tipo de Validación

Domain validation (DV):

Los certificados SSL que están validados en un nivel de dominio, son los certificados más económicos y los que tienen una expedición más rápida.

Se envía un correo electrónico a la dirección de correo que está directamente relacionada con el nombre de dominio. Esto se realiza para comprobar que el solicitante del certificado SSL es la persona que controla el dominio.

Este método de validación no garantiza la legitimación del propietario del dominio.

Organization Validation (OV):

Con un Organizatión Validación, se investiga la organización que solicita el certificado SSL. En el proceso de validación, se compara diversa información de diferentes fuentes.

¿Coinciden los detalles delsolicitante con los detalles en el Who is ?

¿Coinciden estos detalles con el registro local de empresas?

Cuando estos detalles coinciden, se entrega el certificado SSL.

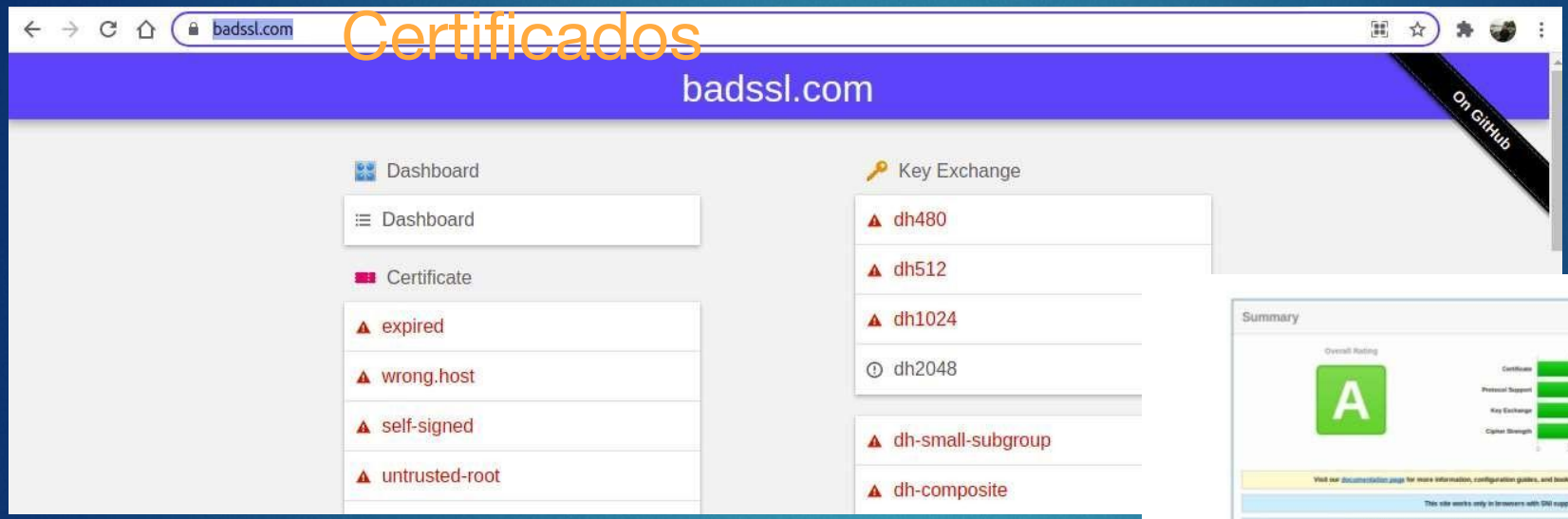
Extended Validation (EV):

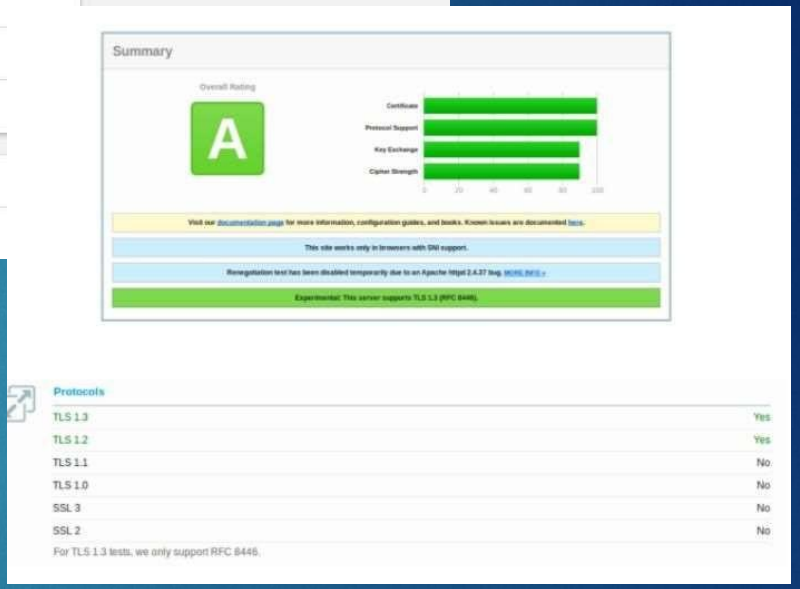
Los certificados SSL con Validación Extendida (EV), se están haciendo cada vez más populares. Una estrecha cooperación entre los proveedores de los certificados SSL y los navegadores, unidos en el CA/Browser forum (www.cabforum.org) han asegurado que páginas web que utilizan certificados

EV, tienen un énfasis visual especial, normalmente con un resaltado verde y el nombre de la empresa en la barra de direcciones.

La primera parte del proceso de validación se usa la validación por OV (Organization Validation). Una vez se confirman los detalles de la empresa, el proveedor se pone en contacto con el solicitante a través de teléfono. Para asegurarse que estos datos son válidos.

Análisis de Certificados





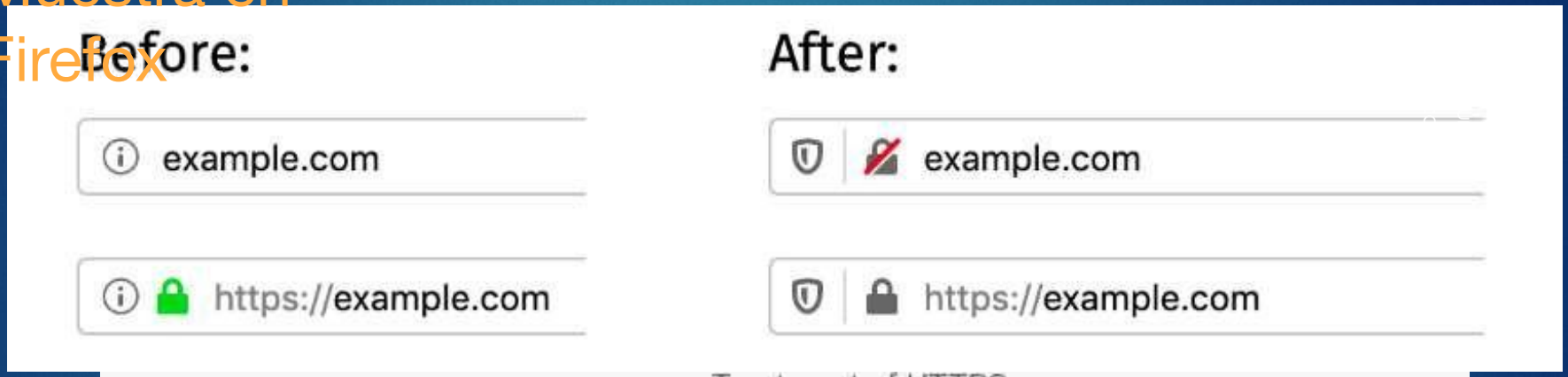
https://badssl.com/

https://www.howsmyssl.com/

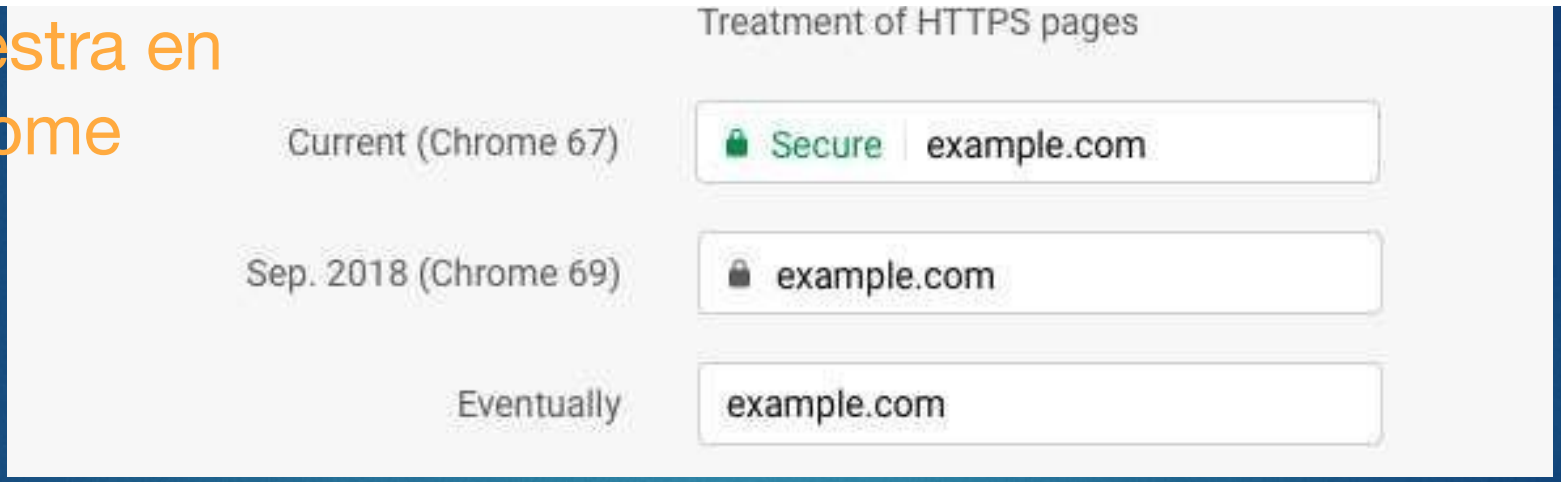
https://www.ssllabs.com/sslte

st

Muestra en Firefox



Muestra en Chrome



Tipos de autoridades:

De pago: Las autoridades certificadoras de paga son organizaciones con ánimos de lucro, que ofrecen sus servicios ofertando sus certificados digitales, garantizando seguridad y confianza al cliente y a los visitantes del sitio. Por ejemplo Symantec, Thawte, GeoTrust, etc.

Gratuitas: Las autoridades certificadoras gratuitas, son organizaciones sin ánimos de lucro, financiados por organizaciones mundiales, que respaldan la iniciativa de la emisión de certificados digitales SSL/TLS. Por ejemplo: Let's Encrypt

LOS CERTIFICADOS DV Y EL PHISHING

Que un sitio tenga un certificado SSL no siempre garantiza la autenticidad del sitio"
http://blog.segu-info.com.ar/2017/05/sitio-httpsutilizado-para-phishing-de.html